

Ciao a tutti.

Metto a disposizione i miei appunti di **Etica, Società e Privacy** professor **Pensa**.
Consiglio vivamente di seguire le lezioni e magari affiancare questi appunti.
Potrebbero presentarsi, alle volte, problemi legati all'italiano, *ide* anzichè *idea*.

Potrebbe mancare qualcosina... ma ina ina ina. Spero di essere d'aiuto.

Buono studio e un abbraccio dal vostro **Cirino Pomicino**.

Contents

1	Privacy and Data Protection	2
1.1	La privacy e le leggi sulla privacy	2
1.1.1	Che cos'è la privacy?	2
1.1.2	Che cosa è stato deciso a livello di standard internazionale?	3
1.1.3	Perché la privacy è così importante?	4
1.1.4	Quali tipi di privacy conosciamo?	4
1.2	Data Privacy	5
1.2.1	La Data Privacy negli Stati Uniti	6
1.2.2	La Data Privacy in Canada	8
1.2.3	La legge sulla privacy nell'Unione Europea	8
1.3	Data Protection Directive	8
1.3.1	Personal Data	9
1.3.2	Data Processing	9
1.3.3	Responsabilità	10
1.3.4	Processor	10
1.4	Principi fondamentali che sono alla base di qualsiasi trattamento del dato personale	10
1.4.1	La trasparenza	10
1.4.2	La proporzionalità	11
1.5	La Privacy Authority	12
1.6	Il GDPR	12
1.6.1	Privacy by Design by Default	14
1.6.2	La pseudonimizzazione all'interno del GDPR	15
1.6.3	Responsability e accountability	15
1.6.4	Il data protection officer (DPO)	16
1.6.5	Il data breach	16
1.7	Il passaggio da una nazione all'altra	17
2	Privacy in the «Big Data Era»	18
3	Information Systems and Privacy	21
3.1	Information system	21
3.1.1	Computer Information System	21
3.1.2	Information Systems and (private) data	22
3.1.3	Sistema informatico e il GDPR	23
3.2	Attributed Based Authorization	24
3.2.1	Access Control	24
3.2.2	Role Based Access Control (RBAC)	24
3.2.3	Attributed Based Access Control (ABAC)	25
3.2.4	XACML	27

4	Pseudonimizzazione usando l'encryption	30
4.1	Introduzione alla pseudonimizzazione	30
4.1.1	Differenza con l'anonimizzazione	31
4.1.2	Column Encryption e la sua realizzazione	31
4.1.3	Deterministic Encryption	32
4.1.4	Cifatura randomizzata	32
4.1.5	Realizzazione di Encryption all'interno di database commerciali	32
4.1.6	Dynamic Data Masking	33
4.1.7	Conclusioni	33
4.2	L'auditing	34
4.2.1	Processo di auditing	35
4.2.2	Il Data Auditing	35
4.2.3	L'auditing model 1	36
4.2.4	L'auditing model 2	36
4.2.5	Historical Auditing Model	37
4.2.6	Esempi nei più importanti database	37
4.2.7	Conclusioni	37
5	Statistical disclosure control	38
5.1	Statistical data dissemination	38
5.2	La disclosure - nozioni generali	39
5.2.1	Macrodata vs Microdata	39
5.3	La disclosure	40
5.3.1	Information disclosure	40
5.3.2	Identity Disclosure Protection	40
5.3.3	Attribute Disclosure	41
5.3.4	Inference Disclosure	41
5.3.5	Restricted data and restricted access	41
5.4	Statistical Disclosure Control	42
5.4.1	Procedura tipica della SDC	42
5.4.2	SDC: Macrodati	43
5.4.3	SDC: Database Query Point	43
5.4.4	SDC: Microdata	44
5.5	Utility Measurement	45
5.5.1	Tipologie di information loss utilizzate dai diversi metodi - Macrodata	46
5.5.2	Tipologie di information loss utilizzate dai diversi metodi - Information Loss for Query	46
5.5.3	Tipologie di information loss utilizzate dai diversi metodi - Microdati	46
6	Anonimizzazione: k-anonymity	47
6.1	Anonimizzazione	48
6.1.1	Problemi dell'anonimizzazione all'interno dei dati	48
6.1.2	Linking Attacks	48
6.2	La k-anonymity	49
6.2.1	Definizione di k-anonymity	50
6.2.2	Come ottenere la k-anonymity	50
6.2.3	Gerarchia di generalizzazione del dominio (DGH)	51
6.2.4	Gerarchia di generalizzazione del valore	51
6.2.5	Reticolo generalizzato	52
6.2.6	Tavola generalizzato con soppressione	52
6.2.7	Distance Vector	52
6.2.8	Criterio di generalizzazione - intuizione	53
6.2.9	Generalizzazione k-minimal con soppressione	53

6.2.10	Classificazione delle tecniche k -anonymity	54
6.2.11	Risolvere i problemi dovuto ad algoritmi k -anonymity	54
6.3	Algoritmi per k -anonymity	55
6.3.1	Algoritmo di Samarati	55
6.3.2	Algoritmo Incognito	56
6.3.3	Algoritmo Mondrian	58
6.3.4	Algoritmo Topdown	59
6.3.5	Differenza ottenute con i vari algoritmi	59
7	Limiti della k-anonymity	60
7.1	Ipotetici attacchi	60
7.1.1	Homogeneity Attack	60
7.1.2	Background knowledge attack	61
7.1.3	Positive and negative disclosure	61
7.1.4	Basi teoriche: definizioni	61
7.2	Lack of diversity	62
7.2.1	l -diversity (principio)	62
7.2.2	Principio della l -diversity globale	63
7.2.3	Entropy l -diversity	63
7.2.4	Teorema della monotonicità dell' l -diversity	63
7.2.5	Problemi legati all' l -diversity	64
7.2.6	Altri esempi di problemi	64
7.2.7	Attacchi che possono essere attuati su l -diversity	64
7.3	t -closeness principle	65
7.3.1	Distanza tra le due distribuzioni	65
7.3.2	EMD Distance	66
7.3.3	Problemi della t -closeness	67
7.4	δ -presence	68
7.4.1	Scelta di un buon δ	70
7.4.2	Conclusioni	71
7.4.3	Curse of dimensionality	71
8	Differential Privacy	72
8.1	Definizioni	72
8.1.1	Meccanismo Randomizzato	72
8.1.2	δ -differential privacy	72
8.1.3	Privacy vs. Accuracy	73
8.1.4	Il meccanismo di Laplace	73
8.1.5	Sensitività Globale (GS)	74
8.1.6	Beyond the Laplace Mechanism	74
8.1.7	Il meccanismo esponenziale	75
8.2	Proprietà della Differential Privacy	76
8.2.1	Teorema di Post-Processing	76
8.2.2	Teorema di Composizione	77
8.2.3	Teorema di composizione in parallelo	77
8.3	(ϵ, δ) -Differential Privacy	77
8.3.1	Il meccanismo di Gauss	79
8.3.2	Laplace vs Gauss	79
8.4	(ϵ, δ) -local differential privacy	79
8.4.1	Interactive vs Non-interactive	79
8.4.2	Untrusted curator	80
8.4.3	(ϵ, δ) -local differential privacy	81
8.4.4	Confronto tra le due differential privacy	81

8.4.5	Il meccanismo della moneta - Prima formulazione	82
8.4.6	Generalized Randomized Response	82
8.4.7	Metodi per preservare la LDP	83
8.5	Machine Learning and Differential Privacy	84
8.5.1	L'algoritmo DP-k-means (input perturbation)	86
8.6	Limitation and Critical Issues	88
8.6.1	Come scegliere ϵ	89
8.6.2	Problema legato alla sensitività globale (GS)	89
8.6.3	Esempi di applicazioni reali basati sulla Differential Privacy	91
9	Privacy in distributed system	92
9.1	Definizioni e proprietà principali	92
9.1.1	Distributed Data Analysis: The Standard Method	92
9.1.2	Private Distributed Data Analysis	93
9.1.3	Private Distributed Mining	93
9.1.4	Classe di soluzioni	94
9.1.5	La Data Separation	94
9.2	Secure Multiparty Computation	95
9.2.1	Il problema del Milionario di Yao	95
9.2.2	Il protocollo Oblivious Transfer	96
9.2.3	L'algoritmo ID3	97
9.2.4	Rendere Privacy Preserving ID3	98
9.2.5	Altri approcci complementari	99
9.3	Il Federated Learning	100
9.3.1	Definizioni e proprietà principali	101
9.3.2	Federated learning assumptions, goals & desiderata	102
9.3.3	FL: il protocollo generale	103
9.3.4	Cross-device FL: esempio giocattolo	103
9.3.5	Federated Learning: major challenges	103
9.3.6	Federated SGD: FedSGD	104
9.3.7	Funzionamento di FedSGD	104
9.3.8	Federated Averaging: FedAvg	105
9.3.9	Il Federated Learning Decentralizzato	105
9.4	Privacy in Federated Learning	106
9.4.1	Tipi di attacchi nel FL	106
9.4.2	Homomorphic encryption	107
9.4.3	Secure Aggregation (& SMC)	107

Chapter 1

Privacy and Data Protection

Corso che mira a far riflettere su quelle che sono le problematiche di privacy nella modellazione e nell'analisi del dato. Inoltre, andremo a comprendere quelli che sono i metodi per gestire e analizzare il dato in maniera **Privacy Preserving**. Le competenze acquisite una volta terminato il corso, saranno le seguenti:

- generale conoscenza riguardante le violazioni di privacy in senso generale e i vari modi per proteggersi;
- maggiore consapevolezza riguardante il bisogno che esiste per migliorare la gestione della privacy nella gestione dell'analisi dei dati, in particolare i Big Data

Principali argomenti trattati nel corso saranno:

1. concetto di privacy e concetto di privacy nei diversi paesi (Europa e Stati Uniti);
2. sfide della privacy nell'era dei Big Data;
3. come affrontare queste sfide nell'ambito della progettazione dei sistemi informativi;
4. proteggere i database statistici dagli attacchi e quali sono i modelli di protezioni del dato d'analizzare
5. analisi del dato fatta in maniera data-preserving
6. differential privacy

1.1 La privacy e le leggi sulla privacy

1.1.1 Che cos'è la privacy?

Il primo riferimento alla privacy è visto come il diritto a restare da soli. È stato stilato un saggio importante scritto da Warren riguardante la ricerca di una regione legale per proteggere la privacy degli individui, all'interno sempre degli statuti e principi che esistevano all'epoca. Siamo in un periodo in cui le forze dell'ordine avevano potere di perquisire senza un motivo reale e quindi la necessità di rafforzare la privacy era un bisogno effettivo dei cittadini. Rispetto all'idea che abbiamo noi di privacy, questa appena descritta viene visto come un concetto molto primitivo.

Concetto che inizia ad evolversi negli anni successivi. Inizia ad essere concesso un accesso **limitato alla vita delle persone**. L'idea della privacy era vista come la possibilità di una persona di partecipare ad una società senza che individui o altre organizzazione potessero collezionare informazioni su essa. Qui, intendiamo organizzazione come aziende o banche. La privacy veniva vista come un sistema per limitare l'accesso alle persone e chiaramente da qui in poi iniziano ad essere proposte definizioni diverse per il concetto di Privacy

- Godkin ad esempio, nel 1880 esprime il diritto dell'essere umano di essere lasciato da solo e fino a che livello devono essere soggetti all'osservazione e discussione del pubblico (gossip)
- Bok (1989), definisce la privacy come la condizione di essere protetti da accessi indesiderati da parti di altri, sia in termini fisici che in termini di informazioni personali come le indagini;

Un concetto più moderno vede la privacy come **controllo sull'informazione**. Altro saggio (1970) vede la privacy come il desiderio, bisogno dell'individuo, di determinare per se stessi, il come, il quando e a che livello, le informazioni su di loro potessero essere comunicati ad altri. In sostanza, le informazioni private in mio possesso, ovvero quelle che riguardano la mia persona, possono essere in possesso di terzi, ma il punto è comunque decidere con che modalità queste informazioni devono essere comunicate ad altre persone. Altra definizione interessante (1968), dice che la privacy non è semplicemente l'assenza di informazioni su di noi nella mente degli altri, piuttosto è il controllo che noi abbiamo sulle nostre informazioni. Altre definizioni vedono la privacy come:

- la segretezza nel senso di poter optare nel nascondere informazioni ad altri;
- controllo che hanno gli altri sull'uso delle nostre informazioni
- privacy che riguardano diverse tipologie del dato personale;
- autonomia e personalità;
- identità di se e crescita personale
- protezione personali degli affetti intimi

1.1.2 Che cosa è stato deciso a livello di standard internazionale?

- Una delle prime definizioni formali è quella che trova compimento nel sistema statunitense. La privacy viene vista come il **diritto di un'entità** (termine fondamentale) di determinare il livello con cui questa entità¹ interagisce con l'ambiente e questo livello d'interazione include anche il livello con cui questa entità può voler condividere le sue informazioni con altri.
- per quanto riguarda lo standard ISO, viene definita come il diritto da parte degli individui di controllare o influenzare quali informazioni possono essere collezionate e memorizzate e a chi soprattutto queste informazioni possano essere distribuite.

La definizione che reputeremo valida all'interno di questo corso è la seguente

- **la privacy non è altro che l'abilità di una persona di controllare la disponibilità di informazione su di essa e l'esposizioni (comunicazione, condivisione) di essa.**

Punto fondamentale che questa definizione è collegata al bisogno di poter funzionare/operare nella società in maniera anonima, in modo tale da poter garantire la possibilità agli individui di funzionare e operare nella società in maniera anonima (utilizzare credenziali cieche come pseudonimi)

¹si fa riferimento sia ad una persona che ad un'organizzazione

1.1.3 Perché la privacy è così importante?

Dibattito aperto in tanti campi. Faremo degli esempi in cui sarà evidente che non è così facile dare appunto una vera e propria risposta a questa domanda. Inanzitutto, la privacy riguarda un sentimento dell'individuo che può, in alcuni casi, sentirsi a disagio nel momento che informazioni che lo riguardano vengono diffuse nella comunità e quindi riguarda la proprietà dell'informazione. Fino a quando le informazioni cedute vengono utilizzate in maniera corretta, il problema non si pone affatto, caso contrario risulterebbe un problema.

- furto d'identità;
- informazioni fornite vanno a determinare alcune scelte che riguardano gli individui.
Possibilità di accedere ad un prestito/posizione lavorativa

La privacy è un problema che non riguarda il solo individuo, ma anche le aziende. Con il passare del tempo è stato avvertito, il bisogno crescente da parte delle aziende di far sentire i propri clienti "al sicuro". Il fatto di essere note come aziende che tengono a proteggere la privacy degli individui, fa assumere all'azienda stessa una buona reputazione in asset globale e finanziari. Punto fondamentale che riguarda sempre le aziende è evitare qualsiasi tipo di dispute legali riguardanti la privacy dell'individuo.

Using vs Gathering

È un aspetto relativo ai dati personali e alla privacy, che differenzia quello che è l'uso dei dati da quello che è la raccolta dei dati.

- l'importanza della privacy non è tanto la raccolta dei dati. *Quando c'iscriviamo all'università vengono comunicati dei dati. Stesso discorso per un ipotetico acquisto di un bene su internet.* Il punto fondamentale è l'uso che si fa di questi dati, quindi su come queste informazioni vengono usate. ATTENZIONE, molto spesso il problema non è tanto la comunicazione, ma l'uso che le organizzazioni fanno di questi dati.

1.1.4 Quali tipi di privacy conosciamo?

Andremo ad elencare quelle che sono le più importanti e in quanto tali si ha una regolamentazione nell'utilizzo dei dati.

- political privacy, il fatto di poter decidere i miei rappresentanti in maniera anonima senza che qualcuno sappia quale sia stata la mia scelta;
- consumer privacy, importante in quanto dicono molto della persona. Compriamo moltissimo snack e questo potrebbero dirci in qualche modo quelli che possono essere eventuali problemi di salute futuri;
- medical privacy, dobbiamo poter essere sicuri di poter curare senza che nessuno sappia il tipo di problema che stiamo affrontando. Le nostre necessità mediche non devono poter influenzare le scelte di altri che fanno su di me;
- private privacy, racchiudiamo quelli che sono gli effetti personali, abitudini personali e quindi non soltanto la residenza dove abito. Ovviamente, abbiamo interesse a proteggere la nostra vita privata verso le intrusioni di altre persone.
- Information technology end-user privacy (also called information/**data privacy**). Punto che ha assunto particolare importanza negli ultimi decenni. Questa racchiude tutte le tipologie di privacy dei punti precedenti. Basti pensare al voto elettronico, acquisti online, fascicolo sanitario online.

Quello che noi andremo a studiare è questo ultimo aspetto.

1.2 Data Privacy

Un problema di **data privacy** (dpp) esiste ogni qualvolta un dato/i che sono univocamente identificabili e che sono relativi ad una determinata persona/e, sono **collezionate** e **memorizzate** in forma digitale (ma anche in altre forme). C'è un problema di dpp quindi ogni volta che vengono collezionate e memorizzate, gestite informazioni che riguardano persone che possono essere identificate in maniera univoca.

Quali sono le principale fonti di dati che sono toccate dal problema del dpp

- tutto ciò che è fascicolo sanitario. Dati raccolti da ospedali, medici, cliniche e laboratorio d'analisi;
- indagini riguardanti la giustizia criminale e quindi tutti gli atti di processo. Sono procedimenti che coinvolgono l'utilizzo di dati privati e quindi c'è la necessità di protezioni della privacy;
- istituzioni finanziarie che trattano transazioni economiche e finanziarie tra pari o individui;
- in questi ultimi anni si parla molto di privacy che trattano dati biologici, come ad esempio il materiale genetico. Comunque, è un problema difficile da trattare, ci sono problematiche importanti in quanto la raccolta di materiale genetico è utile a scoprire nuovi trattamenti per nuove malattie e quindi capire come funziona l'essere umano e come curarlo. Il problema è anche l'uso che ne viene fatto di questi dati. Le banche dati genetiche comunque sono tutte informatizzate e molte di esse sono accessibili al pubblico;
- dati riguardanti la posizione geografica, residenza;
- posizionamento geografico e quindi sulla geocalizzazione;
- abitudini riguardanti la navigazione online e quindi preferenze dell'utente che sono raccolte attraverso l'utilizzo di cookie;

La sfida principale riguardante la privacy non è tanto sulla raccolta di dati, ma sull'utilizzo che se ne va fare. In merito a questo, occorre soffermarci su un termine particolare, la **condivisione**. Senza la condivisione non viene possibile ad esempio poter ottenere nuove cure ad esempio sul COVID-19. Informazioni necessarie che permettono al mondo di poter progredire. Il punto centrale è la sfida su come *condividere i dati cercando però contemporaneamente di proteggere le informazioni riguardanti le persone e quindi le informazioni che permettono agli individui di essere identificati*. La condivisione di dati raccolti dagli ospedali, è una prassi comune. Naturalmente questo deve essere fatto senza che l'individuo possa essere identificato. Nel momento in cui un dato aggregato non garantisce l'anonimato delle persone abbiamo un problema. Quello che cambia nei diversi paesi è il modo con cui i sistemi legislativi dei singoli paesi cercando di proteggere il diritto alla privacy.

Privacy laws and regulation

Cerchiamo di capire come i diversi paesi affrontano i problemi legati alla privacy e questo lo vedremo in alcuni paesi che stati pionieri al diritto alla privacy.

- Stati Uniti
- Canada
- Unione Europea dove in particolare ci soffermeremo

- caso italiano sulla legge della privacy (anno 1993 prima direttiva e aggiornata nel 2018 con l'introduzione del GDPR, **regolamento generale sulla protezione del dato**)

Come ultimo punto andremo a vedere come ci si confronta con il diritto alla privacy nell'era globalizzata dove i dati possono circolare e quindi vedere quelle che sono le principali regolamentazioni internazionali che riguardano la protezione del dato.

1.2.1 La Data Privacy negli Stati Uniti

Negli USA non esiste una legge univoca sulla privacy, pur essendo loro stessi ideatori della definizione di privacy. Non è altamente regolamentata, ovvero non esistono leggi che affrontano il problema della privacy in maniera forte, quindi non esiste un regolamento unico sulla privacy che riguarda tutti gli aspetti. Cosa contraria avviene nel GDPR, ovvero questo **regola** l'acquisizione e uso dei dati personali. Se qualcuno entra in possesso di dati personali, questo qualcuno ha il diritto di usarli e memorizzarli nel modo che lo ritiene più opportuno e cosa fondamentale e che ne può far ciò che vuole.

- Esempio. Quando una persona sta cercando un lavoro, oppure sta cercando di comprare un'auto, comunque quando si trova in una situazione di richiesta di credito, le aziende possono accedere alle informazioni riguardanti i diversi crediti che ha quella persona, in modo tale da vedere quella che è la situazione economica della persona.

I crediti di terze parti (report riguardanti i crediti di persone) possono essere consultati da aziende o enti che comunque in quel momento vogliono stipulare un contratto di lavoro con questa persona. Comunque esistono delle eccezioni regolamentate in singoli esempi di legge che trattano aspetti specifici della privacy negli USA.

- **Health Insurance Portability and Accountability Act (HIPAA)**. Legge che riguarda le assicurazioni sulla salute e quindi la possibilità di trasferire l'assicurazione su altre compagnie e sulla responsabilizzazione stessa delle compagnie rispetto l'assicurato.. Siamo nel 1996 e l'idea di base di questa legge è la seguente. Stabilire quelle che sono le procedure per l'esercizio al diritto della privacy riguardanti le informazioni sulla salute. Non diceva che le informazioni non potevano essere divulgate, ma che c'erano delle procedure ben definite per aver accesso ad atti riguardanti informazioni di salute dei cittadini. Altro aspetto regolamento in questa legge è l'utilizzo e la diffusione dell'informazione riguardante la salute dell'individuo che deve in qualche modo essere autorizzata e richiesta. C'era quindi una procedura di autorizzazione nella comunicazione e uso di questi dati. Cosa importante dietro questo atto è la seguente:

- L'esistenza di un meccanismo di autenticazione per quei cittadini che domandavano l'accesso ai propri dati.

Naturalmente solo Nome e Cognome non bastavano e quindi l'atto dava anche di quale fosse l'indicazione su come essere autenticati dal punto di vista della salute pubblica. Il mezzo con cui una persona può essere identificata nel USA per procedure riguardanti la propria salute è il **SSN**. Famosissimo numero univoco che viene attribuito ad un singolo paziente e permette di correlare qualsiasi tipo di informazione medica riguardante il paziente in qualsiasi parte degli Stati Uniti. Il fatto che ad ogni paziente viene associato questo SSN, rende questo, un numero molto importante e riservato. *In Italia il CF viene costruito da un'informazione pubblica. L'SSN è un numero che in teoria deve rimanere nascosto.* Grazie a questo possono essere possibili un numero di operazioni enormi e quindi questo è la base dei cosiddetti furti. La legge aveva regolamentato l'utilizzo del SSN che di per se può portare a minacce riguardante la privacy.

- **Children's Online Privacy Protection Act (COPPA)**. Provvedimento importante riguardante la privacy dei minori. Provvedimento che si applica alla raccolta dei dati personali per le sole persone la cui età è al di sotto dei 13 anni. A differenza di prima, la privacy entra nel nome della legge. Deve essere protetta in maniera più accurata e includere nozioni che riguardavano la tutela legale dei minori, la responsabilità genitoriale. Quello che questa legge regolamentava, era come i siti dovevano rendere:

- i. accessibile la privacy nel caso in cui i minori accedevano a quel sito;
- ii. avere un consenso da parte di un genitore o tutore legale in maniera verificabile in modo che si fosse sicuro che c'era stato un consenso informale da parte di genitori o tutore;
- iii. responsabilità dell'operatore del web nei confronti della protezione del dato dei minori e quindi come salvaguarda la sicurezza online del minore

Si nota come molti siti web per ovviare a questi problemi organizzativi, vietano l'accesso ai minori.

- **Fair Credit Reporting Act (FCRA)**. È una legge che riguarda non direttamente problemi di privacy, ma di procedimenti che possono toccare la privacy del cittadino. Questo cerca di stabilire quelle che sono le regole che permettono di assicurarsi la *fairness* delle informazioni riguardanti acquirenti o clienti che potevano essere contenute negli archivi di agenzie che facevano report riguardanti acquisti da parte di utenti. Legge che regolamentava il modo con cui i report sulla situazione debitoria dei clienti poteva essere raccolta e utilizzata. L'idea era quella di proteggere il cittadino da aggiunta o inclusione d'informazione inaccurate o informazioni poco veritiere riguardanti il report dei crediti. Non si vieta l'utilizzo dei credit report (fondamentali per tutto il modo con cui si svolge la vita economica), quello che la legge stabilisce è che i credit report devono essere accurati e non contenere informazioni inesatte (false) e quindi permettere ai cittadini di accedere al credito in maniera trasparente. Altra cosa che viene permessa è quella di accedere/visualizzare/correggere/contestare l'utilizzo dei credit report. L'obiettivo raggiunto da questa legge ha permesso di minimizzare o evitare del tutto la profilazione di alcune tipologie di credit report chiamate **private credit guides** che in sostanza potevano contenere informazioni private quasi a livello di gossip riguardanti i cittadini
- **Computer security and Privacy Laws**. Provvedimenti che sono più vicini al mondo della computer science. Vediamo come esempi di legge si sono concentrati su quello che riguarda la privacy online, o comunque privacy che riguarda in generale la comunicazione di dati utilizzando mezzi telematici ma non solo. Problema che si avverte all'inizio degli anni 70 dove alcune parti della vita pubblica iniziavano ad essere trasferite su memorie non cartacee e quindi abbiamo il
 - i. Family Educational Rights and Privacy Act (FERPA), regolamentava le modalità su come potevano essere utilizzati i record riguardanti gli studenti
 - ii. Electronic Communications Privacy Act (ECPA), sicurezza nelle comunicazioni elettroniche;
 - iii. Video Privacy Protection Act (VPPA), regolamentazioni di come possono essere seguite le riprese da parti di enti pubblici e privati
 - iv. Provide Appropriate Tools Required to Intercept and Obstruct Terrorism (PATRIOT) Act, atto con cui Bush andò a contrastare le conseguenze dell'attacco alle torri, permettendo un accesso più discriminatorio riguardanti le informazioni dei cittadini, con il famosissimo PATRIOT Act. Con la scusa del terrorismo in America fu permesso di accedere a chiunque passasse sul suolo Americano in modo da aver più facile accesso a informazioni che potevano mettere in repentaglio la sicurezza stessa degli Stati Uniti. Come si è visto in seguito questo PATRIOT Act è stato abusato mettendolo sotto accusa in varie occasioni.

1.2.2 La Data Privacy in Canada

Anche il Canada è una nazione in cui la privacy è molto sentita ed il Paese dove è stato codificato uno dei principi fondamentali del nostro GDPR - Privacy By Design - Il Canada si avvicina di più ad una tipologia di protezione delle informazioni di stampo Europeo, grazie anche al PIPEDA Act (promulgato nel 2001) che va a occuparsi di come vengono gestiti i dati personali in Canada e in sostanza va a risolvere la compliance con la direttiva europea sulla privacy. In sostanza, il PIPEDA è stato promulgato in Canada in modo da potersi adeguare ai requisiti della privacy in Europa. Legge che sostanzialmente va a specificare le regole che permettono la raccolta, utilizzo e diffusione di informazioni personali e specifica anche quelle regole con cui le organizzazioni possono raccogliere/utilizzare e diffondere le informazioni personali.

1.2.3 La legge sulla privacy nell'Unione Europea

A differenza di quello che succede negli Stati Uniti, la privacy in Europa è fortemente regolamentata. Presa come punto di riferimento per poter andare a gestire tutti i problemi di privacy nel mondo.

- regolamentata dalla convenzione europea sui diritti umani (art. 8) in cui viene specificato come il diritto per il rispetto alla privacy, alla vita privata, alla casa e alla corrispondenza dell'individuo. Esiste un diritto fondamentale definito da questo articolo che definisce che la privacy è un diritto.
- la Corte Europea sui diritti umani ha dato un'interpretazione vasta a questo articolo che tocca aspetti importanti come:
 1. raccolta d'informazione riguardante i censimenti pubblici;
 2. sicurezza nazionale, come la raccolta di impronte digitali, foto nei registri di polizia
 3. raccolta di dati medici
 4. si interessa alla modalità con cui l'identificazione personale avviene e quindi si fa anche da promotrice di sistemi per l'identificazione personale

Per quanto riguarda la privacy nell'UE possiamo stabilire essenzialmente due epoche:

1. **1995-2018**, che vede gli stati europei governati dalla "**data protection directive**", promulgata nel 1995. È una direttiva quindi non è direttamente una legge che entra così com'è, ma deve essere recepita dai governi nazionali per poi essere tramutata, in un secondo momento, in legge nazionale;
2. **2018**, General Data Protection Regulation (GDPR) (EU) 2016/679. L'aumento della sensibilità riguardante problemi come la raccolta del dato online e l'utilizzo di dati nei social media ha fatto scaturire nei nostri legislatori la necessità di andare a governare in una maniera più accurata e anche meno ambigua, il dato personale. Dopo anni di discussioni e meeting (che hanno visto la collaborazione oltre di legislatori ma anche di computer scientist), nel 2018 nasce, o meglio, viene promulgato il **General Data Protection Regulation** noto semplicemente come **GDPR**. Rispetto alla direttiva è un regolamento vero e proprio e di conseguenza ha tutti gli effetti di una legge.

1.3 Data Protection Directive

Adottata dal parlamento europeo nel 1995.

- è stato un tentativo di armonizzare le leggi di protezioni del dato che esistevano in alcuni, se non tutti i paesi dell'UE.

- questa direttiva doveva essere recepita dai diversi paesi membri e poi tramutata in legge entro la fine del 1998

In sostanza questa legge si basava su otto principi di buona pratica riguardanti il trattamento del dato personale:

1. utilizzo legale aderenti ai principi di legge dei dati;
2. processamento dei dati con scopi limitati
3. utilizzo dei dati in quantità adeguata, quindi dati pertinenti per l'attività per cui venivano raccolti e non usare più dei dati necessari rispetto a quelli che realmente servivano
4. accuratezza del dato
5. memorizzati per il tempo necessario
6. devono essere tratti in accordo con i diritti del data subject
7. processati in maniera sicura, quindi garantire i principi di accesso e trattamento sicuro del dato
8. possono essere trasferiti tra paesi soltanto se sono adeguate le protezioni del dato. Ovvero, se il trasferimento non comporta la divulgazione dei dati verso quelle associazioni che in realtà non potrebbero disporre del dato stesso

Definizioni importanti che vengono introdotte all'interno di questa direttiva, che poi, verranno arricchite con l'introduzione del GDPR, sono:

1.3.1 Personal Data

Erano definiti come:

- ogni informazione riguardante una persona identificata o identificabile nota come **data subject**;
- persona identificabile è una persona che può essere appunto identificata in maniera diretta o indiretta, in particolare in riferimento ad un numero ID o ad uno o più aspetti specifici della sua identità fisica, physiological, mental, economic, cultural or social identity

Questa definizione nel GDPR viene definita come tale, ma con delle piccole modifiche.

1.3.2 Data Processing

Viene visto come l'insieme di operazioni attuate sui dati personali in maniera automatica o non:

- raccolta dei dati;
- memorizzazione dei dati;
- organizzazione dei dati;
- adattamento o alterazione dei dati;
- retrieval, ricerca dei dati
- consultazione dei dati

Sostanzialmente venivano fatte un elenco di operazioni che potevano essere attuate su dati personali di natura molto varia, dalle semplici memorizzazioni, alla cancellazione, fino ad operazioni complesse come la combinazione dei dati. Tutte queste operazioni sono definite come **trattamento del dato**. Il data processing nel GDPR presenta dei piccoli cambiamenti.

1.3.3 Responsabilità

Responsabilità che sono sulle spalle del **controller**, ovvero il titolare del trattamento. La persona naturale o artificiale che insieme o in comunione con altre persone o azienda, determina quelli che sono scopi e mezzi per il trattamento dell'informazione del dato. *Nel caso dell'università è il rettore.*

1.3.4 Processor

Persona naturale o legale, autorità pubblica, agenzia o ogni altro corpo che tratta i dati (li processa) per un titolare del trattamento. Ad esempio gli amministrativi che in qualche modo registrano i dati nel momento dell'immatricolazione, oppure i docenti stessi che trattano i dati che riguardano le nostre carriere.

Responsabilità e Processor non hanno avuto cambiamenti significanti nel GDPR.

Incaricato del trattamento

Si occupa del trattamento dei dati facendo le veci del responsabile del trattamento.

1.4 Principi fondamentali che sono alla base di qualsiasi trattamento del dato personale

Non bisognerebbe trattare i dati personali, tranne quando queste e tre categorie di condizioni sono verificate

1. **trasparenza**, il data subject ha il diritto di essere informato nel momento in cui i suoi dati personali sono trattati da qualcuno. Il titolare del trattamento ha l'obbligo di fornire tutte le informazioni richieste in modo da verificare che il trattamento sia stato fatto in maniera corretta;
2. **scopo legittimo**, i dati personali possono essere trattati solo per scopi legittimi e non possono essere trattati per scopi che vanno oltre a quello legittimi per cui sono stati raccolti;
3. **proporzionalità**, se c'è un obiettivo questo deve essere perseguito utilizzando i soli dati necessari e non più di quelli necessari. I dati devono essere adeguati, pertinenti (raccolgere dati che servono per il solo scopo/obiettivo per cui devono essere trattati) e non devono essere eccessivi, ovvero non raccogliere più dati del necessario.

Qui di seguito, vediamo due dei tre principi nel dettaglio.

1.4.1 La trasparenza

I dati possono essere processati se almeno una delle seguenti condizioni risulta essere vera. Qui di seguito verranno elencati dei punti etichettati come fondamentali per chi intende processare i dati

- il data subject deve dare il consenso
- se così non fosse il processamento deve essere necessario per la finalizzazione di un contratto di qualsiasi tipo
- il processamento è necessario per motivi di aderenza a delle obbligazioni legali. Quindi, la legge in qualche modo obbliga la raccolta dei dati e questa raccolta non implica un consenso.

1.4. PRINCIPI FONDAMENTALI CHE SONO ALLA BASE DI QUALSIASI TRATTAMENTO DEL DATO PER

- il processamento dei dati si rende necessario per proteggere gli interessi vitali del data subject. *Se una persona sta affronta un ricovero ospedaliero, i suoi dati devono essere trattati per garantire a questo individuo le cure ottimali*
- c'è un interesse pubblico per il trattamento. *Motivazioni statistiche che servono a governi per prendere decisioni importanti per il pubblico interesse*
- processamento necessario per scopi legittimi perseguiti dal titolare del trattamento, tranne quando questi scopi vanno ad intaccare gli interessi difesi dal diritto di libertà del data subject. In ogni caso il titolare del trattamento non può ledere i diritti fondamentali dell'individuo.

Lato utente:

- il data subject deve poter accedere a tutti i dati che vengono trattati e può chiedere la rettifica di questi dati, la modifica, la cancellazione e il blocco dei dati

1.4.2 La proporzionalità

- i dati devono essere accurati e aggiornati. Diritto che riguarda anche la privacy dell'individuo.
- i dati devono essere immagazzinati in una forma che non permette l'identificazione del data subject per più del tempo necessario. *Dati in forma anonima per motivi statistici possono essere sempre conservati ma non devono essere utilizzati in una forma tale da poter identificare il data subject.* Nel momento in cui il data subject sta usufruendo del servizio è ovvio che devono poter essere identificati, quindi fornire il servizio. Nel momento in cui il servizio smette di esistere allora l'identificazione non deve più avvenire;
- stati membri devono dotarsi di misure appropriate per quei dati che devono essere memorizzati per lunghi periodi di tempo ai fini di statistica o per uso scientifico, o anche motivi storici. Qui diciamo che dati che contengono possibili identificativi di persone o comunque attributi che possono portare all'identificazione di persone per motivi scientifici/statistici, possono essere memorizzati a lungo, però devono essere attuate tutte le precauzioni necessarie affinché questi dati non vadano in mani sbagliate
- restrizioni aggiuntive vengono applicate a quei dati che vengono considerati *sensibili*. Ci sono delle definizioni giuridiche precise che possono variare da stato a stato. Sono dati che riguardano:
 - religione, razza intesa come etnia, credo politico, orientamento sessuale
- in qualsiasi momento il data subject può optare affinché i suoi dati non vengano utilizzati per scopi di marketing diretto e quindi i dati devono poter essere utilizzati per il solo servizio che ci interessa e comunque nel caso dovessero essere usati per motivi di marketing dobbiamo comunque essere informati di questo fatto con l'eventualità di opporci
- qualsiasi decisione che produca un effetto legale o che comporta/impatta in maniera significativa sulla vita stessa del data subject non può essere basata unicamente sul trattamento automatico dei dati. Vuol dire che se un algoritmo decide di darmi o non darmi ad esempio un prestito, questa decisione presa deve essere comunque vagliata da un umano. Quindi, non è possibile, che una decisione, che abbia un impatto importante sulla vita dell'individuo, che in qualche modo produca degli effetti legati, non può essere presa in maniera esclusiva da algoritmi che processano i dati in maniera automatica. Se dovesse avvenire, ci deve essere comunque una forma di appello in modo che l'utente possa esigere che il trattamento di questi dati sia fatto in maniera umana;

1.5 La Privacy Authority

Ogni stato membro dell'UE, deve dotarsi della cosiddetta **autorità della privacy**, autorità, che supervisiona tutto quello che riguarda il trattamento del dato nel proprio Paese. In sostanza, questa autorità, ha l'obbligo di monitorare i livelli raggiunti nella protezione dei dati nei singoli stati, perchè chiaramente ci sono paesi dove la cultura informatica è avanzata e che quindi permetta di usufruire di tecniche del dato più efficienti, altri paesi no. Inoltre, deve consigliare al governo su quelle che sono le misure amministrative e regolamenti da prendere in considerazione al fine del trattamento del dato. Può anche dar via a procedimenti legali nel momento in cui si verificano delle violazioni della regolazioni riguardanti la protezione del dato. In aggiunta a questo, il titolare del trattamento deve notificare all'autorità, le seguenti informazioni

- fornire sempre nome e indirizzo del titolare
- fornire motivi/scopi del trattamento
- dare una descrizione delle categorie di dati che vengono raccolte in merito al data subject, quindi anche il tipo di data subject di cui si vuole memorizzare i dati e anche le categorie
- bisogna anche notificare al garante, l'autorità che supervisiona tutto quello che riguarda la privacy nei diversi paesi e notificare anche i destinatari che possono accedere ai dati

Se i dati dovessero essere mai trasferiti in altri paese, oltre a notificare l'autorità, bisogna fornire una descrizione generale di quelle che saranno le misure prese per assicurare che tutte le informazioni vengono mantenute in un registro pubblico.

Legge sulla Privacy in Italia

D. Come si è adeguata l'Italia a questa direttiva negli anni?

R. L'Italia, subito dopo la promulgazione della direttiva del 95, ha promulgato una legge sulla privacy, migliorata con il decreto legislativo 196/2003 conosciuto anche come **codice materia di protezione dei dati personali**, questo 196 è il contesto legale in cui ci siamo mossi fino al 2018. Legge avanzata che recepisce tutte una serie di caratteristiche e obblighi che erano stati sanciti dalla direttiva 95 e che dovevano essere comunque convertiti in una legge. Inoltre, rispetto a quelli che erano gli obblighi della direttiva, l'Italia decide di dotarsi di una **data protection authority**, chiamato Garante per la protezione dei dati personali, che in sostanza aveva il compito di lasciare delle linee guida (direttive) + dettagliate riguardanti le casistiche particolare del trattamento del dato. Quindi, linee guida emanate dal garante che riguardano per esempio casi come la video sorveglianza, dati biometrici ed ecc. Questo garante è un autorità composta da più persone e guidata da un Presidente.

1.6 II GDPR

Le aziende lo hanno visto come un insieme di norme che impedivano di svolgere in maniera ottimale quella che era la *mission* dell'azienda. Altre aziende invece hanno preso spunto dal GDPR per dotarsi di metodi di protezione all'avanguardia in modo da fornire agli utenti servizi sempre più sicuri. La prima fondamentale differenza è che il GDPR è un regolamento, non è soltanto una direttiva. Essendo un regolamento, ha gli effetti di una legge.

- regolamento che ha gli obiettivi di rafforzare e unificare le modalità di protezione del dato per tutti gli individui che si muovono all'interno dell'UE.

- restituire ai cittadini il controllo sui dati personali e anche semplificare l'ambiente (burocrazia) per le aziende internazionali facendo in modo che le aziende che si muovono fuori i confini dell'unione europea abbiano un unico riferimento normativo a cui far a capo. Così facendo non si adeguano i servizi alle singole nazioni
- regolamento adottato il 27 aprile 2016
- entrato in vigore il 25 maggio 2018

Ci sono stati dei cambiamenti alle varie definizioni. Le introduciamo in modo da vedere come si è evoluta la percezione della privacy durante questi decenni

- **personal data**, a differenza di prima questi includono dati riguardanti la localizzazione (GPS), identificatori online (location data) e a questi si aggiungono aspetti genetici, economici e culturali;
- **data processing**, la definizione rimane la stessa con l'aggiunta di poter strutturare un dato in qualche modo che riguarda ad esempio la possibilità di modellare dati utilizzando strumenti come i DBMS o altre modalità per la raccolta, memorizzazione e trattamento.
- **pseudonomizzazione**, il processamento del dato deve essere effettuato per poter portare a termine un obiettivo, ma questo deve essere processato nel seguente modo
 - i dati personali non possono attribuiti ad uno specifico data subject senza utilizzo di informazione aggiuntiva. Significa che questa informazione aggiuntiva dovrebbe essere tenuta separata e le organizzazioni devono dotarsi di misure che permettono di non attribuire in maniera univoca le informazioni personali ad una singola persona identificata o identificabile

È una tecnica (sono più) che permettono di tener separati i dati personali dalle informazioni che permettono di identificare i singoli data subject. Ci deve essere una netta separazione tra dati identificativi e dati personali

- **personal data breach**, violazioni di dati personali. Violazione della sicurezza che ha portato in maniera accidentale o illegittima alla distruzione, perdita, diffusione non autorizzata, accesso non autorizzato, trasmissioni di dati personali, memorizzati o in maniera diversa (eventualmente anche cartacea). In ogni caso (dovuto o no) riguarda attività che hanno causato la distruzione, perdita di dati personali

I diritti del data subject si sono rafforzati

Il GDPR fornisce una lista di diritti che può godere il data subject e ovviamente può avvalersi nel momento in cui è a conoscenza di un trattamento che riguarda i suoi dati personali. Diritti che danno un maggior controllo al data subject rispetto ai propri dati personali, introducendo la nozione di **consenso chiaro**. Nella direttiva (quella precedente al GDPR) si parlava di consenso informato, qui di consenso chiaro. L'informativa deve essere fornita in

- maniera chiara e possibilmente fornita senza che venga utilizzato un gergo legale ma utilizzando frasi semplici in modo che il data subject possa dare un consenso informato e diretto all'utilizzo dei dati personali
- deve essere permesso al data subject di aver accesso in maniera semplice ai dati personali
- sancito anche il diritto alla rettifica, cancellazione e anche al diritto all'oblio (dimenticati) caratteristica più difficile da mettere in atto e garantire, proprio per difficoltà di garantire una cancellazione effettiva totale di tutte le informazioni riguardante l'individuo.

- il data subject ha il diritto di obiettare a riguardo l'utilizzo dei propri dati anche in riferimento allo scopo di profilazione. *Se delle aziende utilizzando i nostri dati per motivi di profilazione, l'utente ha il diritto di decidere di non fornire dati a questo scopo*
- portabilità del dato. Diritto di difficile attuazione

1.6.1 Privacy by Design by Default

Nuovo principio che viene sancito da questo regolamento è il Privacy by Design by default. Il GDPR nel suo testo rafforza e incoraggia l'utilizzo di questo

- il concetto di privacy by design è in sostanza un'evoluzione del concetto di privacy by default ma attuato in maniera più drastica. Richiede ad esempio che l'intero processo di business sia sviluppato tenendo in mente i principi di protezione del dato. L'idea principale che se un servizio decide i settaggi della data protection, questi devono essere messi al massimo a livello di default (l'utente deve decidere se ampliare il numero di dati)
- il titolare del trattamento deve mettere in atto delle procedure tecniche per essere sicuro che il trattamento del dato sia compliance con il GDPR, in particolare compliance con i principi sanciti dal privacy by design by default
- il titolare del trattamento deve implementare meccanismi che permettono che i dati siano processati quando sono necessari e solo per obiettivi specifici

Si inizia a parlare di privacy by design by default verso la fine degli anni '90. Anna Cvoukian, sancisce quelli che sono i principi che vanno intesi come buone prassi di system engineering per fare in modo che prendano in considerazione la privacy in tutto il processo di ingegnerizzazione. Fin dalle fasi di raccolta dei requisiti, fino alle operazioni di post vendita e manutenzione del prodotto. In tutte le fasi deve essere sempre preso in considerazione l'aspetto riguardante la privacy.

I principi fondamentali della privacy by design by default

1. deve essere proattiva e non reattiva; preventiva e non utilizzata come un rimedio ad un eventuale problema di divulgazione di dati personali non autorizzato. I sistemi devono già prevedere delle misure di protezioni del dato che prevengano eventuali abusi sui dati o eventuali divulgazioni non autorizzate sui dati, quindi adottare di misure di sicurezza per la protezione del dato;
2. la privacy deve essere considerata come impostazione di default del sistema. Sta eventualmente all'utente decidere se dare più informazioni all'azienda;
3. privacy incorporata con design dell'intero servizio (dall'analisi di mercato, fino al ciclo di vita del prodotto)
4. garantire il fatto che prodotto/servizio sia interamente funzionante, ed essere a somma positiva e non a somma zero. Significa che con il fatto vogliamo proteggere una protezione degli utenti, non possiamo fornire un servizio inefficiente, quindi il servizio deve comunque dare delle buone funzionalità all'utente ma lo deve fare nel rispetto della privacy. Funzionalità e privacy possono essere viste sia come trade-off ma comunque deve essere a somma positiva a vantaggio delle funzionalità del sistema;
5. deve esserci sicurezza end-to-end, protezione della pp per l'intero ciclo di vita del prodotto;

6. visibilità di trasparenza devono essere principi che devono essere rafforzati nello sviluppo e implementazioni dei sistemi quindi fare in modo che venga tenuto aperto il modo con cui vengono rafforzate alcune misure di pp. OPEN-source assicura che il sof sia sicuro.
7. l'utente deve essere messo al centro del sistema e pensare all'intero prodotto avendo in mente che l'utente sia sempre al centro tenendo in mente che l'utente è al centro e bisogna avere rispetto della sua privacy.

1.6.2 La pseudonomizzazione all'interno del GDPR

Abbiamo detto che il GDPR si riferisce alla pseudo, come un processo che trasforma i dati personali in modo che questi dati non possono più essere attribuiti univocamente ad un data subject, senza l'utilizzo di informazione aggiuntiva.

- usare qualche forma di cifratura di dati in modo che siano cifrati in locale
- separare quelle che sono le chiavi di cifratura dai dati cifrati in modo che poi chi accede al sistema in maniera fraudolenta non possa avere sia chiavi che dati. Questo chiaramente rafforza le modalità di protezione del dato
- se si dimostra che i dati sono pseudonomizzati con delle policy interne adeguate, allora il GDPR considera che i dati sono effettivamente anonimi e quindi non soggetti a controlli e a sanzioni.
- il regolamento non riguarda il processamento di informazioni che sono considerate di per se considerate già anonime, come quelle mantenute per motivi statistici o di ricerca
- se come azienda vengono messe in atto delle policy che sono aderenti ai principi di data protection by design e default, allora possiamo considerare queste misure come adeguate allo scopo del trattamento dei dati come codificato nel GDPR.

Tutto Questo non è di semplice attuazione. Innanzitutto, la pBYdBYd è definita in termini di principi. Esistono poche linee guida che permettono tutto ciò. Bisogna garantire che ci sia sempre un'adeguata protezione delle varie parti che vanno a permettere il collegamento del dato personale con il data subject.

1.6.3 Responsibility e accountability

Altro principio importante che viene sancito all'interno del GDPR. In italiano tradotti come responsabilità e responsabilizzazione

- Il titolare del trattamento deve essere in grado di dimostrare SEMPRE che il trattamento viene fatto in compliance con il GDPR e che sono state prese misure adeguate che vanno a mettere in atto i principi sanciti dalla data protection by design e default
- il titolare del trattamento ha la responsabilità di implementare le misure efficaci ed effettive e capace di dimostrare la compliance dei processi delle varie attività relativamente ai principi sanciti dal GDPR
- gli utenti devono poter essere responsabilizzati, quindi informati su quanto dei loro dati vengono raccolti, quali sono le basi legali per il processamento dei dati personali, quanto a lungo sono memorizzati questi dati, se vengono trasferiti dentro o fuori l'UE e comunque bisogna fornire informazione su come eventuali processi di decisioni fatti in maniera automatica sono realizzati e soprattutto bisogna essere sicuri che le varie decisioni non vengono prese sulla base di algoritmi, ma che ci sia in qualche modo il controllo di essere umani.

- utenti devono avere linformazione corretta su chi sia il titolare del trattamento e inoltre questo deve anche nominare il **data protection officer** nei casi in cui questo è necessario.²
- deve essere prodotto un documento noto come Data protection impact assessments (DPIA) di pia. dv essere tale per cui devono essere analizzati tutti i rischi che possono riguardare un particolare trattamento, applicazione, servizio
- devono essere anche documentati le varie misure dellanalisi di rischio e mitigazione del rischio. dv essere fatta unoperazione di risk assest, misura il rischio e inoltre tutta la DPAs deve essere in qualche modo approvato dal data protectio autor o altre autorità proposte allo scopo
- deve esserci un registro dei trattamenti mantenuto in modo che vengono elencati quelli che sono gli obiettivi dei vari trattamenti, categorie di dati coinvolte e i vari limiti di tempo del trattamento
- questo registro del trattamento devv essere reso disponibile allautorità garante

1.6.4 Il data protection officer (DPO)

Data Protection officer (DPO), per quanto riguarda la normativa italiana viene introdotto come responsabile per la collezione del dato personale. tutte le organizzazioni grandi e medio grandi, anche associazioni e azienda che in generale trattano dati di utenti devono dotarsi di questa figura. è una persona che ha unesperienza sia legale (rigurdante quelle che sono le ornative della privacy) anche tecnica e pratica e che puo assistere i titolari del trattamento in tutte le operazioni di monitoraggio di processi di adeguamento al regolamento europeo sulla privacy. Il DPO deve essere un

- esperto di processi IT e cyber security
- garantire la continuità dei servizi oltre a conoscere tutti gli aspetti legali sulla normativa della privacy

Tutte le autorità pubbliche, aziende, attività produttive che hanno al centro del loro business il trattamento sistematico e regolare dei dati personali devono avere un DPO. Università ha un DPO. Assunto dallazienda o ente esterno. Dipende comunque da quanto è grande lazienda

1.6.5 Il data breach

Con data breachs si fa riferimento alla violazione dei dati

- Il titolare del trattamento ha lobbigo di notificare lautorità garante senza aspettare un lasso di tempo esagerato (quindi notificare per tempo) che è avvenuto un data breaches e che questo non ha causato una violazione di quelli che sono i diritti fondamentali dellindividuo. Deve assicurare al garante i danni che questa violazione ha causato.
- ha 72 ore di tempo per effettuare un report che informa il garante che ha riguardato questo data bre
- nel caso in cui ci sia un impatto importante su quella che è la liberta dellindividuo, quinsi sulla pp dellindividio a seguito di una violazione dei dati gli utenti devono essere tutti avvertiti. ovviamente lobbigo non persiste nel caso in qui la violazione non ha causato perdita di dati e divulgaione di dati a persone non autorizzate

²Il data protection officer è una figura molto importante nellambito del GDPR

- il responsabile del trattamento deve notificare al titolare del trattamento senza nessun ritardo il momento in cui è a conoscenza di un eventuale data breach e se i dati non sono stati toccati più di tanto da questo data breach e se in particolare il data controller ha implementato delle misure tecniche e organizzative che permettono questi dati non interpretabili e non leggibili (in quanto memorizzati in forma cifrata) allora in questo caso possiamo anche non avvertire della violazione

Il messaggio che dobbiamo portare a casa da tutto quello visto finora è una conoscenza che ricopre almeno coinvolgere quelli che sono i principi fondamentali che riguardano la protezione del dato e i regolamenti che riguardano la protezione del dato. Questa protezione è da non sottovalutare.

1.7 Il passaggio da una nazione all'altra

Problematiche che riguardano il passaggio di dati da una nazione all'altra.

1. safe harbor privacy principles
2. EU-US privacy shield

Così come si regola il traffico di merci attraverso trattati internazionali, essendo i dati una ricchezza/valore aggiunto per aziende, organizzazione, anche questo trasferimento di dati ha necessità di regolamenti più dettagliati che riguardano le norme internazionali. In particolare vediamo

- la safe harbor privacy principles, è stato un quadro normativo sviluppato dal 1988-2000, ai fini di evitare che organizzazioni che operavano all'interno di EU o Stati Uniti potessero divulgare in maniera accidentale o perdere informazioni private, riguardante i cittadini di altre nazioni. In sostanza, stabilivano che le company di USA dovevano memorizzare i dati, soprattutto di cittadini europei, aderendo a questi 7 principi
 1. informare gli individui sul fatto che i loro dati venivano utilizzati e collezionati
 2. scelta che potevano esercitare gli individui che potevano o non potevano cedere i dati a terze parti
 3. dati potevano trasferiti solo se c'erano garanzie adeguate di protezione dei dati
 4. sicurezza del dato garantita
 5. integrità del dato garantita
 6. accesso garantito da parte dell'individuo in modo che questi potevano accedere alle informazioni riguardanti i propri dati
 7. misure effettive per esigere il rispetto di queste norme

La commissione europea nel 2000 ha deciso che i principi del safe harbor erano compliance con la direttiva europea e quindi il safe harbour degli USA era aderente appunto ai principi della direttiva dell'unione europea. Successivamente un cliente si lamentò del fatto che Facebook non proteggeva in maniera adeguata i dati dei cittadini. Di conseguenza la corte di giustizia della commissione europea dichiarò nell'ottobre 2015 che la Safe Harbor Decision (la decisione che l'IEU aveva accolto il safe harbour è data anno 2000) non era più valida, proprio per cui doveva essere sostituito. Compito intrapreso dalle varie nazioni, fino a quando nel febbraio del 2016 non si arrivò al cosiddetto **privacy shield**. Il problema di questo è che è del tutto bloccato nonostante la commissione europea abbia adottato questo regolamento il 12 luglio 2016. Negli USA Trump ha sostanzialmente promulgato un regolamento ("enacting public safety" regolamento per aumentare la sicurezza degli USA, in cui in sostanza diceva che tutti i regolamenti che si applicano per la protezione del dato dei cittadini statunitensi non vengono applicati fuori ai confini degli USA e soprattutto a quelli non residenti agli USA. Esempio lampante è quello di Facebook o di altri attori di internet (social media) che continuano a trattare dati dei cittadini europei in maniera poco chiara.

Chapter 2

Privacy in the «Big Data Era»

Quello che andremo a fare è andare ad inquadrare la privacy all'interno di un quadro epocale, ovvero l'era dei Big Data. Nel 1996 (albori di internet) in America il 24% della popolazione aveva personalmente provato una qualche invasione della privacy. Soltanto nel 1978, questa percentuale era del 19%. In mezzo a questi anni si è diffuso parecchio l'utilizzo di tecnologia informatiche nella vita di tutti i giorni, soprattutto in ambito bancario, assicurativo e medico. Di conseguenza, è nato il bisogno di proteggere la propria privacy di anno in anno. Se dovessimo misurare la percentuale di persone che credono che la propria privacy sia a rischio, sicuramente queste percentuali aumenterebbero.

Aspetto su cui noi ci focalizzeremo

Si può parlare di compromesso tra la privacy e i vantaggi che derivano dall'utilizzo dei nostri dati.

- dobbiamo vedere la privacy come un ostacolo nell'utilizzare i nostri servizi?
- oppure vedere l'utilizzo di questi servizi senza che venga compromessa la nostra privacy? Naturalmente questo è possibile farlo

Illustreremo quelle che sono le tecnologie per raggiungere l'obiettivo previsto, ovvero l'utilizzo di determinati servizi senza che la nostra privacy venga intaccata. Con privacy noi intendiamo avere un controllo di quelle che sono le informazioni riguardanti la nostra vita privata. Non vorremmo essere discriminati, che sia per un'idea politica o religiosa, quindi occorre che la privacy delle persone venga preservata.

Il diritto alla privacy era definito con il diritto di essere lasciati soli. Da questo si è susseguito un'evoluzione che ha trovato posto nelle Costituzioni, carte di diritti, ecc. ecc.

Vivendo nell'epoca dei Big Data non possiamo far finta di niente. Ci sono delle collezioni enormi di dati che ci riguardano, dove per fortuna, sono così tanti che alcuni non sanno nemmeno di utilizzarli, ma d'altra canto sono così tanti che viene difficile proteggerli. In qualche modo, ci sono varie problematiche che sono state introdotte in quest'epoca:

- **datafication**, processo tecnologico che trasforma vari aspetti della vita sociale o della vita individuale in dati che vengono successivamente trasformati in informazioni dotate di nuove forme di valore anche economico;
- **enorme quantità di dati "disordinati (messy)" non strutturati**. Abbiamo dati enormi e sporchi. Essendo sporchi non sappiamo esattamente a cosa fa riferimento ogni dato. Cosa che non avviene ad esempio in un DBMS tradizionale, dove sappiamo cosa viene associato ad ogni dato; Queste quantità di dati sono così tante che alle volte ci chiediamo se esiste una qualche tecnologia che permette di utilizzarli. La grossa quantità

di dati permette di trovare pattern che prima era impossibile trovare. Una cosa che è stata scoperta andando ad analizzare i Big Data era che prendere un farmaco depressivo insieme ad un farmaco anti-colesterolo, ha permesso d'individuare un numero di glucosio elevato nel sangue e questo ha permesso quindi d'individuare questi soggetti che soffrivano di diabete.

Punto doloso, se dovessimo scovare un pattern pericoloso, questo potrebbe essere utilizzato in maniera non corretta.

I BD coinvolgono dati di diverso tipo e in qualche modo questi dati possono essere utilizzati per fare analisi a 360Gradi. Quindi possibile che grandi mole di dati permettano di facilitare l'utilizzo di questi dati per scopi di intelligence.

Information privacy

La capacità, abilità, che abbiamo noi essere umani di determinare per noi stessi quali informazioni possono essere raccolte da terzi e cosa possono fare queste altre persone con le nostre informazioni. Quello che si osservato è che nessuna degli sviluppi mostrati può essere fatto senza una perdita del controllo dei nostri dati, o almeno questo è quello che si pensa. Quello che cercheremo di capire se in realtà c'è la possibilità di scoprire nuovi pattern o modellare/analizzare un certo tipo di comportamento senza accedere ai singoli dati delle persone senza che si invada la pp delle persone. **tutto questo è relativamente difficile da fare**

Threat: Deanonimizzazione

Potremmo pensare che i dati raccolti dall'azienda sono anonimizzati e che quindi non saranno mai ricondotti alla mia persona. Il problema è che in realtà tutto questo non è tanto facile da realizzare. La sono **anonimizzazione** dei dati non risolve il problema. Una serie di eventi realmente accaduti smentiscono questa ipotesi, ovvero eliminare l'identificativo.

Spiegare il caso studio di Netflix

- Netflix Ha rilasciato un database riguardante il rating degli utenti per i vari film. Dataset rilasciato inizialmente per scopi di ricerca, in forma anonima. Dati che riguardavano 100,000,000 privati rilasciati da 500,000 utenti.
- L'obiettivo era quello di migliorare la **raccomandazione**, ovvero processo in cui in base ad un profilo, a questo profilo vengono associati dei film basati su quelle che erano le loro abitudini.
- se all'utente X piacciono i film A,B,C a questo utente X piacerà senz'altro un film D. Problema, era possibile, molto facilmente combinare i voti privati di Netflix con le recensioni pubbliche sul sito IMDB, database che raccoglie molte informazioni su film, dai registri, agli attori, alle recensioni di film. Incrociando i voti dati dagli utenti di Netflix con i rating pubblici rilasciati da utenti che avevano pubblicamente dato dei voti su determinati film, è stato possibile reidentificare lo stesso utente sia per Netflix che per IMDB. Di conseguenza è stato possibile associare l'utente X con la visione/voto di un film per adulti. In sostanza, statisticamente si è osservato, che bastava conoscere dai 6 agli 8 rating approssimati (possibilmente correlati da date) per identificare in maniera univoca, un singolo utente con un 90%. Per esempio andando a correlare il dataset di Netflix con 50 utenti di IMDB, questo ha portato all'identificazione di due record. Conseguenza di tutto è che Netflix ha cancellato la seconda parte della challenge. Da questo avvenimento s'impara come l'anonimizzazione non si può ridurre alla sola

rimozione dell'identificato. La grossa mole di dati presenti online permette di trovare molta più informazione.

Costo di un data breach

Uno studio commissionato da IBM ha fatto emergere come in sostanza un costo medio di data breach è di circa 4 milioni (in Italia è più basso in quanto non esistono tantissime aziende che lavorano con i dati). Dal 2013 il costo totale di un data breach è aumentato del 13%. Aumento dovuto da tanti fattori, dalle spese legali a fattori dovuti alla messa in sicurezza dei sistemi.

- 158\$ costo medio per ogni singolo dato rubato
- guardando le varie categorie di dati, emerge che i dati di tipo sanitario hanno un costo maggiore, a questi seguono dati relativi all'educazione e alla finanza.

Chapter 3

Information Systems and Privacy

In questo capitolo ci occuperemo di come rafforzare le misure di data protection e la salvaguardia della privacy nei sistemi informativi.

3.1 Information system

Può essere definito come un sistema formale socio-tecnico organizzazionale progettato per diversi scopi che hanno a che fare con le informazioni gestite dall'azienda. L'azienda, o ente che sia, non può far a meno di far circolare informazioni per operare, proprio per cui qualsiasi processo che venga messo in atto dall'organizzazione trova la sua forma in informazioni che vengono scambiate tra un reparto e l'altro, oppure tra organizzazione e fornitore.

Essenzialmente le operazioni da compiere sulle informazioni, sono:

- raccolta;
- trattamento;
- memorizzazione;
- distribuzione delle informazioni. Vista anche come comunicazione con l'esterno.

Quindi, un sistema informativo deve poter gestire le informazioni in questo modo. Composto non solo da tecnologia informatica, ma comprende anche l'interazioni che c'è tra gli umani.

3.1.1 Computer Information System

È un sistema composta principalmente da persone che interagiscono con computer e che processano/interpretano le informazioni. È composto in particolare, da:

- insieme di risorse sw o hw (programmi e server gestionali che ospitano i vari applicativi). Sistemi che lavorano insieme per acquisire/raccogliere informazioni che sono necessari per l'organizzazione dell'azienda stessa
- immagazzinare informazione
- processare le informazioni
- distribuzione delle informazioni

Ha gli stessi compiti del sistema informativo. L'informazione ha l'obiettivo di supportare

- l'attività dell'organizzazione, quindi l'automazione dell'organizzazione. Un esempio sono i processi di trattamento dei documenti. Ordine che deve essere processato per portare a termine un determinato scopo. Parte dal singolo utente, fino ad arrivare all'ufficio acquisto. Si nota come c'è un processo in cui c'è uno scambio di informazioni. Processo automatizzato in modo che sia più agevole per tutti gli attori dell'organizzazione.

- supporto alle decisioni, prese dal CDA o dall'ufficio marketing. Decisioni che si avvalgono di diverse attività
- analisi, controllo, coordinamento e visualizzazione di reporting che si avvalgono di strumenti avanzati per data analysis e machine learning.

Comunque queste parti di un sistema decisionali dell'organizzazione e attività dei normali processi dell'organizzazione, si avvalgono, di grosso scambio di informazioni. Si nota come l'informazione è al centro per il funzionamento di un sistema informatico.

3.1.2 Information Systems and (private) data

Il sistema può avere accesso anche ad informazioni private. Il sistema funziona grazie allo scambio di dati, dove questi, possono essere modellati come un insieme di processi interconnessi tra loro, dove output di un processo potrebbe essere l'input per un altro processo. I dati possono appartenere a differenti entità:

- impiegati che producono dati che gli riguardano (ferie, stipendi, loro produttività), dati prodotti dal modo di lavorare nell'azienda
- attori esterni che forniscono dati all'azienda che permettono loro di operare con l'azienda. Sono utenti, o aziende che forniscono beni, fornitori, questi forniscono beni e servizi all'azienda stessa.

Esistono anche tipi di dati che sono scambiati all'interno dell'azienda e vanno dal personal identification data (dati che permettono l'identificazione delle persone), fino a considerare anche il contenuto generato dall'utente (forum di discussione, centro di raccolta di recensioni). Anche l'email scambiati all'interno stessa dell'azienda, o tra clienti/fornitori con l'azienda. Dati transazionali (operazioni finanziarie se stiamo parlando di una banca). Log di processi prodotti dall'azienda, sensori posizionati sui macchinari. Dati applicativi, dati prodotti anche dalle applicazioni in uso da parte del personale dell'azienda o anche eventualmente dai clienti.

Esiste uno scambio di informazioni, questo scambio (almeno in parte) potrebbe essere anche di tipo privato e poi a seconda del core-business alcune di esse potrebbero essere anche sensibile (toccando sfera personale delle persone), proprio per cui occorre attuare dei metodi in modo che si rafforzi la privacy nei sistemi informativi aziendali. Esistono vari livelli su cui è possibile operare.

1. formare impiegati e manager. Formazione sul campo. Eventualmente con casi di studio (workshop) che mettono in grado non soltanto gli impiegati, ma anche i manager essendo i responsabili dei dati trattati all'interno dell'azienda, devono essere messi in condizioni dell'eventuale violazioni di quelle che possono essere che riguardano i dati privati e devono sapere quelle che sono le contromisure da adottare per evitare che questo avvenga o per risolvere la violazione
2. rafforzamento di misure di privacy all'interno dell'azienda e rafforzamento di misure di cyber security (da intendere diversi aspetti, che va dalla possibilità di cifrare HD, o pen-drive, dal controllo del traffico di rete)
3. rafforzare la rete con firewall
4. idea di non permettere accesso fisico ad aree che sono ritenute sensibili. Ad esempio evitare l'accesso ad data-center, solo il personale autorizzato può avere accesso fisico a queste aree
5. Using VPN for remote work. L'idea di poter lavorare da casa è importantissimo, si è dimostrato anche che potrebbe aumentare la produttività, ma questo comporta un accesso ad una rete di per se non protetta. Con le VPN abbiamo una garanzia di sicurezza in più per lo scambio di dati

6. tenere sempre aggiornato il software in modo che tutte le varie vulnerabilità siano risolte in modo che attaccanti non riescono a sfruttare a vulnerabilità vecchie

Noi ci soffermeremo su come fare in modo che un sistema informatico sia compliant con le norme rafforzate dal GDPR, quindi come fare a mettere in sicurezza un sistema informatico in relazione a quelli che sono i principi che vengono rafforzati nel GDPR, che vengono incoraggiati dal GDPR.

Esempio che potrebbe far capire cosa vorrebbe dire essere compliance con il GDPR

Alice vuole in qualche modo accedere ad un mutuo per l'acquisto di una casa e si rivolge a questo ad un consulente privato. Il consulente deve discutere con Alice per capire quale sia la sua situazione personale, proprio x cui deve accedere a informazioni personali, quali reddito personale, professione e caratteristiche personali come il fatto che sia o meno sposata o che abbia figli. Queste informazioni sono utili in modo da offrire il miglior prodotto possibile. Ovvero quello che le garantisce la sicurezza di pagare le rate e un interesse non troppo elevato. Il consulente adesso può rivolgersi ad un'agenzia che eroga mutui fornendo il profilo di Alice da lui stilato. Una volta acquisite le varie quotazioni, il consulente ha finito il suo lavoro e Alice può accettare l'offerta o declinare.

Quali sono gli elementi d'interesse per il GDPR?

- È fondamentale capire quali sono le parti che hanno memorizzato le informazioni private di Alice. Sono il consulente e il provider e tra questi, la logica prevede che il solo provider che stipulerà un contratto con Alice andrà a salvare le informazioni. Il problema è capire cosa devono fare gli altri provider che le hanno fornito una quotazione.
- Essendo comunque un processo composto da scambio d'informazioni, queste chiaramente sono memorizzate da qualche parte (per qualsiasi provider). In che modo Alice può capire dove e da chi queste informazioni sono state memorizzate? Come sappiamo il GDPR stabilisce il principio della trasparenza e di conseguenza Alice deve sapere chi tratta le sue informazioni, chi ha avuto accesso e dove sono memorizzate.
- Le parti coinvolte in questo processo soddisfano i requisiti della legge sul GDPR? Chiaramente se operiamo nello stesso paese è chiaro che gli attori abbiano una compliance con il GDPR pieno, ma se immaginassimo un qualcosa di più internazionale? È lecito chiedersi se tutte le parti coinvolte nel processo soddisfano i requisiti del GDPR. Una volta scelto il prestito come fa Alice ad assicurarsi che le informazioni precedentemente salvate vengono effettivamente cancellate? Il GDPR impone che i dati non sono tenuti più del tempo necessario (nozione che si presta a varie interpretazioni).

3.1.3 Sistema informatico e il GDPR

Come rendere il sistema informativo più sicuro in ottica non solo di GDPR ma anche in ottica di salvaguardia di privacy degli utenti. Quattro caratteristiche importanti che un sistema informatico deve assicurare in modo che sia compliant con il GDPR.

1. Bisognerebbe utilizzare un sistema d'autorizzazione basato su attributi, sistema dichiarativo interamente tracciabile che offra meccanismi per l'accesso di dati sotto determinate circostanze.
2. garantire anonimizzazione e pseudonimizzazione. Se un'azienda riesce a garantire la pseudonimizzazione dei dati e riesce a dimostrarlo che i dati siano pseudonimizzati in maniera corretta, a quel punto le leggi che riguardano il GDPR sono molto più blande verso l'azienda. Con la separazione del dato privato da quello identificativo, possiamo assicurare che il dato privato non venga utilizzato per fini malevoli.

3. tracciabilità, aspetto fondamentale del GDPR. Avere un registro che tenga traccia di chi ha creato e modificato e cancellato le informazioni e lo scopo scaturito per l'accesso al dato
4. data deletion, diritto di essere dimenticati senza in qualche modo intaccare l'affidabilità del sistema stesso.

3.2 Attributed Based Authorization

3.2.1 Access Control

Controllo degli accessi è un qualcosa che riguarda anche aspetti di cyber security che non vengono trattati in questo corso. È un aspetto molto importante. Sono delle tecniche che permettono di restringere l'accesso a delle risorse informatiche in sistemi in cui ci sono molti utenti e vengono scambiati dei dati. Politiche messi in atto in modo da capire se un determinato attore della nostra azienda può usufruire di determinate informazioni. Se il sistema informativo è complesso, e quindi se anche la complessità di meccanismi d'accesso è di un certo livello, chiaramente anche il controllo degli accessi deve adeguarsi a questo tipo di complessità. Sistemi semplici richiedono controllo d'accesso semplici, sistemi complessi richiedono controllo d'accesso complessi.

Esempi di controlli complessi

Paziente richiede l'accesso ad un fascicolo sanitario elettronico e decidere che questo può essere consultabile da un determinato medico, o da uno specifico centro medico. Succede che questa norma viene applicata in una situazione normale, ma in una situazione d'emergenza chiunque deve avere la possibilità di accedere a questo fascicolo, onde evitare problemi durante ad esempio un intervento. Si notano due tipi di situazioni, una normale e una emergenziale. Tipicamente un sistema di controllo degli accessi deve tener conto di queste informazioni.

3.2.2 Role Based Access Control (RBAC)

- sistema di controllo degli accessi formalizzato 30anni fa circa dal NIST
- aveva in qualche modo definito/standardizzato tutte le varie proposte di sistema di controllo degli accessi che venivano fatte in quel periodo da centri di ricerca, o comunque università che operavano nel campo della sicurezza
- meccanismo valido per sistemi composti da 500 impiegati. Una volta passati ad organizzazione molto più grosse il RBAC limita molto le capacità di controllare gli accessi.

L'idea è la seguente. Anzichè avvalersi di UserID per decidere quelli che sono i diritti d'accesso di un certo utente, questo sistema si avvale dei ruoli che gli utenti assumono nei vari processi del sistema informativo C'è una prima mappatura tra utenti e ruoli e una seconda mappatura tra ruoli e risorse di cui si può avere l'accesso. Abbiamo anche la tipologia di accesso, solo lettura/scrittura. Il ruolo funge come livello extra d'astrazione. È una collezione di permessi e diritti associati ai vari utenti. Ogni ruolo non ha una cardinalità ben precisa, quindi la gestione del controllo degli accessi diventa molto semplice. Una volta definiti i ruoli e come questi ruoli accedano alle risorse è sufficiente assegnare i ruoli corretti ai vari utenti.

Funzionamento

- admin danno permessi d'accesso ai vari ruoli

- gli amministratori devono semplicemente aggiornare ruoli e permessi d'accesso. aggiungendo o rimuovendo utenti. L'assegnamento dei ruoli ai permessi d'accesso deve essere ben curata.

Limiti grossi dell'RBAC

Al giorno d'oggi è abbastanza limitativo avere questo d'accesso. RBAC non è sufficiente. Non c'è soltanto utente e risorsa, ma c'è tutto un contesto che circonda utente e risorsa. C'è un'interazione tra utente e risorse. In sostanza quando vogliamo utilizzare delle risorse non lo facciamo sempre nello stesso modo, ma lo facciamo ogni volta in contesti diversi. Quindi per esempio un controllo degli accessi accurato deve poter tener traccia di:

- chi è l'utente giusto che può fare accesso ad una risorsa
- controllare se l'utente che fa richiesto d'accesso nel giusto momento e posizione geografica e se in quel momento l'utente soddisfa tutta quella che è la compliance relativa alle regole vigenti nello Stato cui sta operando.

Tutto questo il RBAC non può controllarlo e per questo motivo, c'è uno shift verso un paradigma definito ABAC, modello d'accesso ai dati basato sugli attributi.

3.2.3 Attributed Based Access Control (ABAC)

Permette di definire in maniera accurata un contesto. Quando si aggiunge il contesto le decisioni che riguardano l'accesso a dei dati viene fatto in base al contesto che comprendono diverse proprietà

- ruolo rimane comunque importante e quindi tenuto in conto per decidere se effettivamente viene possibile accedere ai dati
- bisogna capire chi e a che cosa questo utente è collegato e di cosa l'utente ha necessità d'accedere
- da dove l'utente vuole accedere - casa, sistema protetto, totem
- quando ha necessità di accedere a queste informazioni
- come questo utente sta accedendo a queste informazioni

Ci sono varie domande che vengono poste. Chi, cosa, dove, come e quando. Domande che la semplice politica RBAC non può soddisfare, cosa che un ABAC opportunamente settato può consentire l'accesso o meno alla risorsa. Nel momento in cui si definiscono correttamente il contesto tra utenti e attributi, le policy possono essere definite anche in maniera più robusta. Viene possibile specificare da parte dell'utente, creare/approvare un ordine d'acquisto ma in qualche modo questo utente non può approvare l'ordine ad esempio se È lui stesso che lo ha creato. Ci deve essere sempre un altro livello di controllo sull'ordine d'acquisto. La conoscenza del ruolo si vede come non è più sufficiente per un accesso sicuro al dato.

Immaginiamo diversi utenti dipendenti all'interno di un'azienda - dipartimento d'acquisto.

- Questo fatto da persone che operano con dei macchinari e quindi da persone che devono poter accedere a delle risorse che gli permettono di comprare per esempio un laptop per effettuare meglio il proprio lavoro.
- se l'utente che ha fatto richiesta e avendo anche il ruolo di approvare l'ordine potrebbe comprarselo anche solo e questo non È tanto auspicabile. Potrebbe favorire comportamenti illeciti quindi ci vuole un meccanismo che dica che questo potrebbe essere fatto (ovvero l'approvazione) soltanto se lo stesso utente non ha effettuato l'ordine.

- Il tutto viene reso possibile solo con ABAC. Contesto e informazioni di relazioni che coinvolgono le varie entità di sistema sono fondamentali. ABAC permette alle aziende di estendere i ruoli usando da un lato attributi e dall'altro le politiche d'accesso.

Intuizione che c'è dietro

ABAC, cerca di costruire delle politiche d'accesso ai dati, sfruttando linguaggio naturale. L'idea è di poter esprimere politiche d'accesso ai dati sfruttando qualcosa che può essere vista con un linguaggio simile a quello naturale. ES. I dottori possono visionare i fascicoli sanitari di qualsiasi paziente nel loro dipartimento. Possono fare update dei fascicoli ai soli pazienti assegnati a loro, con device approvati e soltanto nelle ore di lavoro. Una politica di questo tipo È difficile da esprimere attraverso il solo RBAC.

ABAC dal punto di vista di come è strutturato può essere visto simile all'RBAC, anche ABAC adotta un approccio guidato da policy.

- anziché usare ruoli vengono definiti attributi di soggetti, oggetti e ambiente.
- dove gli attributi possono essere usati per esprimere delle policy più ricche e articolate
- allevia la necessità di essere registrati nel sistema per accedere alle risorse. Se non siamo un utente del sistema vero e proprio, ma esprimo una richiesta esprimendo correttamente il contesto, ABAC potrebbe in qualche modo accontentarmi. Cosa impossibile con RBAC, limita accesso alle risorse ai soli utenti registrati, quindi non concede risorse ad utenti esterni.

Funzionamento nel dettaglio (slide 18)

1. immaginiamo di aver gli utenti (subject) definiti da un insieme di attributi
2. ambiente dove operano gli utenti e che viene definito in qualche modo anche attraverso degli attributi
3. patrimonio informativo cui l'utente vuole accedere. Sono risorse e azioni compiute su risorse e queste risorse e azioni sono definite attraverso attributi

Si nota come gli attributi servono a definire tutte e tre. Queste varie caratteristiche vengono processati da un motore di autorizzazione che accede alle policy, verifica che siano soddisfatte per la richiesta che perviene da un certo utente, che opera in un certo ambiente, che ha bisogno di effettuare una certa azione su una certa risorsa. In base a policy e in base alla richiesta decide se quest'ultima può essere accettato o reject.

Le entità in ABAC

1. Il soggetto è colui che fa l'accesso a qualche tipologia di servizio.
 - abbiamo diversi tipi di attributi associati all'utente. Possono essere i ruoli assunti dall'utente. L'appartenenza a dei gruppi. Dipartimento, livello manageriale, certificazione di competenze.
 - azione è la tipologia d'azione che deve essere fatta sulla risorsa su cui si vuole accedere. È di tipo read or write. In alcune situazioni l'azione potrebbe essere descritta da una combinazione di attributi. Se stessimo operando in un sistema di online banking potremmo specificare il tipo d'azione deposito, quantità di quello che voglio versare.

2. risorsa identifica, ovvero qual'è l'oggetto impattato dall'azione. Gli attributi possono essere utilizzati per definire l'oggetto. Nell'online banking un tipo di attributo potrebbe essere il numero di CC. Nei sistemi di gestione dei documenti attributi corrispondono ai metadati e utilizzati per identificare quelle che sono le risorse documentali d'interesse.
3. ambiente. importante xk permette di restringere ancor di più e identifica il contesto in cui l'accesso viene richiesto.
 - ora corrente e posizione geografica. La richiesta fatta ad esempio durante la notte non viene accettata.
 - tipo di canale di comunicazione
 - tipo di protocollo o potenza di cifratura
 - tipo di client che stiamo utilizzando

Tutte queste informazioni sono processate dal motore di autorizzazione e questo confronta tutto gli attributi della richiesta d'accesso con le policy che descrivono le varie casistiche che permettono d'accedere alle varie informazioni e se c'è concordanza tra policy e attributi di richiesta allora la richiesta viene soddisfatta.

Authorization Engine (details)

1. richiesta d'accesso viene portata verso un PEP - policy enforcement point. PEP è il punto in cui arriva la richiesta e una volta arrivata (visualizzare record) e inoltra al policy decision point PDP
2. PDP, componente che prende la decisioni. Guarda la richiesta e quelle che sono le policy che possono essere applicate a questa richiesta. Valuta le policy e restituisce la decisione al PEP. Quest'ultimo comunica all'utente la decisione, andando a cercare e restituire la risorsa all'utente oppure impossibile
3. Nel prendere la decisione, il PDP si avvale degli attributi memorizzati all'interno di PIP. Quindi questo memorizza tutti gli attributi che riguardano le varie risorse e soggetti che possono operare su queste risorse.
4. A questo punto le policy per verificare che la richiesta soddisfi le policy memorizzate nel sistema, il PDP accede all'PAP. Qui sono memorizzate tutte le policy
5. Una volta che il PDP ha potuto accedere agli attributi addizionali alle policy le ha confrontate con la richiesta a quel punto può decidere se l'utente può visualizzare la richiesta oppure no.

Il linguaggio d'interscambio usato da queste componenti È noto come XACML.

- standard che implementa ABAC anche se ne esistono altre che sfruttano standard un po' meno strutturati come JSON.
- XACML, eXtensible Access Control Markup Language. Dialecto di XML espressamente pensato per esprimere richieste d'accesso, ma anche a delle policy d'accesso ai dati.

3.2.4 XACML

Esempio di XACML per capire come sono strutturate richieste d'accesso e policy. Entrambe espresse in XACML.

- data store che in qualche modo raccoglie dati clinici di salute da varie provider di servizi health care - cliniche, assicurazioni, ecc. Informazioni gestiti da vari attori che operano nel sistema sanitario.

- i dati clinici sono ricevuti dal data store che processa questi dati secondo le istruzioni del paziente e regole legali stabilite per l'utilizzo di questi dati.
- Il paziente è proprietario dei dati (pieno controllo dei dati) e può decidere chi può avere controllo e questa decisione può essere fatta prima che i dati vengono distribuiti a X istituti che possono operare su questi dati.

Policy of Institute 1

Permette il rilascio di pazienti per i soli ricercatori e viene fatta solo se la richiesta è compliance con il GDPR, quindi opero in un paese dove opera il GDPR oppure che abbia una certificazione che assicuri che sia compliance con il GDPR

1. definiamo il policy set definita da un certo nome
2. ogni policy ha un insieme di attributi target su cui opera e definiti attraverso da Attribute ID :Attribute Value
3. definiamo gli access-subject, ovvero i soggetti interessati a questa policy
4. definiamo il tipo di risorse, quindi dati HealtDate e dati mostrati in forma aggregata (quindi somma, media)
5. tipologie di azioni permessa da questa policy sono il relase, read e write

Definizione di una policy specifica

1. strutturata da un target, specifico target che riguarda questa specifica policy
2. il subject role di questa policy è il ricercatore
3. le risorse interessate da questa policy sono la HealtDate e Aggregate
4. l'azione interessata da questa policy è la Release, quindi rilascio di dati di tipo aggregato o dati semplice al ricercatore

Definizione di regola per la policy

- ha un suo ID e ha un effetto di Permit ovvero se soddisfatta l'effetto è garantire l'accesso ai dati al ricercatore
- condizione espressa utilizzando le caratteristiche del linguaggio XACML, if che si esprime tramite una function *string-equal*, l'access-subject deve avere l'attributo GDPR comp settato a YES.

Nel caso della policy del paziente 2 c'è anche un'obbligazione, ovvero se la data viene riscritta allora l'accesso viene permesso. Poi abbiamo una regola di default che dice che in generale l'accesso viene negato.

Esempio di richiesta d'accesso

Consideriamo un ricercatore che vuole accedere ai dati e che sia compliance con il GDPR. Sta conducendo uno studio in modo da capire l'efficacia di un particolare farmaco sperimentale sui sintomi delle patite C, ogni mese nel primo anno di trattamento.

- Il ricercatore avrà necessita d'accedere alla storia passata del paziente, ovvero quale tipologie di farmaci che ha utilizzati il paziente e anche eventuale utilizzo di sostanze.

Siamo a Slide 40

- REQ1 ha il subject-ID, iD del ricercatore che sta facendo l'accesso
- ruolo che è appunto ricercatore
- compliance con il GDPR dove in questo caso è YES
- richiesta di risorsa che si vuole accedere che è HealthData

Viene definito in maniera dettagliata il contenuto dei dati cui si vuole accedere, definendo meglio gli attributi della risorsa

- utilizzo di sostanza, sintomi, malattia di cui il paziente soffre, durata, data

Altra parte della richiesta coinvolge dettagli ulteriori sulle diverse tipologie di dati

- disease, granularità mensile, ultimo anno

L'azione è release e lo scopo del rilascio è studiare l'effetto dei farmaci

Cosa succede quando c'è questa richiesta

1. il data store attraverso IAE inizia a vedere se il target fa match con il target della policySetInstitute
2. anche la risorsa fa match
3. l'azione fa match

Ora possiamo andare a vedere quelle che sono le policy che possono essere applicate

Il **rule-combining algorithm permit-overrides** ha il seguente significato. Nel caso ci dovesse essere una contraddizione tra le regole prevale il permit, quindi anche se c'è una deny la richiesta viene soddisfatta.

Chapter 4

Pseudonimizzazione usando l'encryption

In questo capitolo cercheremo di capire come realizzare un sistema informativo rispetto ai principi sanciti all'interno del GDPR. La **pseudonimizzazione** è un principio cardine del GDPR che se realizzato appropriatamente, ovvero con le tecnologie adeguate, rende la base dati anonima e tutti i principi di protezione del dato sanciti dal GDPR a protezione della privacy dei dati subject viene meno in quanto il dato viene etichettato come **anonimo**, questo permette di non individuare il singolo data subject. Le tecnologie impiegate per ottenere questa pseudonimizzazione sono:

- **encryption**, Vuol dire che i dati sensibili, dati che possono ricondurre all'identificazione di utenti/data subject, devono essere in qualche modo cifrati a livello di server. Nel DB in cui vengono memorizzati devono essere in forma cifrati.
- **dynamic data masking**, evitare l'esposizione di dati sensibili a quelle persone che non hanno diritto all'accesso di questi dati. I dati sono memorizzati in forma chiara nel server, ma quello che succede che nel trasferimento dal server al client una parte di esso vengono cifrati e un'altra parte rimane in chiaro. Sono operazioni diverse tra loro e vengono applicate a tipologie di dati diverso proprio per cui servono procedure di sicurezza diverse.

4.1 Introduzione alla pseudonimizzazione

- È una procedura di gestione del dato che consiste nel de-identificare i singoli dati. Ovvero la raccolta di dati che contengono informazioni privati viene scollegata dai diritti data subject, ovvero i detentori di questi dati.
- Qualsiasi informazione che possa ricondurre all'identità della persona, sono sostanzialmente rimpiazzati da uno o più identificatori anonimi artificiali detti **pseudonimi**.
- Se utilizzo il CF per identificare i paziente possiamo sostituire questo CF con un pseudonimo. Ed esistono diverse metodologie per effettuare questo, comunque per fornire il servizio corretto occorre sapere chi sono questi utenti.
- Fino a quando eseguiamo questa pseudonimizzazione sui dati e poi usiamo i dati pseudonimizzati per effettuare analisi o altri tipi di processamenti (ad esempio per estrarre pattern, o altri) non abbiamo bisogno dell'identificativo del paziente, ma nel momento che forniamo il servizio al paziente dobbiamo sapere quelli che sono i dati del paziente e quindi essere sicuri che un dato pseudonimizzato debba essere correttamente correlato al legittimo proprietario attraverso una procedura di restore.

Bisogna effettuare un'operazione di re-identificazione che però può essere fatta unicamente accedendo a delle informazioni aggiuntive (mapping) tra CF e id numerico. Naturalmente la chiave che permette di riportare i dati singoli ai legittimi data subject, deve essere completamente memorizzata separata rispetto ai dati, altrimenti accedendo ai singoli dati viene possibile accedere alle informazioni che permette poi di re-identificare i singoli dati.

4.1.1 Differenza con l'anonimizzazione

La parola pseudo davanti dice che il dato di per sé è anonimo, ma esiste in sostanza, un qualcosa o chiave che possono essere utilizzate per re-identificare i singoli dati e ricondurli ai data subject originali. Nel caso di dati anonimi non esiste nessuna procedura che permette di ripristinare lo stato originale di questi dati, cioè di ripristinare l'identità dei data subject a cui si riferiscono i dati anonimizzati.

In ogni caso se la pseudonimizzazione è condotta in maniera sicura e la chiave viene protetta, i dati stessi possono essere considerati anonimi e in quanti tali non sono soggetti alle norme previste dal GDPR.

4.1.2 Column Encryption e la sua realizzazione

È una proprietà importante presente nei DB commerciali che serve per proteggere dati sensibili memorizzati nel database. Questa permette ai client di cifrare i dati all'interno dell'applicazione client senza rilevare la chiave di cifratura al motore di database. I dati vengono cifrati, dove il database vede solo i dati cifrati, dove per risultato finale abbiamo che l'encryption fornisce una separazione tra chi possiede i dati e chi gestisce i dati. Di conseguenza chi amministra i dati non ha la possibilità di decifrare questi dati, si può considerare il DB sicuro. Anche bucando il server non sarà possibile decifrare i dati. Così facendo realizziamo una separazione che permette ai dati memorizzati in un server di considerarli pseudonimizzati. Molte delle caratteristiche presenti del GDPR che si applicano in quei casi dove i dati sono gestiti male, non si applicano e quindi siamo al sicuro dal punto di vista della sicurezza.

Quando si decide che una colonna deve essere cifrata, bisogna fornire a livello di definizione di dati, informazioni che riguardano il tipo di algoritmo da utilizzare e le chiavi crittografiche usate per proteggere i dati. Esistono due tipi di chiavi:

1. **column encryption key**, utilizzata per cifrare i dati in colonna. Ogni colonna presenta una chiave di cifratura diversa;
2. **column master key**, chiave che permette la cifratura di una o più colonne

Il DBMS memorizza la configurazione dell'encryption, ovvero memorizza metadati che indicano quale tipo di algoritmo di cifratura è utilizzato e altre informazioni (metadati) che permettono la de-cifratura. Quello che non viene memorizzato sono le chiavi private. Il DBMS memorizza i valori cifrati delle colonne, insieme a questo l'informazione la location (URL) della column master keys in modo da sapere dove andare a cercare la chiave di de-cifratura in modo da poter decifrare i dati. Generalmente le chiavi sono memorizzate in server diversi, key store esterno. Verrà considerato un key store esterno e il database conoscendo l'URL di questo Key Store permette di conoscere la chiave.

Realizzazione di Encryption

Realizzata in diversi modi, oltre a considerare una chiave per ogni colonna o una chiave master per un insieme di colonne, quello che si può fare è utilizzare due tipi di cifratura.

1. **deterministic encryption**.
2. **randomizzata**.

4.1.3 Deterministic Encryption

Data una stringa (valore) da cifrare questo valore verrà cifrato sempre nello stesso modo. Il database genererà lo stesso valore cifrato per ogni valore diverso della colonna cifrata.

Succede che un CF viene cifrato sempre nello stesso modo. Due CF avranno due cifrature diverse, ma dato due volte lo stesso CF ogni volta verrà cifrato nello stesso modo. Importantissimo xk permette sostanzialmente di andare a recuperare i singoli valori (tuple) che corrispondono al valore cifrato

- permette di fare join senza decifrare la stringa
- grouping, avere come attributo su cui raggruppare attributi che sono colonne cifrate
- indici, indicizza le colonne

Il tutto rende la cifratura leggermente meno sicura ma comunque permette di effettuare interrogazione sul database che hanno bisogno di effettuare dei JOIN senza però al contempo decifrare questi dati. Potrebbe accadere che utenti che non sono autorizzati a vedere questi dati, di indovinare informazioni su valori cifrati. Avendo sempre lo stesso valore cifrato, con un po di brute force potremmo decifrare anche dati su cui non potrei conoscere il contenuto. Se il set di valori è piccolo (true or false) viene facile capire quale chiave di cifratura corrisponde a True e a False.

4.1.4 Cifratura randomizzata

Oltre a cifrare dati utilizzando una chiave, usa dei valori random che vanno in qualche modo a sporcare il dato cifrato e di conseguenza quello che succede che lo stesso CF potrà presentare una cifratura diversa, cifratura che dipende dal questo numero random.

Questa è più sicura ma in qualche modo non permette di effettuare ricerche **lookup**, raggruppare dati e indicizzare quelle colonne. Naturalmente il tutto dipende da valori diversi per gli stessi dati.

ID interni o comune di nascita potrebbe essere cifrato con un encryption di tipo deterministico. CF o comunque informazioni che permette di identificare l'utente viene consigliato utilizzato una encryption di tipo randomizzato.

4.1.5 Realizzazione di Encryption all'interno di database commerciali

Nei database Microsoft

In Microsoft viene utilizzato il paradigma **Always encrypted**. Quello che si fa è creare una master key con alcune caratteristiche

- tipo di provider dello store
- path della chiave
- crea una column encryption key specificano
- la column master key (quella definita precedente) estratta soltanto attraverso il key store
- specificato algo di cifratura
- encrypted_value da cifrare.
- nella definizione di tabella ci saranno vari tipologie di attributi dove per alcuni utilizza una cifratura deterministica e altre randomica.

Nei database Oracle

Il modo con cui la column encryption viene definita è **Transparent Data Encryption**. Quello che viene fatto è settare una chiave di criptazione identificata da un certo codice utilizzato per accedere ad un certo key store, dove la tabella viene definita in questo modo

- **id** cifrato in maniera deterministica
- l'attributo viene memorizzato con una cifratura di tipo salt utilizzando come algoritmo il 3DES168

4.1.6 Dynamic Data Masking

Per evitare che i dati vengono estratti in maniera chiara, quello che fa è offuscare questi dati sensibili. La feature viene implementata direttamente nei server di tipo Microsoft ma può essere facilmente implementato in qualsiasi tipo di DBMS semplicemente utilizzando le store procedures.

- il risultato finale permette di rilasciare dati mascherati... come le carte di credito
- stessa cosa per l'email, facendo vedere che si tratta di un email. c*****@gmail.com

Quello che cambia rispetto all'encryption è che in realtà i dati sono in chiaro nel database. Viene semplicemente applicato il masking nel momento in cui si effettua la query per accedere al dato.

La data masking function

Come vengono utilizzati i dati mascherati all'interno di un dato. Tutti gli utenti che hanno owner come ruolo, possono vedere i dati non mascherati, tutti gli altri in forma mascherata. Esistono dei privilegi che vengono dati e revocati. MASK/UNMASK, non può essere dato alle singole tabella in maniera diversa, ma per ogni tabella nello stesso modo xk opera a livello di database. I dati vengono mascherati indipendentemente dal comportamento della select. Nella nuova tabella i dati verranno memorizzati nel modo in cui la select ha catturato quei dati.

Attacco di tipo brute force

È preferibile associare questa tecnica anche a tecniche di auditing in modo da monitorare le attività che vengono effettuate sulle diverse tabelle. Basta avere abbastanza privilegi per lanciare query ad hoc su un db e poter indovinare attraverso query consecutive valori di una singola colonna. Supponiamo che ci sia una colonna di masking sul salario, se non limitiamo i limiti di privilegi, quello che si può fare È andare ad effettuare delle ricerche dicotomiche in cui si fanno ricerche di range sull'attributo salario andando sempre più a restringere il range iniziale

4.1.7 Conclusioni

Quello mostrato che il dynamic data masking non può essere utilizzato come misura isolata per mettere in sicurezza dati sensibili xk viene possibile che gli utenti possano lanciare query ad hoc in modo da trovare in maniera brute force i valori di una certa colonna. Dobbiamo settare in maniera corretta il controllo degli accessi. Il DM è utile per prevenire accessi accidentali ai dati sensibili ma quello che fa non è proteggere in nessun modo accesso da utenti malevoli. Gestire i permessi in maniera accurata. Adottare sempre il principio dei permessi minimi - minimal required permission - se diamo i giusti privilegi siamo più sicuri che tutto quello che stiamo facendo sia corretto. Auditing abilitato in modo da tracciare le attività che sono messe in atto sul singolo database.

4.2 L'auditing

Punto fondamentale:

- come l'auditing possa assicurare il principio di tracciabilità di operazioni all'interno di un sistema informativo. Questo è un punto fondamentale richiesto dalla compliance GDPR

Concetti generali dell'auditing

- indica un processo di validazione di varie tipologie di entità. Utilizzato per esaminare e validare documenti/dati/processi e sistemi

Viene effettuato a livello di singolo documento, ma anche a livello di processi e procedure o intero sistema.

- **audit log**: documento che contiene tutte le attività che sono soggetti ad auditing e memorizzate in ordine cronologico in modo da costruire cosa è effettivamente successo all'interno di un sistema/DBMS

l'**obiettivo** è produrre un insieme di regole aziendali e sistemi di controllo, regolamento e policy. Utilizzando l'auditing viene possibile verificare se determinate policy di sicurezza sono implementate in maniera corretta.

Altre definizioni di processi auditing

- auditor, persona autorizzata ad effettuare l'auditing
- procedure di auditing, insieme di istruzioni che servono al processo di auditing
- report di auditing, documento che contiene quello che si verifica/scoperto durante l'auditing, in modo da capire quelle che sono le criticità di processi oppure x vedere se qualcosa sta funzionando bene
- auditing trail, record cronologico dei cambiamenti di dati, documenti, attività di sistema degli eventi operazionali del sistema. Quindi tiene traccia di ciò che è stato lasciato dal sistema e utilizzate in fase di auditing per analizzare che tutto è eseguito in maniera corretta.

Esistono due tipi di auditing:

1. **auditing interno**, condotto dalla stessa azienda, membri dello staff, in modo da andare a verificare che all'interno dell'azienda tutto è ciò che è stato messo in atto sia corretto. Viene utilizzato soltanto per migliorare procedure interne;
2. **auditing esterno**, è una funzione di controllo eseguita dall'ente indipendente che non fa parte dell'organizzazione. Funzione che viene usata per analizzare e verificare la dichiarazione finanziaria della società.

Attività di auditing

- identificare se ci sono problemi di sicurezza che devono essere risolti
- stabilire piani/procedure/policy per condurre auditing
- condurre auditing interni
- assicurare che tutte le contrattazioni sono raggiunte a livello di azienda
- serve come consulenza x l'ufficio della stessa azienda.

4.2.1 Processo di auditing

Assicura che il sistema sia funzionante e che sia compliance con policy interne, regolamenti e leggi. In generale viene effettuato dopo che il prodotto è stato messo in produzione. Prima della messa in produzione si preferisce non effettuare operazioni di auditing. Il processo di auditing può essere inserito all'interno del ciclo di vita del sistema e utilizzato per diversi obiettivi e diversi livelli

- da un lato capire quelli che sono gli obiettivi
- revisionare e convalidare il sistema
- documentare il risultato

Esempio di ciclo di vita dello sviluppo di un sistema

1. ci sono varie policy, regolamenti che devono essere incorporate come parti del prodotto stesso.
2. messa in produzione bisogna cercare di capire quelli che sono gli obiettivi e fare in modo che questi sono raggiunti
3. revisione degli obiettivi. Assicurarsi che gli obiettivi dell'auditing son raggiunti in accordo con le policy di business e specifiche
4. produzione di report e documentazione che permette di andare a chiarire quelle che sono le modifiche fatto al sistema in fase di sviluppo. Output incorporato nella fase di sviluppo del sistema stesso e soprattutto nella fase di design e implementazione in modo da porre rimedio a problemi che possono riguarda la fase di sviluppo e implementazioni

4.2.2 Il Data Auditing

Come una procedura identica a quella di auditing possa essere implementa a livello di database per effettuare il data audit.

- data audit, record cronologico di modifiche effettuate sui dati che vengono memorizzate su un file di log o tabelle dello database stesso
- **database auditing**, record cronologico delle attività del database stesso

Obiettivi

- verificare che sia preservata l'integrità dati verificare che sia applicata in maniera corretta la mappatura tra utenti e ruoli e ruoli e permessi
- verificare che i dati siano protetti e confidenziali
- procedure di access control sia eseguite in maniera corretta
- cambiamenti dati seguono effettivamente i processi per cui sono stati progettati
- cambiamenti nello strutture di dati e questo determina che c'è stato un cambiamento nei servizi
- verificare la disponibilità del sistema in modo che ci siano stati di down e accessi negati
- cambiare politiche di controllo dei cambiamenti
- generare report di auditing utilizzati per verificare che tutto stia andando per bene

Viene implementato in diversi modi. Esistono delle funzioni già esistenti all'interno dei DBMS oppure viene possibile definirle tramite un linguaggio conosciuto come PLQL

- memorizzare informazioni riguardanti lo stato dell'oggetto prima che la modifica sull'oggetto stesso abbia avuto luogo;
- descrizione di quella che è stata l'azione eseguita sull'oggetto stesso
- nome dell'utente che ha eseguito la modifica
- IP address dell'utente

4.2.3 L'auditing model 1

1. parte l'azione come ad esempio la modifica di una tupla. L'auditing recuperare username e credenziali d'accesso (ruoli)
 2. verifica che l'utente sia registrato nel repository di auditing;
 3. se l'utente è soggetto ad auditing bisogna verificare se l'azione sia soggetta a sua volta ad auditing
 4. l'oggetto è registrato per l'auditing?
 5. si ottengono i valori precedenti alla modifica e poi si continua con l'azione stessa che viene completata
- facile da capire e realizzare
 - nel repository di auditing vengono memorizzate le entità che sono oggetto di auditing
 - traccia cronologica delle attività eseguite sul database
 - le entità sono generalmente utenti, tabelle e colonne. MYSQL ha come un'unica entità il database stesso
 - le attività da monitorare sono di diverso tipo. Possono essere transazioni DML, logon, logout

4.2.4 L'auditing model 2

- Vengono memorizzati soltanto i cambiamenti di colonna
- ci sono sistemi di purgin in modo che i dati vengono archiviati in forma compressa o comunque cancellati dopo X tempo
- non registra un'azione eseguita sui dati
- ideale per effettuare auditing di una colonna o 2

Effettua lo storage soltanto dei cambiamenti dei valori e non registra l'azione che viene effettuata sui dati e in generale viene considerato più utile quando l'auditing non coinvolge tante colonne o tabelle. Lo schema risulta essere molto più semplice.

- una tabella di audit (quella di destra di slide 66) dove vengono memorizzate le informazioni riguardante la tabella oggetti di auditing. Contiene informazioni di quante volte è stato effettuato l'archiviazione di dati, colonne e varie informazioni di controllo
- dati di auditing che riguardano essenzialmente ogni singola tabella

4.2.5 Historical Auditing Model

Utilizzato quando un'intera riga della tabella deve essere oggetto di auditing. Usato per lo più nelle operazioni finanziarie.

La data table è la definizione dei dati stessi della nostra tabella e poi abbiamo a destra uno storico dei dati memorizzati all'interno di questa tabella x verificare quelli che sono stati i cambiamenti nelle singole tuple della tabella.

4.2.6 Esempi nei più importanti database

Microsoft

Abbiamo la possibilità di creare auditing con CREATE SERVER AUDIT che va a memorizzare le informazioni su un file e il nome del file fornito tramite PATH. Auditing viene effettuato sull'object_name Employees. Definire anche lo stato dell'audit.

MYSQL

In MYSQL viene caricato un modulo aggiuntivo che memorizza informazioni in un file di log. Esistono dei metadati da modificare all'interno di tabelle di servizio per decidere a che livello effettuare l'audit.

Oracle

Utilizza il comando CREATE AUDIT POLICY che monitora alcune azioni in determinate tabelle. In sostanza applica la policy utilizzando AUDIT POLICY AuditDataAccess

4.2.7 Conclusioni

In generale come conclusione possiamo dire che sicuramente utilizzare le tecniche appena viste possono rendere il sistema informativo compliance al GDPR, da considerare tutte assieme.

ABAC, ENCRYPTION, DYNAMIC DATA MASKING, AUDITING.

Possiamo concludere che tutte queste misure sono sufficienti per proteggere la privacy. La garanzia al diritto all'oblio rimane sospesa. Ma ha senso parlare quando ci sono motori di ricerca e siti che memorizzano un sacco d'informazioni.

Chapter 5

Statistical disclosure control

Non riguarda tanto la privacy in se, ma riguarda la protezione della **confidenzialità** del dato. Quindi si applica a scenari in cui c'è bisogno di proteggere la confidenzialità del dato

- segreti industriali
- proteggere informazioni dall'utilizzo abusivo di terzi

Un problema di confidenzialità riguarda la privacy quando i dati riguardano le persone fisiche. Cerchiamo di capire cosa vuol dire e in quale contesto ci stiamo inserendo.

- raccolta di dati e divulgazione, dove la raccolta può essere fatta in tanti modi. Un esempio potrebbero essere i questionari, un'altra possibilità è internet, dispositivi IoT ecc. ecc.

Comunque una volta che questi dati sono raccolti vengono in qualche modo collezionati. La raccolta di questi dati potrebbe fornire anche informazioni riguardanti scopi nobili (apple watch utilizzato almeno una volta in situazioni di pericolo per gli utenti).

Di conseguenza, l'utilizzo di questi dati è importante e lo si fa con tecniche importanti

- ML e Data Mining
- statistical inference
- big data analytics, tecniche di analisi di dati calibrati per dati di grosse moli

Se i dati sono a disposizione della comunità per essere analizzati, devono essere protetti in modo che non ci siano attacchi che permettono il recupero della proprietà della persona.

5.1 Statistical data dissemination

I dati utilizzati per scopi statistici devono essere pubblicati e ci sono svariati motivi per farlo.

- politiche, norme, leggi che spingono affinché questi dati vengono pubblicati in modo che venga reso possibile ad esempio sviluppare aspetti importanti che riguardano la società. Un esempio potrebbe essere quello di migliorare le politiche di una città
- dal punto di vista più scientifico, si è parlato tanto della possibilità di aver accesso a dati inerenti alla pandemia, in modo che tutta la popolazione mondiale ne possa trarre beneficio.
- riproducibilità di esperimenti in modo che tutta la popolazione mondiale ne possa trarre beneficio
- data challenges/contests... gare dove si mettono a disposizione dati in modo che i partecipanti producano algoritmi più performanti

Tutti questi dati sono dati utili e devono essere **pubblicati**, ma che inizialmente sono stati raccolti non con l'intento di essere pubblicati. La **pubblicazione** deve essere fatta seguendo alcuni accorgimenti.

Non possiamo pubblicare ogni singola scheda in riferimento al censimento così com'è, proprio per cui viene scelto di pubblicare un aggregato.

5.2 La disclosure - nozioni generali

C'è un alto rischio di disclosure quando riusciamo a combinare dati raccolti/pubblicati per scopi nobili, con altre banche dati. L'incrocio di dati permette di risalire all'identificazione di utenti.

L'uso di banche dati libere potrebbe essere anche non necessario, in quando viene possibile combinare gli stessi dati raccolti per scopi nobili con dati rilasciati attraverso strumenti social come Twitter, Instagram, Facebook, e questo permetterebbe lo stesso, l'identificazione di utenti.

5.2.1 Macrodata vs Microdata

Cerchiamo di capire meglio il problema della disclosure, ovvero il problema legato alla divulgazione di dati non autorizzati, andando a studiare due tipologie di dati che sono tipicamente pubblicati per scopi **statistici**

- **macrodati**, sono tabelle riassuntive contenenti risultati di indagini statistiche effettuate su vari tipi di problematiche riguardanti la popolazione. Quindi possiamo definirli come una collezione di dati che riguardano database statistici
- **microdati**, utilizzati per raffinare meglio le politiche e per prendere decisioni più a grana fine. Sono essenzialmente record che vengono memorizzati con all'interno ID delle persone e i dati che riguardano in maniera più specifica le singole persone. Essendo dati più specifici allora sono considerati anche più a rischio.

Esempi di tipi di tabelle contenente macrodati

- **tabelle di conteggi e frequenza**. Sono matrici in cui ogni cella contiene per esempio il conteggio di persone che hanno determinate statistiche. Con **frequenze** si intende la percentuale di respondent ¹ che hanno lo stesso valore di attributi rispetto ad un insieme di attributi che vengono analizzati
- **magnitude data**, sono dati dove le singole celle contengono un aggregato di una quantità d'interesse

L'idea è che in queste tabelle tutte le informazioni vengono aggregate in qualche modo, o sulla base del conteggio di persone che hanno determinate caratteristiche (count table) o sulla base della quantità stessa.

Esempio di tabella count table

Indicare il numero di beneficiari rispetto ad una provincia.

- abbiamo dei range di beneficio, dove ogni bonus viene rilasciato in base al reddito

Si nota come in questo tipo di tabelle non viene svelato nulla. Alcune celle sono a rischio, come ad esempio la cella contenente l'1 o il 2. Incrociando i dati in qualche modo potrebbe essere possibile risalire a quel tipo di persona.

¹possono essere diverse tipologie d'attore. Aziende, autorità come il comune, oppure singole persone

Esempio di Magnitude Data

Sono delle tabelle dove non abbiamo delle percentuali di conteggi, ma abbiamo aggregati calcolati sulla base di valori. Abbiamo il numero di giorni passati in ospedali da pazienti che hanno una precisa malattia, raggruppati per sesso e tipologia di malattia per cui sono stati ricoverati.

Il valore indica il numero medio di ricovero per pazienti divisi per sesso

- comunque non sono da considerare dati problematici.

I dati più a rischio sono i Microdati. Considerando un semplice questionario, ogni singola riga della tabella corrisponde ad uno specifico foglio di risposte del questionario. Nell'esempio visto in classe abbiamo visto una tabella contenente i record giudiziari riguardanti minori di una particolare contea

- accedere a questo tipo di tabella risulta essere problematico.²

I microdati in generale sono soggetti a maggior rischio di violazione (privacy breaches) e bisogna tenere in considerazione diverse tipologie di disclosure che possono avvenire

5.3 La disclosure

Quando si parla di disclosure, i requisiti principali che devono essere presi in considerazione sono:

1. **identity disclosure protection.** Il rilascio di dati permette di risalire all'identità della persona
2. **attribute disclosure protection.** Il rilascio di dati fa sì che si riesca ad attribuire ad un'informazione sensibile un determinato data subject
3. **inference channel.** La disclosure non è immediata, ma si ottiene applicando algoritmi di inferenza statistica di ML per risalire all'identità di una persona o ad un attributo sensibile. Quest'ultima determina le altre due, ma per farlo bisogna utilizzare un canale d'inferenza statistica più complesso.

5.3.1 Information disclosure

Quello che affronteremo da qui a seguire sarà la divulgazione di informazioni non autorizzate. Sono state date tante definizioni di disclosure per diversi tipi di disclosure.

In generale viene definita disclosure l'attribuzione impropria di informazioni ad un data reponent che sia un individuo o organizzazione.

5.3.2 Identity Disclosure Protection

Quando una terza parte non autorizzata riesce ad identificare un data subject guardando semplicemente i dati rilasciati, utilizzando eventualmente altre sorgenti d'informazione. Il fatto di risalire all'identità di una persona, non è una violazione dei requisiti di confidenzialità, ma potrebbe essere un problema di privacy.

- **macrodati**, questa possibilità è limitata, essendo degli aggregati, non permettono facilmente di risalire all'identità di una persona, nonostante questo, possono essere problematici quando ci sono degli aggregati che fanno riferimento ad un numero limitato di persone (1 o 2), proprio per cui si riesce a ricollegare l'informazione di una persona.

²Potrebbe essere usata facendo piccoli accorgimenti togliendo informazioni come il nome del bambino e agendo su altre caratteristiche che potrebbe portare all'identificazione della persona

- **microdati**, il rischio è molto più alto in quanto abbiamo dati a livello di singolo respondent e quindi qualsiasi informazione aggiuntiva su questo singolo respondent rischia di determinare l'identità di una persona

5.3.3 Attribute Disclosure

- Si verifica quando vengono rivelate informazioni riservate su un respondent e possono essere attribuite ad esso.

Questa attribuzione può avvenire in due casi diversi:

1. attribuire l'informazione con certezza ad una persona;
2. stimare l'informazione con un'altra confidenzialità

Attribuire riguarda il collegamento di una singola persona con delle informazioni che dovrebbero essere riservate ma che in realtà non lo sono.

Per quanto riguarda i microdati, l'attribute disclosure risulta essere un'operazione abbastanza facile, se i microdati stessi sono rilasciati così come sono.

5.3.4 Inference Disclosure

- In confronto alle precedenti è la più difficile da mettere in atto in quanto obbliga l'utilizzo di algoritmo di inferenza statistica.
- algoritmi che vanno a studiare delle statistiche sui dati in modo da utilizzarle in maniera malevola. Ad esempio alcuni dati potrebbero mostrare un alto tasso di correlazione tra reddito e prezzo di vendita di una casa. Dal prezzo di vendita della casa viene possibile scoprire un certo tipo di reddito

5.3.5 Restricted data and restricted access

Onde evitare problemi legati alla disclosure, esistono due tipologie di azioni che viene possibile fare.

- prima cosa, è rimuovere tutto quello che è **identificativo** di una certa persona (nomi, email, telefono nel caso di microdati)
- altra analisi che viene fatta è sulla tipologia di dati che stiamo considerando. Se sono dati sensibili, occorre attuare certe protezioni, in caso contrario no. Anche rimuovendo l'ID, non è detto che la privacy sia mantenuta, le informazioni restanti potrebbero comunque far sì che si vada ad identificare la persona

Per poter limitare i danni, esistono principalmente due metodi

1. restringere l'accesso alle informazioni. Imporre delle condizioni d'accesso sui dati. In base al livello d'accesso possiamo ottenere un dato più o meno aggregato/preciso
2. limitare le informazioni stesse, ovvero limitare la quantità d'informazione rilasciata, sia nelle tabelle macrodati che microdati
3. ultimo punto è combinare le due strategie.

5.4 Statistical Disclosure Control

È una disciplina sviluppata nell'ambito statistico. Consiste in una collezione di metodi che sono usati come parte del processo di anonimizzazione per controllare il rischio di re-identificare oppure metodi che consentono di limitare il rischio che avvenga una attribute disclosure attraverso la manipolazione dei dati.

Quindi si tratta di metodi che applicati a dati in chiaro, rendono difficile o impossibile il processo di de-anonimizzazione o attribute disclosure. Bisogna ricordare che la SDC non è privacy, sono sostanzialmente dei metodi che si utilizzano per qualsiasi tipo di dati, in modo che venga garantita la confidenzialità dei dati.

Nella fase di protezione di questi dati c'è sempre un **trade-off** tra l'**utilità** e il **rischio**. Ipotizziamo di rappresentare sull'asse X l'utilità e sull'asse Y il rischio di disclosure.

- ipotizzando di avere un numero bassissimo (o quasi nulli) di dati, si nota una situazione in cui si ha una bassa disclosure ma anche una bassa qualità
- una situazione estrema (rilascio di dati in originale), siamo nel caso in cui abbiamo un'utilità massima, in quanto i dati sono originali, ma il rischio di disclosure è elevato
- l'obiettivo della SDC è arrivare ad una situazione intermedia, che permette sia un rilascio di dati che comunque viene vista sempre meglio rispetto ad un rilascio quasi nulli di dati ma che comunque non permetta di avere una disclosure

Quello che si fa tipicamente è considerare una soglia. La scelta di questa soglia non è facile. Viene naturale pensare di rilasciare dati che sono il più vicini a questa soglia, non bisogna superarla ma comunque nemmeno stare troppo sotto.

5.4.1 Procedura tipica della SDC

1. recuperare i dati che vogliamo proteggere. Abbiamo una tabella di micro o macro dati
2. consiste nell'applicare il metodo scelto e in questo caso dobbiamo scegliere un parametro (anche più) che determinano il livello di protezione
3. misurare l'utilità dei dati stessi
4. misurare il rischio di dati che sono stati protetti dal metodo scelto al passo 2

I punti 3. e 4. sono intercambiabili. Si cerca di trovare un compromesso attraverso un'analisi di rischio ex-post. Per ottenere 3. e 4. dobbiamo applicare il metodo e poi misurare sulla tabella ottenuta un valore di utilità e un valore di rischio.

I seguenti metodi che andremo a presentare si prestano a questa tipologia di analisi di rischio. In seguito vedremo come applicare una analisi di rischio che permetta di determinare il rischio di divulgazione x qualche tipo di dati e poi di applicare un modello di privacy particolare di cui sappiamo già quelle che sono le garanzie di utilità e in termini di protezioni. Settando un parametro a seconda del livello di protezione da noi scelto, riuscire ad ottenere un dataset anonimizzato che garantisca sicurezza di utilità e protezione del rischio. I metodi che andremo a presentare dipendono dalle modalità di rilascio di dati. Quindi parleremo di metodi che fanno riferimento a:

- macrodati, tabelle statistiche
- microdati, tabelle con record che corrispondono ad ogni singolo respondent
- **database query output**, possibilità di avere un sistema che permetta di ascoltare in ingresso un certo numero di query e rilascio in output dati in base a quella che è stata la query. Le informazioni rilasciate, vengono appunto rilasciate non all'interno di un file ma attraverso un'interfaccia d'interrogazione.

In base a queste tre modalità di rilascio, abbiamo diverse tecniche che possiamo utilizzare

5.4.2 SDC: Macrodati

Abbiamo due classi di metodi

1. **non perturbativi**, metodi che non vanno a modificare i valori delle celle ma vanno a sopprimere alcuni valori che sono considerati a rischio. Metodi noto con il nome di **Cell Suppression (CS)**
2. **perturbativi**, non vengono cancellate delle informazione, ma vengono applicati metodi di modifiche di celle che hanno lo scopo di limitare inferenza. I metodi sono:
 - Random rounding (RR)
 - Controlled Rounding (CR)
 - Controller tabular adjustment (CTA)

CELL SUPPRESSION (CS)

In riferimento a dati macrodati, si vanno ad eliminare particolare valori attraverso due metodi:

- **primary**, rimozione di valori considerati a rischio. Se abbiamo a che fare con delle tabelle di conteggio, andremo ad eliminare tutti quelle celle contenenti numeri piccoli. Procedendo in questo modo non si garantisce la protezione del dato in quanto viene sempre possibile risalire ad alcune informazioni che permettono di risalire alla precisa identità della persona;
- **complementary (secondary) suppression**, modificare altri valori perchè se ne elimino soltanto uno questo non sarà sufficiente a proteggere la privacy

L'ideale sarebbe limitare al massimo la secondary suppression

Random Rounding

Abbiamo un valore numerico arrotondato o per eccesso o in difetto in maniera casuale. Scelgo in maniera random come effettuare l'arrotondamento.

Controlled Rounding

L'arrotondamento del dato viene fatto in modo controllato in modo che vengano mantenuti i marginali delle righe e delle colonne. Quello che si fa è utilizzare algoritmi di programmazione intera, lineare, ecc... ecc...

Controller tabular adjustment

I valori delle celle sensibili vengono sostituiti da uno dei valori di sicurezza più vicini e vengono apportate piccole modifiche alle altre celle per far si che i marginali vengano rispettati. Il rimpiazzo con valori più vicini permette di non risalire al valore originale. Questa modifica deve essere fatta in maniera controllata. L'importante che quando applicata venga fatta sempre rispettando i marginali.

5.4.3 SDC: Database Query Point

Non viene rilasciato l'intero dataset, ma permettiamo agli utenti di effettuare delle interrogazioni (query) sul dataset con delle limitazioni sulle query.

- **query perturbation** in input o in output.
 - input, il database reale viene perturbato in qualche modo e poi s'interroga il database perturbato e questo implica ad avere anche dei risultati perturbati

– output, la perturbazione viene applicato sull'eventuale risultato della query

- **query restriction**, viene considerata la possibilità di bloccare alcune interrogazioni. Questo richiede di tener traccia di tutte le query precedenti. Un avversario potrebbe usufruire di una sequenza di query pensata ad hoc per scoprire dei segreti che sono nel dataset che in realtà non vorremmo divulgare

5.4.4 SDC: Microdata

Quando si parla di metodi SDC applicati ai microdati si deve far riferimento al

1. **data masking**, mascheramento dei dati. Generare delle versioni modificate del database X attraverso due tipologie di mascheramento **perturbativo, non perturbativo**
2. **data synthesis**, consiste nel produrre un dataset sintetico a partire da X, generando un nuovo dataset che preserva alcune proprietà di X. X' è una versione perturbata di X nel primo caso (pre-selected). Nel secondo caso è stato generato preservando alcune proprietà del database X

Metodi di mascheramento perturbativo dei microdati - Data Masking

- **noise-addition**, ad ogni record viene aggiunto un rumore, questo viene possibile farlo quando i dati sono numerici. In caso contrario è difficile applicarlo. Un'altra idea è quella di prevedere metodi che tengono conto di **medie** e correlazione tra i dati.
- **microaggregazione**, anzichè pubblicare il dataset con tutte le tuple, si vanno ad aggregare le sole tuple simili. La similarità è basta sul concetto di intra-gruppo e in particolare saranno considerati i soli gruppi piccoli. Alla fine, si pubblica la media di ogni cella all'interno del gruppo e in caso di dati categorici si utilizza il dato più frequente. Se dovessero essere tutte uguali allora verrà sostituito da un valore random.
- **data swapping**, consiste nell'ordinare i valori di un attributo in ordine ascendente e poi si scambiano i valori che sono di rango simile. Se abbiamo 10 valor diversi e dove il piu frequente è X, ed il secondo è Y, alla fine possiamo decidere di switchare X e Y in quanto hanno rango vicino in modo da provocare una minima perturbazione
- **post randomization**, lavora su dati categorici quindi nominali, cambiano gli attributi secondo una matrice stocastica data. Abbiamo un attributo composta da 5 valori, creiamo una matrix 5x5 dv in ogni cella c'è la probabilità che un valore segui un altro valore (processo Markoviano) e quello che si ottiene è uno scambio di valori secondo appunto questa matrice stocastica. Avviene tipicamente per valori di tipo categorico

Metodi di mascheramento non perturbativo dei microdati - Data Masking

- **sampling**, pubblico un sotto-insieme dell'intero dataset facendo attenzione di rimuovere ciò che identificativo per l'utente. Problema, pubblicando questo sotto-insieme noi non sappiamo piu qual è il sottoinsieme scelto di pubblicare e quindi dire con certezza se un elemento è presente oppure no
- **Generalization**, attributi che sono di tipi categorico vengono generalizzati in categorie meno specifiche. Se abbiamo il comune di residenza di una persona possiamo sostituirlo con la provincia, regione o stato. Gli attributi numerici vengon generalizzati con intervalli, mettendo un range d'eta anzichè l'età esatta.
- **top/bottom coding**, i valori vengon sostituiti con un valore considerato di limite inferiore o superiore.

- **local suppression**, soltanto alcuni attributi vengono soppressi, questa tecnica la si può vedere simile alla soppressione di celle (CS) per i macrodati. Così facendo comunque si vanno ad aumentare l'insieme di record che in qualche modo hanno le stesse combinazioni di valori su un certo insieme di attributi

Data Synthesis per microdata

Il **goal** è quello di prendere un dataset, estrarne qualche caratteristica statistica, generare un dataset X' causale che vada a preservare le caratteristiche precedenti. L'obiettivo finale è quello di rilasciare un dataset che mantenga comunque la confidenzialità del data subject. Per far ciò esistono due metodi.

1. generiamo un dataset sintetico - **fully synthetic data**
2. generiamo soltanto valori sintetici degli attributi considerati sensibili - **partially synthetic data**.

Problemi da risolvere quando si fanno queste operazioni

- i dati sintetici prodotti devono comunque continuare a permettere di fare analisi statistiche.
- la tipologia di sintesi dipende dal modello scelto
- ci potrebbe essere un problema di **overfitting**. Se i dati sintetici sono simili a quelle originali ci potrebbe essere un problema di identificazione. Il trade-off non è sempre facile da raggiungere

Il dataset risultante comunque è ancora utilizzabile per fare delle indagini statistiche o applicare algoritmi di ML. Quello che si deve fare è trovare un compromesso tra rischio e utilità del dataset. L'obiettivo è trovare un punto di compromesso in modo tale che si preservi l'utilità dei dati ma anche di diminuire il rischio dei dati e quindi viene ovvio calcolare una certa misura di utilità. Il problema di questo calcolo è che se rilasciamo un dataset per cui non so l'utilizzo che ne verrà fatto e ci calcoliamo una certa utilità avendo un certo obiettivo non è detto che il dataset rimanga utile. Dobbiamo poter cercare di calcolare un'utilità in modo da capire se il dataset rimane utile per determinati obiettivi.

5.5 Utility Measurement

La misurazione dell'utilità è difficile perché in molti casi non c'è chiarezza su ciò che gli utenti dei dati vorranno fare con quei dati.

- **information loss**. Vogliamo calcolare la perdita d'informazione. Sono tentativi di catturare in termini di teoria dell'informazione quanto questa informazione è stata variata rispetto al metodo di perturbazione utilizzato per proteggere i dati.
 1. abbiamo un dataset originale
 2. ne abbiamo calcolato uno sintetico che ovviamente non ha la stessa informazione del primo
 3. quello che vogliamo calcolare è quanto abbiamo perso in termini d'informazione tra uno e l'altro

5.5.1 Tipologie di information loss utilizzate dai diversi metodi - Macrodata

- **cell suppression**, calcoliamo il numero totale della somma dei valori delle celle che sono state soggetto di soppressione secondaria.
- **rounding and tabular adjustment**, somma delle distanze tra le celle vere e quelle perturbate. Calcoliamo proprio una differenza tra valore reale e pubblicato e questo da una grandezza da considerare come perdita di informazione.

5.5.2 Tipologie di information loss utilizzate dai diversi metodi - Information Loss for Query

- **query perturbation**, l'information loss viene calcolata come la differenza tra la risposta vera e quella perturbata. Ad esempio potrebbe essere calcolata in termini di media e varianza del rumore aggiunto che dovrebbe essere 0 per la media e varianza piccola per quei valori calcolati
- **query restriction**, numero di query rifiutate

5.5.3 Tipologie di information loss utilizzate dai diversi metodi - Microdati

Dobbiamo poter valutare in che misura la DSC incide sul risultato di determinate analisi. Misure generali di perdita di informazioni.

- Statistiche di base: medie, covarianze, correlazioni, ...
- Punteggi (es. Propensity Scores)
- The distance between the original and disclosure-controlled data using measures (e.g., Jensen-Shannon divergence, Kullback-Leibler divergence...)

Quello che abbiamo fatto fino ad adesso è stato applicare un rischio *ex-post*.

- abbiamo applicato i metodi
- possiamo calcolare quanto dei dati rilasciati permettono di risalire all'identità dei nostri utenti. Se la probabilità è bassa siamo contenti, ma questa probabilità la possiamo calcolare solo dopo aver applicato i vari metodi. Se dovesse servire un modello in cui a priori possiamo calcolare una probabilità di re-identificazione, utilizzeremo un modello di rischio *ex-ante*

Il rischio *ex-ante* è basato sulla nozione di **modello di privacy**, che è una condizione che dipende da un parametro che garantisce un upper bound sul rischio di re-identificazione

In base alla tipologia di disclosure e ad un livello accettabile di rischio (tipicamente definito da un parametro) abbiamo una protezione assicurata, ovvero upper bound del rischio.

- *k*-anonymity
- *l*-diversity
- *t*-closeness
- δ -presence
- ...
- differential privacy

Chapter 6

Anonimizzazione: k-anonymity

Introdurremo l'argomento dell'anonimizzazione andando a presentare degli algoritmi che sono utilizzati per raggiungere l'obiettivo di rilasciare un insieme di dati che si possano considerare completamente anonimizzati e quindi sicuro da qualsiasi tipo d'attacco e che non faccia re-identificare data subject presenti nel dataset.

Il problema della disclosure di dati anonimizzati non è banale. Internet, offre in generale opportunità per la raccolta di dati che possono essere di per se sensibili rispetto alla privacy e che riguardano utenti qualsiasi che hanno rilasciato questi dati x vari scopi. Sono dati raccolti con una frequenza di ogni secondo

- social media
- utilizzatori di smartphone
- dispositivi IoT

L'insieme di queste tecnologie rende disponibile ad un insieme di attori un insieme di dati utili non solo per questi attori ma anche per noi stessi, però noi utenti abbiamo tutte delle grosse preoccupazioni di come questi dati vengono utilizzati e soprattutto sulla privacy delle informazioni personali che ci riguardano.

L'idea di proteggere la privacy è un problema che riguarda diversi aspetti. Potrebbe includere anche poter proteggere le nostre informazioni contro degli attacchi malevoli, portati avanti con tecniche di inferenze o con tecniche note come **linking attacks**.

Oltretutto, pur non avendo la capacità di analizzare personalmente questa grande quantità di dati che se incrociate potrebbe intaccare la nostra privacy, esistono algoritmi basati su ML, data mining possono analizzare tranquillamente grande mole di dati in tempi brevissimi e che quindi utilizzare questi dati per prendere decisioni che vadano incontro a quelle che sono le nostre esigenze anche x correlare dati che possono mettere in repentaglio la nostra privacy. Quindi, algoritmi che in realtà dovrebbero servire solo per creare dei benefici, potrebbe essere usati anche per intaccare la nostra privacy.

In generale, dati di tipo statistico sono spesso e devono essere rilasciati al pubblico (open data, dati rilasciati per migliorare aspetti che facciano riferimento alla società, dati rilasciati per scopi medici... il COVID19 ne è un esempio lampante). Il problema principale è che questi dati, rilasciati per scopi nobili, permettono di essere utilizzati per scopi malevoli e quindi inferire informazioni sensibili e private riguardante l'individuo. La **disclosure**, come visto può avvenire in modo diversi:

Le tecniche di disclosure protection sono:

- **sampling**, al posto di effettuare un censimento si effettua un sondaggio. in modo da non avere informazioni di tutte le persone d'interesse, ma dati che corrispondono ad un campione, essendo un campione ed essendo anonimi non diamo la certezza che sia presente una persona in particolare

- **special rules**, regole particolari per l'accesso ai dati. Imporre restrizione sul livello di dettaglio che può essere fornito da una richiesta di rilascio di un database riguardante dati specifici. Altezza e peso sono rilasciati nel dettaglio, ma se devono essere usati per misurare caratteristiche private, allora posso decidere se di rilasciare queste informazioni ma come aggregato
- regole che sono pensate per proteggere le celle di una tabella che sono di tipo più sensibile. Usare tecniche di
 - soppressione, rimozione della cella stessa
 - arrotondamento di tipo casuale o controllato
 - confidentiality edit.

6.1 Anonimizzazione

6.1.1 Problemi dell'anonimizzazione all'interno dei dati

Abbiamo detto che ci sono diverse agenzie, uffici, che in qualche modo devono rendere dati di tipo sensibile disponibili in varie forme, quindi ad esempio anche comunicarle ad altri enti. Non deve riguardare per forza una pubblicazione online di dataset, ma anche la comunicazione ad altri enti.

- In generali alcuni microdati dati che sono usati per scopi di analisi che molto spesso sono richiesti e imposte da vari tipi di legge

Per proteggere la pp delle persone, i microdati devono essere igienizzati, ovvero togliere di mezzo qualsiasi tipo di identificatore esplicito. Informazione che sole riescono a identificare ogni singolo data subject devono essere rimosse. Operazione non sempre sufficiente e quindi rende comunque il dataset rilasciato in questo modo soggetto al linking attacks. Sfruttando database pubblici, che contengono informazioni riguardanti singoli individui (pagine gialle, pagine bianche) e quindi scoprire identità nascoste all'interno di dataset.

6.1.2 Linking Attacks

Siamo nel 2001 e Latanya (non so chi cazzo sia, diciamo un ricercatore e siamo tutti felici), riuscì ad identificare il fascicolo sanitario riguardante un governatore. Lo stato collezionava e pubblicava dati che erano comunque igienizzati e che riguardava gli impiegati di stato. Per loro (inteso come governo) dati che riguardavano il personale statale e personale che aveva accesso alle cure mediche dovevano essere resi pubblici. Allo stesso modo pubblicano anche le persone registrate al voto. Se rappresentiamo i dati medici con cerchio a sinistra, votanti destra si va a creare un sottoinsieme in comune - ZIP CODE, birth date e person sex

Se analizzati singolarmente, questi tre attributi non davano nessun tipo d'informazione. Si è scoperto che effettuando un semplice JOIN tra le due tabelle si è riuscito a dedurre quelle che erano le caratteristiche del governatore. Di conseguenza, dati medici che facevano riferimento al governatore furono resi noti.

- considerando i dati del censimento del 1990, è stato possibile identificare con i soli tre attributi circa l'87% della popolazione.

Il **linking attack** è un attacco di collegamento che permette di identificare una singola persona grazie al collegamento di tuple diverse di tabelle diverse. Quello che viene necessario è poter andare a rafforzare la privacy nei microdati.

Occorre evidenziare quelli che sono i ruoli degli attributi all'interno di tabelle contenente dati di tipo microdati

- **identificatori espliciti**, identificatori che sono sempre rimossi e quindi mai presenti all'interno di tabelle
- **quasi identifiers**, identificatori utilizzati per la re-identificazione dell'individuo
- **attributi sensibili**, possono anche non esistere e sono attributi che portano informazione di tipo sensibile.

Abbiamo un certo numero di attributi che vengono partizionati in tre insiemi. Il ruolo di qualsiasi tecnica di preservazione della privacy o comunque di anonimizzazione è quella di disassociare gli individui dalla loro informazione sensibile. Rendere impossibile l'attribuzione di un valore di attributo sensibile ad particolare data subject contenuto all'interno della relazione. In generale quello che viene è rimuovere gli id (identificatori espliciti) e lavorare su quasi identifiers e attributi sensibili, in modo che il rilascio di questa sola informazione non vada a rendere possibile la re-identificazione.

Gli attributi quasi identifiers

Sono attributi che di per se non sono identificatori espliciti, ma che in combinazioni con altri quasi identifiers permettono la creazione di un ID univoco. In riferimento all'esempio del governatore, la tripletta

- data di nascita, zip code e sesso

permette la creazione di un ID univoco. Questa definizione è alla base del concetto di *k-anonymity*

6.2 La k-anonymity

È stato il primo framework prodotto per la privacy e la protezione del dato. L'idea è che il dataset lasciato deve comunque contenere un informazione veritiera al massimo mancante, ma l'informazione non deve essere sporcata. Quindi, framework pensato per rilasciare un dataset anonimizzato in modo da essere comunque utilizzato in maniera proficua. Il rilascio del dataset deve comunque proteggere sempre quella che è l'identità dei data subject.

È stata proposta nel 1998. La definizione si basa sulla definizione dei *quasi-identifiers*.

- consideriamo un insieme di attributi $A = \{a_1, \dots, a_n\}$
- dataset D definito sull'insieme degli attributi A

Un **quasi-identifier** di D è un set di attributi $QI \subseteq A$, al limite uguale ad A di cui bisogna controllare il rilascio, quindi andare a controllare i dati che vengono rilasciati.

Considerando tabella di slide 11, abbiamo un certo insieme di tuple, dove attributi come SSN e Name sono stati soppressi, i rimanenti comunque non permettono l'identificazione di un singolo respondent.

- ci sono due esempi di QI
- $QI_1 = \{\text{ZIP, Date of Birth, Ethnicity}\}$
- $QI_2 = \{\text{ZIP, Date of Birth, Gender, Marital Status}\}$

Sono due insiemi di attributi cui vogliamo andare a controllare il rilascio perchè la combinazione di questi possono rendere più probabile la re-identificazione di singoli respondent di una certa tabella.

6.2.1 Definizione di k-anonymity

Consideriamo un dataset T su un set di attributi A e un insieme QI_T di quasi-identifiers associati al dataset T .

Definiamo in maniera formale la k-anonymity

- si dice che il dataset T soddisfa la k-anonymity iff per ogni $QI \in QI_T$ ogni sequenza esistente di valori di attributi QI appare in almeno k occorrenze in T . Esistono quindi k occorrenze nella tabella di T di qualsiasi combinazione di valori di ogni QI appartenente a QI_T

Abbiamo un dataset privato di cui abbiamo tolto tutti gli attributi che permettono di identificare i singoli respondent e l'idea è quella di rilasciare il dataset facendo in modo che ogni combinazione di valori di quasi-identifier trovi un riscontro in almeno k respondent all'interno della tabella anonimizzata.

- nascondere ogni individuo tra altri $k-1$ individui. Non è possibile distinguere un individuo in un insieme minore di k elementi. Ci sono k individui simili tra loro per quanto riguarda quasi-id
- definizione alternativa che si rifà alla definizione di linking attacks. Il linking non può essere eseguito con una confidenza maggiore di $1/k$. Se facessimo JOIN tra la tab k-anonymity e una tabella esterna che serve per andare a re-identificare elementi all'interno della tabella anonimizzata, questo JOIN darà sempre almeno k match tra le due tabelle

L'idea che la k-anonymity richiede che nella tabella rilasciata, i respondent diventano indistinguibile rispetto ad un dato insieme di attributi (quasi-ID).

Condizione sufficiente affinché la k-anonymity sia garantita

Ogni insieme di valori di questi identifier nella tabella che viene rilasciata deve avere almeno k occorrenze. Ci devono esserci almeno k occorrenze, x ogni combinazioni di valori di quasi-identifier.

Considerando la tabella di slide 15 e si nota come questa tabella è 2-anonymity perchè considerando la combinazione di attributi {Ethnicity, Gender, Marital Status}, in questa tabella ci sono due occorrenze per queste combinazioni. Ogni combinazione di valori compare almeno 2 volte. **A noi interessa sempre il numero minimo di tuple**

6.2.2 Come ottenere la k-anonymity

Generalizzazione

Non bisogna sporcare i valori ma **generalizzarli** in modo che rimangono sempre valori veritieri, solo che questa volta non viene rappresentata con una granularità dettagliata, ma viene in qualche modo generalizzata e quindi data una rappresentazione meno dettagliata della realtà. Valore generali rispetto ad una gerarchia e quindi deve esserci una definizione di gerarchia di generalizzazione.

- prendiamo uno ZIP Code di Torino. Se rappresentassimo il codice così com'è andiamo a determinare con precisione una zona di torino, ma è sufficiente eliminare le due cifre in moda da una zona rappresentiamo la città di Torino. 10149 → 101**,
- Rimpiazzare la data di nascita con il solo anno di nascita 09/09/1990 → 1990

Soppressione

Idea di sopprimere informazioni che se rilasciate permettono con facilità di identificare alcuni respondent. proteggendo il dato sensibile rimuovendo delle informazioni. Una delle possibili mosse eseguite è quella di rimuovere tutople, ovvero rimuovere le sole tuple che sono così tanto rare da poter essere considerate degli outliers.

L'idea è quella di usare entrambe le tecniche. Troppa generalizzazione farebbe sì che il dataset sarebbe inutilizzabile. Ad un certo punto qualsiasi tupla all'interno del dataset sarebbe rappresentato con lo stesso valore. Combinando le due tecniche, ogni tecnica va incontro all'altra in modo da minimizzare il livello di generalizzazione necessario per anonimizzare il dataset e a sua volta la generalizzazione consente di minimizzare il numero di informazione soppressa in modo che questo rimanga k-anonimo. In questo modo è possibile soddisfare la k-anonymity ad un livello di generalizzazione che è ancora accettabile per qualsiasi tipo di analisi che si possa effettuare su questo dataset.

Quando si fa ragionamento di combinazione di queste due operazioni, bisogna tenere sempre in testa cosa si voglia fare del dataset. IN generale i dati anonimizzati vengono rilasciati per motivi analitici. Se il dataset fosse troppo anonimo diventerebbe in sostanza di poca utilità.

**NON ANONIMIZZARE PIU' DEL DOVUTO NECESSARIO.
È SUFFICIENTE RISPETTARE IL REQUISITO RICHIESTO.**

6.2.3 Gerarchia di generalizzazione del dominio (DGH)

Un DGH_D di un attributo A è un ordine parziale sugli insieme di domini Dom_A che soddisfa le seguenti condizioni

1. ogni dominio di D_i ha al più un dominio generalizzato diretto
2. tutti gli elementi massimali della gerarchia di dominio sono in sostanza dei singleton. In modo da essere sicuri che tutti i valori di un dominio possono essere generalizzati ad un singolo valore
 - Z_0 , dominio in chiaro
53715, 53710, 53706, 53703}
 - Z_1 , singola generalizzazione dove abbiamo soppresso tutte le cifre meno significative del CAP {5371*, 5370*}
 - Z_2 , dominio del CAP generalizzati eliminando le ultime due cifre {537**}

L'elemento massimale Z_2 è un singleton, contiene un solo valore. Per ogni elementi di una gerarchia più basso è possibile risalire ad un singolo valore della gerarchia che lo sovrasta. L'insieme delle Z è la DGH.

6.2.4 Gerarchia di generalizzazione del valore

- abbiamo delle **relazioni di generalizzazione del valore** che associano a ciascun valore v_i del dominio D_i un unico valore v_j del dominio D_j , dove D_j è direttamente generalizzato da D_i
 - $Z_0 \rightarrow D_i \rightarrow Z_1 \rightarrow D_j$, l'associazione di un elemento della gerarchia del livello inferiore D_i con un elemento preciso della gerarchia Z_1 . a 53710 associamo 5371*
- questa relazione implica l'esistenza per ogni dominio D una gerarchia di generalizzazione dei valori denominata come VGH_D

- VGH_D è un albero dove le foglie sono i valori di D , ovvero del dominio dell'attributo non generalizzato e la radice, cioè il valore più generico (singleton top most) è il valore del massimo elemento della DGH , elemento dell'insieme Z_2

Viene generalizzato un albero di generalizzazione. Salendo sempre più in alto abbiamo una generalizzazione di livelli intermedi fino ad arrivare ad una generalizzazione massima.

6.2.5 Reticolo generalizzato

- consideriamo una tupla del dominio DT , dove questa tupla è definita su un certo set di attributi, dove D_{A_i} sono i livelli di ogni gerarchia di dominio
- il reticolo generalizzato è dato dalla relazione DGH_{DT} composto dal prodotto cartesiano $DGH_{D_1A_1} \times \dots \times DGH_{D_nA_n}$
- viene definito un reticolo non più un albero, il cui elemento minimale è DT ovvero la tupla della nostra tabella. Elemento rappresentato dal livello più basso del reticolo
- l'elemento massimo è rappresentato dal livello più alto del reticolo
- le relazioni che intercorrono all'interno del reticolo sono i diretti successori nelle gerarchie in cui è stato generalizzato un solo elemento di ognuno di questi domini.

In sostanza questo ci offre anche un percorso di generalizzazione, quindi strategia, metodo che permette di decidere la strategia di generalizzazione. La disponibilità di questo non ci aiuta ancora a raggiungere l'obiettivo, ovvero quello di ottenere una generalizzazione che abbia un senso per un certo dataset.

6.2.6 Tavola generalizzato con soppressione

Introduciamo quindi il concetto di tavola generalizzata con Soppressione che permetterà di definire il primo algoritmo introdotto in letteratura l'**algoritmo di Savoirdi**

- abbiamo un set di attributi definiti su A e due tabelle T_i e T_j definite su A . La tavola T_j è una **generalizzazione (con tuple sopresse)** della tabella T_i e viene T_i minore uguale T_j , quindi T_i è generalizzata da T_j , quindi T_j è una generalizzazione di T_i iff
 1. il dominio di ogni attributo A_x in T_j è uguale (livello uguale nella gerarchia) oppure generalizzazione del dominio di A_x di T_i
 2. ciascuna tupla t_j in T_j ha una corrispondente tupla in T_i e questa tupla è tale per cui per ogni attributo A_x , il valore di A_x preso sulla tupla t_j è uguale oppure generalizzazione dell'attributo A_x preso sulla tupla t_i

L'inverso non vale, per ogni tupla t_i possiamo anche non avere una corrispondenza in t_j . Vedere slide 23.

6.2.7 Distance Vector

Aggiungiamo un informazione in più che permetta di sfruttare il reticolo in modo tale da ottenere una buona anonimizzazione.

- prendiamo due tabelle che sono definite sullo stesso numero di attributi A . Dove T_j è una generalizzazione di T_i .
- il vettore di distanza di T_j rispetto a T_i è il vettore $DV = [d_1, \dots, d_n]$ dove ogni valore si riferisce al suo attributo di riferimento
- ogni d_x è la lunghezza del percorso univoco tra i due domini

- il path finale deve essere identificato in DGH_{D_x}

In finale spostamento pari ad 1 sull'attributo S e uno spostamento massimo pari a 2 sull'attributo Z

6.2.8 Criterio di generalizzazione - intuizione

Prendiamo due gerarchie di generalizzazione di dominio Z e S

- costruiamo il reticolo di generalizzazione dell'intero set QI, quindi reticolo composto da *gender* e *zipcode*
- piu saliamo nel reticolo e maggiore sarà la generalizzazione e quindi sicuri che il nostro dataset sia k-anonimo rispetto a questo seti QI
- l'obiettivo da raggiungere è ottenere la generalizzazione minima che soddisfi la k-anonimizzazione

Se vogliamo garantirla e riusciamo a preservare l'utilità del dataset abbiamo ottenuto una buona anonimizzazione che rende sì il dataset anonimo ma ancora utile. L'idea è la seguente:

- andare a trovare una k-anonimizzazione che minimizzi il vettore di distanza rispetto al dataset originale

Guardando l'esempio, immaginando che a livello base la tabella sia 1-anonima, se la richiesta è quella di ottenere un dataset 2-anonimo e noi questa richiesta possiamo soddisfarla raggiungendo per esempio un livello dove il vettore risultante in un caso è [1, 0] e nell'altro [2, 0], allora opteremo per il primo caso in quanto il vettore di distanza risulta essere minimo.

- questa risulta essere l'intuizione che c'è dietro l'algoritmo k-anonymity minimizzando la generalizzazione con soppressione

6.2.9 Generalizzazione k-minimal con soppressione

Per questo scopo consideriamo due tabelle T_i e T_j , dove T_j è una generalizzazione di T_i . Consideriamo un parametro $MaxSup$, soglia di soppressione accettata, quindi un valore che sta ad indicare il numero massimo di tuple che devono essere sopprese, parametro definito dall'utente. Diciamo che T_j è una generalizzazione di T_i k-minimale iff

1. T_j deve soddisfare la k-anonymity
2. il livello di soppressione deve essere minimale
 - per ogni T_x che generalizza T_i
 - i vettori di distanza di T_x e T_j sono gli stessi rispetto ad T_i
 - T_x è k-anonima

come conseguenza deve succedere che la tabella T_j deve contenere più tuple della tabella T_x . Questo sta a significare che la soppressione di T_j deve essere minore rispetto a quella di T_x

3. il numero di tuple di $T_j - T_i$ deve essere minore uguale della soglia decisa dall'utente ($MaxSup$). *Questo $MaxSup$ potrebbe essere anche non considerato*
4. per ogni T_x che sia una generalizzazione di T_i e che soddisfi il punto 1. 2. e 3. allora il vettore di distanze $DV_{i,x}$ è maggiore uguale del vettore di distanza $DV_{i,j}$

Date due generalizzazioni della stessa tabella T_i , se entrambe soddisfano la k-anonymity noi andiamo a tenere quella che in qualche modo minimizza il vettore delle distanze e minimizzare anche il numero di tuple sopresse.

Nell'esempio in slide 27 a seguire quello che si può dire che entrambe sono 2-anonime, questo perchè per ogni combinazione di valori E e Z si ha un numero minimo di tuple pari a 2. I vettori di distanza sono $[1, 0]$ e $[0, 1]$ e il numero delle tuple è lo stesso.

Queste sono due generalizzazioni k-minimali della tabella E_0 e $Z=$ (vedere slide 27)

6.2.10 Classificazione delle tecniche k-anonymity

Identificate rispetto a come viene applicata sia la generalizzazione che la soppressione. Entrambe possono essere applicati a diversi livelli di granularità

- **generalizzazione**

- a livello della singola colonna, uno step di generalizzazione generalizza tutti i valori della colonna
- a livello di singola cella, per ogni specifica colonna la tabella potrebbe contenere diversi valori di generalizzazioni in diversi gruppi di tuple

- **soppressione**

- a livello di riga, si rimuove l'intera tupla
- a livello di colonna, si oscurano tutti i valori di una colonna. Questo corrisponde ad una generalizzazione di livello massimo, poichè il valore massimo non dice niente sui valori delle singole tuple
- a livello di singola cella, soltanto alcune celle che contengono alcuni valori possono essere cancellate.

A seconda di come viene eseguita la generalizzazione e la soppressione possiamo avere diversi livelli e tipi di algoritmi di k-anonimizzazione.

6.2.11 Risolvere i problemi dovuto ad algoritmi k-anonymity

Per risolvere il problema della k-anonymity

- si potrebbe esplorare tutte le soluzioni cercando quella che soddisfi la k-minimal generalization, rispetto sia alla suppression che generalization. Naturalmente per far questo deve essere possibile analizzare tutte le possibili combinazioni. Il problema di trovare una tabella k-anonima che sia anche minimale dal punto di vista della generalizzazione e soppressione è un problema ****NP-hard****. Bisognerebbe esplorare tutte le possibili combinazioni di attributi, per ogni combinazione di attributi andare ad esplorare diverse combinazioni di gerarchi di dominio da combinare.
- la maggior parte degli algoritmi esatti proposti in letteratura hanno una complessità esponenziale rispetto al numero di attributi. Il numero di tuple non è un problema
- quando il numero di QI è abbastanza basso rispetto al numero di tuple, gli algoritmi che vanno a trovare una soluzione esatta rispetto alla generalizzazione di attributi e soppressione di tuple sono algoritmi che possono trovare un riscontro pratico e quindi utilizzati. Non sempre possibile, in questi casi quello che si fa è utilizzare delle euristiche

6.3 Algoritmi per k-anonymity

Principali algoritmi per la soluzione al problema della k-anonymity

6.3.1 Algoritmo di Samarati

I presupposti da qui parte Samarati è che ogni percorso nel reticolo a partire dal livello bottom fino ad arrivare al livello top-most, rappresenta una strategia di generalizzazione. Muovendosi in questo percorso stiamo scegliendo una strategia di generalizzazione, quindi scegliamo quelli che sono gli attributi da generalizzare e a che livello generalizzarli.

- algoritmo basato su un approccio noto come locally minimal generalization (generalizzazione localmente minima). Consiste nel nodo più basso dal punto di vista della generalizzazione che soddisfa la k-anonymity, all'interno di ogni path
- altre proprietà garantite dall'algoritmo sono:
 - a. che ogni generalizzazione k-minima è localmente minima rispetto ad una path (percorso) - il contrario non è vero;
 - b. salendo nella gerarchia il numero di tuple che devono essere rimosse per garantire la k-anonymity decresce. È normale perché quando stiamo nella gerarchia generalizziamo di più e di conseguenza è meno probabile che abbiamo bisogno di eliminare delle tuple (outliers) che rischiano di compromettere la k-anonimizzazione del dataset
- da un lato vogliamo rimanere bassi nella gerarchia per non generalizzare troppo. Dall'altro vogliamo salire ad un livello tale per cui non siamo costretti ad eliminare troppe tuple
- se non c'è nessuna soluzione che garantisce la k-anonymity eliminando meno di MaxSup oggetti della base dati ad un'altezza h della nostra gerarchia, non può esistere una soluzione ad altezza minore che garantisca un risultato k-anonimo con una soppressione di meno di MaxSup tuple.

Funzionamento dell'algoritmo

- fa una ricerca binaria nel reticolo dei vettori delle distanze. Abbiamo un reticolo della DGH che viene associato a QI della nostra tabella e accanto a questo abbiamo un reticolo che associa ad ogni livello un vettore di distanze rispetto al livello base.
 1. consideriamo l'altezza h del reticolo e valutiamo le soluzioni che sono disponibili nella parte inferiore di $h/2$. Con un reticolo di altezza 10, considereremo i soli nodi fino all'altezza 5, in modo da vedere se questi soddisfano la k-anonymity
 - a. si guardano i livelli di generalizzazione offerti dai nodi all'altezza $h/2$
 - b. se esiste una soluzione che soddisfa la k-anonymity, quello che succede è andare a trovare una soluzione ad altezza $h/4$. In sostanza si cerca nella metà bassa del reticolo.
 - c. se $h/2$ non c'è nessuna soluzione allora si cerca di trovare una soluzione ad un'altezza $3h/4$. Parte alta del reticolo.
 - d. Iterativamente si va a considerare la metà del reticolo tenuta in considerazione andando a cercare nella parte bassa o alta del reticolo a seconda che ci sia una soluzione che soddisfi la k-anonymity.
- ci fermiamo quando viene raggiunta l'altezza più bassa per il quale esiste un vettore di distanze che soddisfi la k-anonymity.

- l'algoritmo sfrutta una matrice di distanze tra vettori che permette di calcolare ogni volta esplicitamente i distance vector per ogni tabella generalizzata

Esempio di esecuzione (slide 32)

- partiamo da $h=1$, avendo come vincoli $k=2$ e $\text{MaxSup}=2$
- consideriamo una soluzione ad altezza 1 ($3/2 = 1.5$, interno inferiore è 1) dove abbiamo $[1, 0]$ e $[0, 1]$. Si nota considerando $[1, 0]$ la necessità di eliminare due tuple affinché la tabella risulti essere k -anonymity. Il vincolo di MaxSup è ancora rispettato. Procediamo allo stesso modo per $[0, 1]$ e notiamo che per poter garantire la k -anonymity procediamo con la soppressione di 2 tuple. Entrambe le soluzioni mantengono i vincoli richiesti
- a questo punto andiamo ad analizzare il livello $h/4$. ($1/4$, prendendo la parte bassa consideriamo 0) e per renderla k -anonymity siamo costretti ad eliminare un numero massimo di due tuple. Vincolo non richiesto. Ci fermiamo al passo precedente.

L'algoritmo produce una soluzione di livello 1, la prima o la seconda. In questo caso, ci potrebbe essere altre misure per decidere quali delle due soluzioni deve essere utilizzata in output. In generale senza nessun altro vincolo una delle due va benissimo

6.3.2 Algoritmo Incognito

L'idea è la k -anonimizzazione rispetto ad un insieme proprio di QI è una condizione necessaria ma non sufficiente per la k -anonymity rispetto ai QI.

- vuol dire che se prendiamo un sottoinsieme di QI, se la k -anonymity è rispettata per un sottoinsieme dei QI questa condizione è necessaria affinché sia rispettata da QI. Se non è soddisfatta da un suo sottoinsieme stretto, allora non sarà soddisfatta nemmeno dall'insieme totale di QI
- Immaginiamo di avere un set di QI composto da 4 attributi, se su un sottoinsieme di 2 attributi non riusciamo a soddisfare la condizione di k -anonymity questa condizione non sarà soddisfatta nemmeno su un set più grande (di 3 o 4 attributi)

Funzionamento in maniera iterativa nel seguente modo

- **iteration-1:** effettua un check della k -anonymity per ogni attributi di QI andando a trascurare tutte quelle generalizzazioni che non soddisfano la k -anonymity
- **iteration-2:** combina le restanti generalizzazioni, ovvero quelle che soddisfano la k -anonymity, in coppia e va a testare di nuovo la k -anonymity per ogni nuova coppia ottenuta in questo modo
- **iteration-i:** si devono combinare tutte le i -uple (combinazioni di attributi presi a i elementi alla volta) ottenute combinando le generalizzazioni che soddisfano la k -anonymity ottenute fino all'iterazione $i-1$.
 - all'iterazione 4 dobbiamo testare le generalizzazioni composte da 4 attributi. Si testando andando a mettere insieme le combinazioni di 3 attributi che soddisfano la k -anonymity. Siamo a livello $i-1$ abbiamo trovato che ABC soddisfa la k -anonymity, ACD no e ABE sì, chiaramente possiamo combinare soltanto ABC con ABE e avremo un insieme di 4 elementi composti da ABCE
- all'iterazione QI, iterazione corrispondente al numero di attributi all'interno del quasi identifier QI, siamo sicuri di poter restituire il risultato finale.

A differenza di Samarati che effettua una ricerca binaria all'interno del reticolo, questo lavora in maniera bottom-up. Partendo da elementi meno generalizzanti a quelli più.

- adotta un approccio a priori, approccio basato sulla generazione dei candidati in algoritmi che servono per effettuare itemset mining.

L'algoritmo sfrutta le proprietà di monocità che riguardano la frequenza di tuple all'interno del reticolo. Questa proprietà è in qualche modo una proprietà che ricorda quella della gerarchia OLAP e quelli di frequent itemset mining.

- consideriamo insieme di attributi QI con dimensione 2. Studiamo la gerarchia di dominio di questi due attributi. Abbiamo quindi una generalizzazione sugli attributi S e Z.
 - dobbiamo capire se in questa gerarchia abbiamo delle combinazioni di attributi che possiamo generalizzare oppure no
1. **generalization property**, verifichiamo le proprietà di k-anonymity su questi nodi. Se per qualche nodo di questa gerarchia vale la k-anonymity allora questa k-anonymity vale anche per i nodi a livello superiore. Se $[S1, Z0]$ è k-anonimo, saranno anche k-anonimi $[S1, Z1]$ e $[S1, Z2]$
 - a. per quei nodi k-anonimi quello che non possiamo dire è che effettivamente i suoi predecessori sono k-anonimi. Se un nodo non è k-anonimo allora non potremmo dire niente dei nodi superiori.
 2. **subset property**, se per un set di attributi di QI la k-anonymity non può essere garantita allora la k-anonymity non potrà essere garantita nemmeno per i suoi sovrainsieme
 - a. dato che $S0, Z0$ non è k-anonimo, allora anche aggiungendo un attributo come B0 (oppure una sua generalizzazione) a questo insieme, allora la nuova combinazione non può dar luogo ad una tabella k-anonima. L'aggiunta di attributi rende la tabella meno generalizzata rispetto alla precedente.

Queste due proprietà vengono sfruttate dall'algoritmo Incognito per percorrere tutte le varie combinazioni di attributi che fanno parte di QI per cercare di identificare all'interno delle varie gerarchie di dominio un livello di generalizzazione che garantisca la k-anonymity senza esagerare nella generalizzazione stessa, quindi rimanendo sempre ad un livello basso di generalizzazione.

Incognito sostanzialmente considera un set di QI attributi di cardinalità sempre maggiore, andando a potare i nodi del reticolo usando proprietà 1. e 2. Sfruttando queste due proprietà l'algoritmo non ha bisogno di esplorare tutte le possibili combinazioni di generalizzazione su attributi, ma soltanto quelle che effettivamente sono promettenti dal punto di vista della k-anonimizzazione.

- effettuando un rollup di sex viene possibile rappresentare i vari punti dimenticandoci di quale sia il valore reale di sex e utilizziamo il valore generalizzato. Risulta essere unico
- sfruttando la generalizzazione su sex, si scopre come abbiamo delle tuple singole che non garantiscono la 2-anonymity.
- a questo punto facciamo un rollup su zipcode. Nel quadrante in basso a sinistra non ci sono tuple.

6.3.3 Algoritmo Mondrian

- ogni attributo nel QI rappresenta una dimensione
- ogni tupla nella tabella privata è rappresentata da un punto nello spazio definito da QI
- le tuple con stessi valori di QI sono rappresentati associando il numero di occorrenza con il punto.
- lo spazio multidimensionale viene partizionato andando a splittare le dimensioni in modo che le aree così ottenute contenga almeno k-occorrenze di punti
- tutti i punti che appartengono alla stessa regione vengono generalizzati ad un unico valore
- le tuple corrispondenti al gruppo che viene generalizzato sono sostituite con i valori corrispondenti al raggruppamento

Funzionamento dell'algoritmo

In che modo si raggruppa? Se non viene stabilito un criterio ben preciso si rischia di ottenere risultati non interessanti dal punto di vista non tanto dalla generalizzazione che comunque sarà garantita, ma dal punto di vista dell'utilità del dataset.

- Samarati e Incognito lavorano con l'intento di minimizzare la generalizzazione. Mondrian effettua un partizionamento dei raggruppamenti ottenuti da quante tuple sono contenute all'interno di ogni raggruppamento. Per cui non viene possibile applicare un criterio che minimizzi il livello di generalizzazione, perché in questo caso non possiamo controllarlo.

Per fare in modo che il dataset mantenga una certa utilità, viene utilizzata la **discernability metric (DM)**.

- penalizza ogni tupla con la grandezza del gruppo con cui appartiene, dove per grandezza si intende quanti valori distinti vengono rappresentati all'interno di questo gruppo
- idea intuitiva è che il **raggruppamento ideale** sia quello dove tutti i gruppi hanno la stessa dimensione k

In sostanza Mondrian costruisce dei gruppi che hanno all'incirca la stessa taglia k di elementi all'interno di ogni gruppo. Naturalmente in questo modo si garantisce la k-anonymity.

1. consideriamo un dataset espresso da un insieme di punti su due dimensioni.
2. dopodiché partizioniamo iterativamente le due dimensioni. Ipotizzando di dover partire con la dimensione X. I due gruppi ottenuti conterranno circa lo stesso numero di elementi
3. a questo punto si prende ogni gruppo così ottenuto (rettangolo) e si va a partizionare ogni gruppo, stavolta considerando la sola dimensione Y, in modo da ottenere gruppi contenenti all'incirca lo stesso numero di elementi.
4. di volta in volta si alternano le dimensioni su cui si intende partizionare
5. quando non viene più possibile rispettare quella che è la k-anonymity si procede a partizionare i gruppi restanti. Nel nostro esempio l'unico gruppo da partizionare è quello contenente 4 elementi.

Nell'esempio di applicazione si va ad indicare per ogni cella corrispondente ad un elemento delle righe e colonne il numero di tuple che sono contenute in quella cella.

- single 94138 abbiamo un numero di tuple pari ad 1

La qualità dei gruppi

Andando a guardare la qualità dei gruppi, la DM dipende unicamente dalla cardinalità di ogni gruppo

- non c'è nessuna misura che ci dica quanto un gruppo sia fine.

Un buon raggruppamento potrebbe essere quello che contiene tuple i cui valori di QI sono molto simili. Non essendo sempre così, viene definita un'altra metrica, la normalized certainty penalty (NCP). In sostanza non fa altro che sfruttare il perimetro del gruppo per usarlo come penalty al posto della cardinalità del gruppo stesso.

- se devo raggruppare nel modo rappresentato dal primo disegno, o secondo disegno, chiaramente pur facendo rispettare a tutti questi gruppi a k-anonymity, si nota come nel primo caso i punti sono generalizzati in maniera un po' troppo grossolana, in quanto sull'asse X le tuple rosse prendono valori molto diversi tra loro. Quindi si nota come i valori possibili su queste tuple spaziano per circa l'80% della lunghezza dell'asse X. Cosa che non succede con il secondo disegno (box di forma quadrata che minimizzano in qualche modo a parità di area minimizzano il perimetro)

6.3.4 Algoritmo Topdown

- parte con l'intero dataset e lo split in due parti
- continua a splittarlo fintanto che non rimangono gruppi che contengono meno di $2k-1$ tuple

Funzionamento dell'algoritmo

- cerca i due punti che sono i più distanti possibile. Questi due semi genereranno i due gruppi di split
- si assegna ogni punto rimanente al gruppo che permette di minimizzare l'aumento della misura del perimetro
- si ingrandiscono i rettangoli includendo i punti rimanenti cercando di minimizzare sempre il perimetro.

I gruppi ottenuti contengono $2k-1$ tuple e quindi ci si può accontentare di questi.

6.3.5 Differenza ottenute con i vari algoritmi

1. Samarati e Incognito fanno un single dimensional global recoding. Data una dimensione lo split è lo stesso su tutte le altre dimensioni
2. Mondrian permette più libertà. Dato un gruppo viene permesso di splittare differenzialmente le varie dimensioni sui vari gruppi
3. Topdown, permette di effettuare dei raggruppamenti locali. Minimizzando la misura del perimetro, il procedimento permette di ottenere dei gruppi anche sovrapposti, il che garantisce una potenza di generalizzazione ancora maggiore

I dataset ottenuti con gli algoritmi Mondrian e Topdown saranno molto più utilizzabili dal punto di vista della qualità del dato rispetto all'algoritmo Samarati e Incognito, che invece rischiano di generalizzare troppo, essendo vincolati ad avere soltanto un raggruppamento per ogni dimensione, cosa che gli altri algoritmi non fanno, ovvero permettono di avere raggruppamenti diversi per ogni dimensione.

Chapter 7

Limiti della k-anonymity

Vedremo come la k-anonymity vista nel capitolo precedente presenta alcune limitazioni. Comunque come modello di riferimento può essere sempre considerato come modello affidabile, facendo però delle considerazioni, mettendo in ballo gli **attributi sensibili**, lasciati completamente da parte quando abbiamo parlato della k-anonymity.

Cerchiamo in che modo la k-anonymity presenta delle problematiche che rischia di vanificare tutti gli sforzi dell'anonimizzazione posti dagli algoritmi e vediamo come superare questi limiti.

7.1 Ipotetici attacchi

7.1.1 Homogeneity Attack

- Consideriamo un piccolo dataset dove abbiamo attributi identificativi, QI e attributi sensibili.

Immaginiamo di voler anonimizzare questi dati (dove la colonna inerente all'ID dovrebbe sparire). Guardando la tabella in slide si nota come questa addirittura sia 4-anonima (c'è il 25% di probabilità di beccare un individuo effettuando ad esempio un linking attack). Guardiamo un primo problema che potrebbe presentarsi

- se considerassimo il gruppo di persone che abitano nella zona rappresentata dallo ZIP Code 130** quello che si nota che tutti gli individui hanno lo stesso QI e hanno la stessa identica patologia (stiamo considerando individui dello stesso gruppo).
- pur avendo anonimizzato il dataset con un buon livello di anonimizzazione è possibile facilmente inferire che questo individuo soffra della patologia cancro

Può succedere che tutte le tuple con la stessa combinazione di QI possano avere lo stesso attributo sensibile (cancer).

- se sappiamo ad esempio che Carol è una persona di 40 anni, vive nel quartiere identificato dallo ZIP Code, è una donna americana e sappiamo che è presente all'interno di questa tabella, allora possiamo facilmente inferire che Carol soffra di questa patologia

Si nota come pur avendo anonimizzato il dataset, io attaccante riesco comunque ad inferire informazioni sensibile da una tabella k-anonima. Non vuol dire che in generale la k-anonymity è inutile, bisogna cercare di evitare soltanto situazioni del genere, ovvero che si formano gruppi di questo tipo. L'attacco appena mostrato è conosciuto come homogeneity attack, nel senso che per compiere questo attacco è necessario che gli attributi sensibili siano omogenei.

7.1.2 Background knowledge attack

Potremmo possedere altra informazione addizionale. Informazione ottenuta ad esempio attraverso fonti esterne che magari non sono le stesse fonti alla base del dataset pubblicato in modo k-anonimo.

- immaginiamo di sapere che Hellen sia una donna di 29 americana che vive nel quartiere 13068
- quello che riusciamo ad inferire dalla tabella è che Hellen può soffrire di una qualche malattia cardiaca o infezione virale.
- in teoria così facendo dovrebbe essere impossibile andare a distinguere quale sia la malattia di Hellen
- se sappiamo che Hellen è anche una donna che fa molto sport, potremmo immaginare che questa persona faccia tanti controlli dal punto di vista sanitario e quindi essendo una donna che sport a livello agonistico è impossibile che soffra di problemi cardiaci, di conseguenza riusciamo ad inferire che Hellen ha un'infezione virale

Siamo riusciti ad individuare il gruppo di Hellen, sapendo che Hellen è una donna che fa sport e ad escludere certi attributi sensibili e quindi inferire con certezza l'attributo sensibile.

7.1.3 Positive and negative disclosure

Immaginate che una persona abbia una sua conoscenza acquisita e che riesca ad accedere ad una tabella generalizzata GT e che riesca a fare inferenza in questa tabella. Questa inferenza a seconda dei cosa può rivelare informazione in maniera **positiva** o **negativa**.

1. **positive disclosure**: pubblicando i dati della GT derivati dalla tabella privata PT si riesce ad identificare il valore di un attributo sensibile con alta probabilità.
2. **negative disclosure**: pubblicando i dati della GT derivati dalla tabella privata PT si riesce ad eliminare dei possibili valori di attributo sensibile con alta probabilità

In un caso riusciamo ad identificare il valore giusto di una certa tupla (quindi riusciamo in qualche modo a re-identificare), nell'altro si riesce ad escludere dei valori. L'esclusione di valori comporta avvicinarsi sempre più al valore reale, quindi la negative disclosure iterata permette di raggiungere una negative disclosure.

- anche senza avere conoscenza pregressa un'attaccante può dedurre che Hellen non ha cancro. Visto che ricade in quel gruppo dove le uniche malattie rappresentate sono 2, questo significa che sicuramente possiamo escludere altre malattie

7.1.4 Basi teoriche: definizioni

Consideriamo due tabelle, PT: tabella privata e GT: tabella generalizzata

- immaginiamo che q sia il valore di un attributo non sensibile Q in PT
- q^* valore generalizzato di q in GT
- s valore di un attributo sensibile S
- indichiamo con $n(q^*, s)$ il numero di tuple $t^* \in GT$ dove $t^*[Q] = q^*$ $t^*[S] = s$
- chiamiamo **q^* -block** (anche conosciuta come **classe di equivalenza**), l'insieme di tuple in GT i cui valori non sensibili dell'attributo Q generalizzano q^*

Tutte le tuple nella tabella GT che hanno gli stessi valori q^* in corrispondenza di attributi Q sono detti **q^* -block**. Formalizzazione dei gruppi k-anonimi che abbiamo visto in tutti gli argomenti precedenti.

7.2 Lack of diversity

Conosciuta come assenza o mancanza di diversità. Questa avviene quando si verifica

- per ogni valore dell'attributo S diverso da s il numero di tuple di q^* -block che hanno quel valore dell'attributo sensibile s' è molto minore rispetto al numero di tuple che hanno l'attributo sensibile s

$$\forall s' \neq s \quad n(q^*, s') \ll n(q^*, s)$$

Vuol dire che esistono dei valori dell'attributo sensibile che sono molto più rappresentati rispetto ad altri valori dello stesso attributo sensibile. In questo caso succede che:

- la probabilità della tupla presa in esame rispetto all'attributo S abbia il valore s , indipendenza dal fatto che t^* preso su Q sia uguale a q^* è quasi uguale ad 1.

Conoscendo quale sia il q^* si riesce a dedurre con alta probabilità il valore dell'attributo S sulla stessa tupla, con una probabilità vicino 1. Un rilascio di un dataset di questo tipo potrebbe essere molto rischioso. Succede che il valore sensibile s della persona identificata dal valore q per l'attributo Q può essere determinato con alta accuratezza dall'attaccante a patto che lo stesso attaccante sappia che la persona sia presente all'interno della tabella PT .

- tutti gli attacchi prevedono che l'attaccante sappia con certezza che la persona sia presente all'interno del dataset. Se si riesce ad individuare un q^* -block e questo presenta una mancanza di diversità allora si riesce facilmente a fare delle induzioni su questa persona.

7.2.1 I-diversity (principio)

Risolvere il problema precedentemente riscontrato introducendo il principio della **I-diversity**.

- per assicurare la diversità all'interno di un q^* -block, questo deve avere almeno I valori sensibili (dove I è un numero intero ≥ 2), tale per cui i I valori più frequenti all'interno dello stesso q^* -block abbiano all'incirca la stessa frequenza
- ogni q^* -block deve essere formato da almeno I valori e i I valori più frequenti devono avere all'incirca la stessa frequenza

Se avviene questo, possiamo dire con certezza che un q^* -block è **bene rappresentato** da I valori sensibili. Significa che se ho I valori distinti fra loro e questi I sono più o meno tutti alla stessa frequenza difficilmente potremmo capire quali di questi I valori si può attribuire alla persona che s'identifica all'interno di quello q^* -block.

- se ci sono I valori ben rappresentati all'interno di q^* -block, l'attaccante deve avere almeno $I-1$ pezzi di **background knowledge** (informazioni che possono potenzialmente permettergli di scoprire quale sia il vero valore reale) relativo ad una certa tupla, per eliminare $I-1$ valori sensibili ed inferire poi l'unico valore sensibile effettivamente attribuibile alla persona di cui l'attaccante vuole inferire il valore dell'attributo sensibile.
- se settiamo bene il parametro I , il data publisher può determinare quanta protezione viene garantita sul dataset rilasciato, in modo da prevenire attacchi che si avvalgono di background knowledge.
- Questo può essere fatto naturalmente anche se la background knowledge di conoscenza dell'attaccante non sia nota al data publisher.

Se abbiamo un k abbastanza alto per l'anonimizzazione e un I abbastanza alto per garantire la I-diversity all'interno di un q^* -block possiamo assicurare che il nostro dataset sia non inattaccabile ma in qualche modo messo al sicuro con una certa garanzia.

7.2.2 Principio della l-diversity globale

Un q^* -block è l-diversity se contiene almeno l valori ben rappresentati di un attributo sensibile S

- una tabella l -diverse
1. l -diversity in generale è una proprietà locale che si riferisca ad un q^* -block
 2. definita a livello globale se tutti i q^* -block sono l -diverse

Esempio di applicazione

Un modo per rappresentare la stessa tabella considerata prima (quella presentata quando abbiamo discusso dell'attacco Homogeneity attack) con un grado di diversità uguale ad l è raggruppare le tuple in maniera diversa.

- nel caso specifico abbiamo dei gruppi leggermente diversi rispetto a quelli di prima
- la colonna riguardante l'attributo sensibile si nota come in tutti i q^* -block ci sono tutti valori ben rappresentati, ovvero valori diversi rappresentati all'incirca con la stessa frequenza.

7.2.3 Entropy l-diversity

Come definire bene la l diversità e come utilizzarla in maniera corretta andando a definire il concetto di entropy l -diversity (l -diversità basata su entropia)

- possiamo dire che una tabella GT è entropy l -diverse se per ogni q^* -block, abbiamo che l'entropia della probabilità p è maggiore uguale di $\log(l)$
- dove la probabilità è il numero di tuple nel q^* -block con l'attributo sensibile uguale ad s , diviso il numero di tuple con tutti i valori possibili dell'attributi sensibile S . In sostanza la frazione di tuple nel q^* -block con attributo sensibile uguale ad s . Questo ovviamente all'interno dello stesso q^* -block

$$-\sum_{s \in S} p(q^*, s) \log(p(q^*, s)) \geq \log(l)$$

where $p(q^*, s) = \frac{n(q^*, s)}{\sum_{s' \in S} n(q^*, s')}$ is the fraction of tuples in the q^* -block with sensitive attribute value equal to s

Figure 7.1: Definizione di entropy l-entropy

Andiamo a dire che una tabella è l -diversa se rispetta la entropy l -diversità

7.2.4 Teorema della monotonicità dell' l -diversity

Teorema che dice che la l -diversità è una proprietà fondamentale che viene possibile sfruttarla in tutti gli algoritmi classici di k -anonymity.

Si può dimostrare che la l -diversity soddisfa la proprietà della monotonia. Se una tavola GT soddisfa la entropy l -diversity, allora ogni generalizzazione della tavola GT soddisferà la entropy l -diversity

- se abbiamo un livello di generalizzazione che soddisfa la l -diversity, i livelli superiore (livelli dove vado a raggruppare di più, o che comunque andiamo a generalizzare di più almeno uno degli attributi) sicuramente stiamo soddisfacendo ancora la l -diversity.

Viene garantito che la proprietà l -diversity risulta essere una proprietà da utilizzare all'interno degli algoritmi per la k -anonymity (algoritmi Incognito) per andare a rafforzare la k -anonymity sfruttando la proprietà l -diversity in maniera diretta nell'algoritmo. Tutto questo senza andare a generare diversi risultati k -anonimi e poi andare a scegliere quello che rispetta la l -diversity, senza avere neanche la garanzia di riuscire ad estrarre un dataset k -anonimo che abbia questa proprietà. Quindi non esiste un algoritmo apposito per realizzare la l -diversity, ma in particolare la entropy l -diversity è una proprietà che può essere iniettata in quasi tutti gli algoritmi per il calcolo delle tabelle k -anonime.

7.2.5 Problemi legati all' l -diversity

- consideriamo un dataset con un certo numero di attributi sensibile (HIV+, HIV-)
- andando ad analizzare bene i dati, si nota come il 99% degli individui sono HIV-
 1. anonimizziamo in modo da individuare due q^* -block Q1 e Q2,
 - a. Q1 è l -diverso, in quanto abbiamo due valori distinti ben rappresentati dell'attributo sensibile
 - b. il secondo non è l -diverso in quanto in questo q^* -block abbiamo lo stesso valore dell'attributo sensibile

Si deduce che Q1 pur essendo l -diverso ci dice che per questo gruppo di persone (ovvero quelle individuate da Q1) la probabilità di avere HIV+ è più alta. Quindi se io attaccante so che una certa persona ricade all'interno di questo q^* -block, questo automaticamente gli dà una maggiore probabilità di avere il virus dell'HIV. Per quanto riguarda il secondo gruppo, vero che non è l -diverso, in quanto c'è un solo valore rappresentato (HIV-), ma questo dice che la distribuzione di valori all'interno è all'incirca la stessa di quella della popolazione reale (stragranza maggioranza)

- prendiamo un'altra anonimizzazione, dove in ogni q^* -block la distribuzione di valori di persone positive o no all'HIV è all'incirca la stessa di quelle del database originale (99% di persone negative all'HIV).
- non stiamo rispettando il principio di l -diversity, in quanto non abbiamo valori diversi con all'incirca la stessa frequenza, ma comunque se rilasciata non rileva un bel niente, in quanto Q1 e Q2 hanno all'incirca la stessa distribuzione di valori per quanto riguarda la positività all'HIV

7.2.6 Altri esempi di problemi

- tabella in cui abbiamo un q^* -block l -diverso ma i valori per quanto siano diversi e ben rappresentati hanno valori abbastanza simili. In questo q^* -block possiamo facilmente indovinare che la persona che ricade all'interno di questo q^* -block (ammesso che sia sempre presente nella tabella privata) abbia un disturbo allo stomaco di qualche tipo

7.2.7 Attacchi che possono essere attuati su l -diversity

Attacchi basati sulla distribuzione di valori all'interno dei q^* -block

1. **skewness attack**, la distribuzione in alcuni q^* -block è molto diversa rispetto alla distribuzione di valori sensibili nella distribuzione originale
2. **similarity attack**, il q^* -block ha sì dei valori differenti ma il significato di valori è molto simile

id	Zipcode	Age	National.	Disease
1	130**	<30	*	Stomach ulcer
2	130**	<30	*	Stomach ulcer
3	130**	<30	*	Gastritis
4	130**	<30	*	Gastritis
...	...	...	...	...

Figure 7.2: Esempio alternativo di applicazione

7.3 t-closeness principle

È stato definito un altro principio che va a regolare la k-anonimizzazione delle tabelle.

- un q^* -block ha la proprietà della t-closeness se la distanza tra la distribuzione dell'attributo sensibile in questa classe di equivalenza e la distribuzione dell'attributo sensibile nell'intera tabella non supera una certa soglia t.
- se le due distribuzioni sono simili possiamo dire che il database ha questa proprietà
- t è una soglia che non deve essere superata dalla differenza che c'è tra le due distribuzioni

Una tabella si dice **t-close** se tutti i q^* -block presentano la proprietà della **t-closeness**.

7.3.1 Distanza tra le due distribuzioni

Non si andrà a calcolare più una differenza di valori all'interno di un certo gruppo di tuple ma calcolare una distanza tra due distribuzioni P e Q, immaginando che una sia la distribuzione di valori all'interno di un q^* -block e l'altra una distribuzione di valori dell'intera popolazione.

- la richiesta di avere un P e Q vicini permette di limitare la quantità d'informazione utile che può essere rilasciata, in quanto in qualche modo si limita la correlazione tra i QI e l'attributo sensibile.
- se un osservatore ha una visione precisa di questa correlazione potrebbe effettuare inferenza su attributi sensibili e re-identificare l'identità delle singole persone
- il parametro t è un trade-off tra l'utilità e la privacy.
 - se abbiamo un parametro t particolarmente basso, quello che succede è che effettivamente non notiamo nessuna differenza tra le due distribuzioni. Questo diminuisce l'utilità del dataset in quanto non viene più possibile fare ragionamento sugli attributi sensibili e quindi non scoprire correlazioni fra particolari comportamenti e una particolare patologia.
 - t troppo alto, quello che stiamo facendo è permettere ai dataset di avere un'alta differenza tra i q^* -block in termini di distribuzioni di valori di attributi sensibili e distribuzione di attributi sensibile nella popolazione globale.

Possibili distanze che possono essere utilizzate per calcolare la differenza tra due distribuzioni

Consideriamo due distribuzioni P e Q dove abbiamo lo stesso numero di attributi m che si distribuiscono in un caso come P e nell'altro come Q.

- $P=p_1, p_2, \dots, p_m$ e $Q=q_1, q_2, \dots, q_m$, dove p_1, q_1 sono i quantili delle varie distribuzioni, quindi quanti valori di p_1 troviamo, quanti di q_1 e così via...

Le due distanze tipicamente utilizzate sono:

- **distanza variazionale**, misurata andando a calcolare la differenza in termini di valori assoluto dei valori p_i e q_i e sommandone la metà. In questo modo andiamo a pesare correttamente il contributo di ogni quantile di queste due distribuzioni

$$D[P, Q] = \sum_{i=1}^m \frac{1}{2} |p_i - q_i|$$

- **Kullback-Leibler (KL)**, definita come la sommatoria di $p_i \log \frac{p_i}{q_i}$. Definita come una sorta di cross-entropy tra valori

$$D[P, Q] = \sum_{i=1}^m p_i \log \frac{p_i}{q_i}$$

Queste due distanze vanno piuttosto bene, ma in realtà queste non tengono in considerazione la distanza di tipo semantico.

7.3.2 EMD Distance

La t-closeness utilizza la **Earth Mover distance (EMD)** basata sulla minima quantità di lavoro per trasformare una distribuzione in un'altra, muovendo le masse di distribuzioni da una all'altra. Viene possibile utilizzare la stessa EMD per attributi di tipo numerico.

- consideriamo un dominio di attributi $v_1, v_2, \dots, v_m$, dove la distanza normalizzata tra due valori numerici è data dalla seguente formula

$$dist(v_i, v_j) = \frac{|i - j|}{m - 1}$$

- indichiamo la distanza r_i come $|p_i - q_i|$, la EMD viene calcolata come segue

$$D[P, Q] = \frac{1}{m - 1} (|r_1| + |r_1 + r_2| + \dots + |r_1 + r_2 + \dots + r_{m-1}|)$$

- in questo modo viene calcolato qual è il contributo che da ogni componente della distribuzione al calcolo della distanza

Se non abbiamo attributi numerici ma abbiamo attributi di tipo categorico, per domini di tipo **flat**, quindi domini che non hanno una loro gerarchia, possiamo utilizzare come distanza la seguente formula

$$D[P, Q] = \sum_{i=1}^m \frac{1}{2} |p_i - q_i|$$

.Per attributi che hanno come valore una **gerarchia di dominio**, allora

$$D[P, Q] = \sum_N \frac{1}{2} cost(N)$$

- dove *cost* è una specie di costo, ovvero il costo necessario per muovere un elemento da un punto all'altro della gerarchia.

Esempi di applicazione

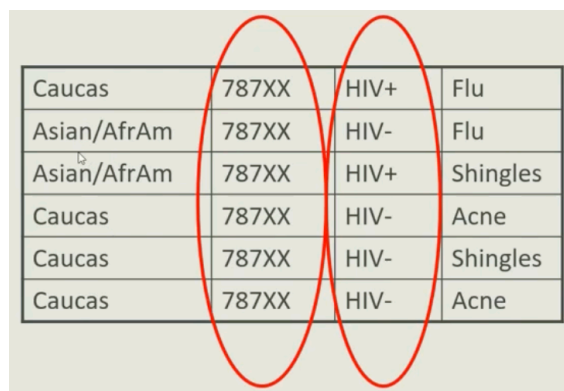
microdata					3-anonymous data				
id	Zipcode	Age	Salary	Disease	id	Zipcode	Age	Salary	Disease
1	47677	29	3K	Gastric ulcer	1	4767*	≤40	3K	Gastric ulcer
2	47602	22	4K	Gastritis	2	4767*	≤40	5K	Stomach ulcer
3	47678	27	5K	Stomach ulcer	3	4767*	≤40	9K	Pneumonia
4	47905	43	6K	Gastritis	4	4790*	>40	6K	Gastritis
5	47909	52	11K	Flu	5	4790*	>40	11K	Flu
6	47906	47	7K	Bronchitis	6	4790*	>40	8K	Bronchitis
7	47605	30	8K	Bronchitis	7	4760*	≤40	4K	Gastritis
8	47673	36	9K	Pneumonia	8	4760*	≤40	7K	Bronchitis
9	47607	32	10K	Stomach ulcer	9	4760*	≤40	10K	Stomach ulcer

Figure 7.3: Esempio di applicazione

Se volessimo calcolare la distanza tra distribuzioni rispetto a due attributi sensibili (salary e disease), notiamo che in questo caso la tabella di destra è 0.167 close rispetto a Salary e 0.278 rispetto a Disease. Utilizzando semplicemente la distanza tra distribuzioni è possibile definire quando una tabella è k-anonima e anche t-closeness

7.3.3 Problemi della t-closeness

Immaginiamo di avere una tabella di questo tipo, dove abbiamo alcuni attributi QI e altri di tipo sensibile (positività dell'HIV) Questa tabella è k-anonima, l-diversa e t-close. Possiamo



Caucas	787XX	HIV+	Flu
Asian/AfrAm	787XX	HIV-	Flu
Asian/AfrAm	787XX	HIV+	Shingles
Caucas	787XX	HIV-	Acne
Caucas	787XX	HIV-	Shingles
Caucas	787XX	HIV-	Acne

Figure 7.4: Esempio di applicazione in modo da capire quali siano i problemi della t-closeness

dire che questa bella è sicura?

- immaginiamo che un attaccante sappia che Bob è bianco e ha sentito di essere stato ricoverato in ospedale dovuta ad una certa forma d'influenza.
- succede che se riusciamo ad incrociare dati che sono in parte appartenenti ai QI e in parte costituiti da attributi sensibili riusciamo ad individuare il valore di positività all'HIV.
- stiamo utilizzando attributi sensibili come se fossero QI, questo viene possibile perché l'attaccante sfrutta una conoscenza di tipo background. Violiamo le regole, ma sti cazzi.

Problema della k-anonymity in generale e di tutte le sue estensioni l-diversity e t-close

Problema che non viene possibile risolverlo rimanendo nell'ambito della k-anonymity.

Cerchiamo di capire per qualche motivo la k-anonymity è un modello che può andare bene ma non sempre. Quando abbiamo definito k-anonymity, l-diversity e t-close, abbiamo preso come esempio un attaccante che aveva un certo tipo di conoscenza per effettuare attacchi su un dataset. Quello che abbiamo trascurato che in qualche modo hanno dell'informazione

propria che non possiamo prevedere a priori di che tipo sia. Inoltre, questo tipo di anonimizzazione non considerando la probabilità che effettivamente riusciamo a fare un attacco e non considerano algoritmo di tipo avversario che possono effettuare decisioni attraverso inferenza. Un altro problema grosso è che ogni attributo potenzialmente è un QI. Se abbiamo un'informazione esterna che si lega ad attributi sensibili, questi devono essere trattati come se fossero QI. Ma se trattiamo attributi sensibili come QI, siamo costretti a generalizzare questi attributi e quindi rilasciare un dataset la cui utilità dal punto di vista dell'analisi delle statistiche è potenzialmente bassa. Vediamo cosa viene possibile fare in quest ambito, quindi come andare in soccorso della k-anonymity per risolvere questo tipo di problema.

Problema che si lega alla **disclosure membership**. Una tabella contenga delle informazioni che sono relative ad una certa persona. Informazioni contenute in maniera anonimizzata, ma in qualche modo la tabella permette di dire se la persona è presente o meno all'interno del dataset.

Il problema che è QI sono unici all'interno di una popolazione. Quello che succede quando generalizziamo o sopprimmo tuple è che in qualche modo la distribuzione nei vari gruppi delle varie tuple all'interno del dataset cambia, però non andiamo a cambiare la distribuzione dei QI all'interno della popolazione.

- immaginiamo di avere una tabella contenente 10 record con un certo QI
- sappiamo che ci sono esattamente 10 persone nel mondo che hanno quei QI

Succede che con certezza una qualsiasi persona tra queste 10 è presente in una tabella. Se ci sono quindi 10 record con un certo QI e ci sono 10 persone che fanno match con quei QI, potremmo tranquillamente dire che con certezza che ognuna di queste 10 persona è presente all'interno della tabella. Morale della favola. Quello che la k-anonymity non può fare è non può nascondere il fatto che una persona sia presente o meno in un dataset. Possiamo nascondere certe informazioni sulle persone, ma di certo non possiamo nascondere che una determinata persona sia presente all'interno di un qualsiasi dataset.

Diminuire il rischio che si possa in qualche modo capire che un determinato individuo è presente all'interno del dataset

Necessità che deriva dal fatto di pubblicare dataset per supportare ricerca su specifiche condizioni ma in qualche modo rilasciare questo dataset potrebbe essere rischioso per certe classi d'individui

- **counter terrorism**, potremmo avere a disposizione di database che contengono informazioni su sospetti gruppi di terrorismi e utilizzare questi database in forma anonima per trovare pattern che possano capire l'eventuali reti terroristiche. Rilasciando questi dataset, se riuscissimo ad inferire la presenza di una particolare persona, riusciamo a capire che questa persona potrebbe essere un ipotetico terrorista.
- **medical research**, se abbiamo un dataset relativo ad una specifica malattia e riusciamo ad inferire che una persona è rappresentata all'interno di questo dataset sappiamo per certo che una certa persona ha quella malattia.

Il solo fatto di sapere che una persona è in un dataset rivela tanta informazione.

7.4 δ -presence

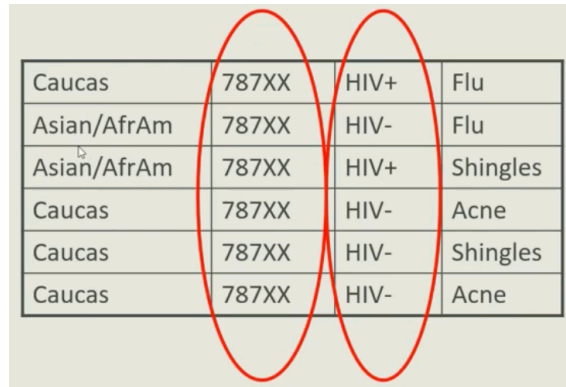
Limita la probabilità che un attaccante riesca a capire se un individuo è presente o no all'interno di un dataset. Consideriamo una tabella pubblica T e una tabella privata PT,

quello che possiamo dire è che la δ -presence è verificata per una generalizzazione di GT della tabella PT e questo con probabilità $\delta = (\delta_{min}, \delta_{max})$ se la proba che una tupla t appartenga a PT dato GT dove t è una tupla della tabella T, se questa probabilità è maggiore di un δ_{min} e minore di un δ_{max}

In un dataset che mantiene questa proprietà diciamo che ogni tupla t è δ -presence in PT.

- $\delta = (\delta_{min}, \delta_{max})$, da un range accettabile di probabilità per la probabilità di t appartenere a PT dato GT

Ovviamente per fare in modo che una tabella sia δ -presence è necessario agire sulla tabella GT



Caucas	787XX	HIV+	Flu
Asian/AfrAm	787XX	HIV-	Flu
Asian/AfrAm	787XX	HIV+	Shingles
Caucas	787XX	HIV-	Acne
Caucas	787XX	HIV-	Shingles
Caucas	787XX	HIV-	Acne

- informazioni in verde sono informazioni sensibili non divulgate. Questa rappresenta una tabella pubblica T

	Zip	Age	Nationality
b	47903	59	Canada
c	47906	42	USA
f	47633	63	Peru
h	48972	47	Bulgaria
i	48970	52	France

- dataset di ricerca in cui vengono raggruppate tutte le persone che hanno un attributo sensibile pari ad 1.

Per motivi di ricerca viene necessario pubblicare il dataset contenente questo insieme di persone (il primo in maniera privata) generalizzando gli attributi, utilizzando la k-anonymity. Possiamo andare a capire qual è la probabilità che una persona sia presente nella tabella (la prima)?? data la seconda tabella generalizzata GT (la seconda)

Si considerano le tuple che hanno lo stesso QI. Per ogni tupla di GT vale la δ -presence con $\delta_{min} = 1/2$, $\delta_{max} = 2/3$

- cosa interessante della δ -presence che se abbiamo una tabella pubblica T, una tabella privata PT e una GT^1 di PT e una GT^2 di GT^1 , se GT^1 è δ -presence rispetto a T, anche GT^2 sarà δ -presence rispetto a T e PT
- si può dire anche che se GT^2 non è δ -presence rispetto a T e PT anche la sua specializzazione GT^1 non è δ -presence.

Nel percorrere il reticolo si possono potare delle parti di reticolo in quanto non rispettano la δ -presence naturalmente per una coppia di parametri $(\delta_{min}, \delta_{max})$ dati in input all'algoritmo

7.4.1 titleScelta di un buon δ

Nel caso della δ presence gli autori hanno in qualche modo fornito una guida che permette di scegliere un buon δ .

- I_p evento che una persona p ha il diabete
- dato che l'incidenza del diabete nel sistema americano è un'informazione pubblica, un attaccante qualsiasi può avere il suo credo a priori b_r rispetto a questo evento a priori I_p

$$- b_r = P(I_p) = 0.07$$

- adesso prendiamo la tabella PT, tabella che risulta essere un sottoinsieme di tutti i pazienti che hanno il diabete.
- se andiamo a generalizzare la tabella PT con una generalizzazione chiamata GT, quale sarà il credo a posteriori che un attaccante può avere sull'evento I_p ?

$$- b_o = P(I_p|GT)$$

Riusciamo ad identificare alla fine una probabilità per il credo b_o che dipende da credo a priori b_r . Riusciamo a definire un credo a posteriori in funzioni di un credo a priori.

Il problema è capire come andare a sfruttare questa informazione per andare a selezionare un buon δ

Andiamo a considerare un costo accettabile dovuto all'utilizzo scorretto di questa informazione, ovvero informazione che una persona sia all'interno di questa tabella PT.

- immaginiamo che decida di assumere o no una persona sulla base di informazione che questa sia presente in PT. Stiamo immaginando una decisione che riguarda l'assunzione di questa persona
- immaginiamo che la differenza nel costo totale di un impiegato sia circa di 100euro, costo da imputare ad un rumore.
- se il costo atteso di un trattamento medico per il diabete basato sull'utilizzo scorretto del database è minore di 100, il rischio che questo dataset venga utilizzato per scopi malefici, ovvero per decidere l'assunzione o meno di una persona, è relativamente basso.
- Ipotizziamo che il costo annuale di diabete è di 10.000 dollari. Grazie a questa informazioni dobbiamo assicurarci che questo questo (prima formula) sia minore di c
- b_o credo a posteriori - b_r priori
- avendo la relazione da b_o b_r , possiamo calcolarci δ_{max}

7.4.2 Conclusioni

- la protezione data dalla k-anonymity deve essere misurata utilizzando delle misure di utilità che permettono di dire quanto questo dataset sia utile per scopi di ricerca. Non esistono standard bene definiti di misure di utilità che dicano quando una k-anonimizzazione ha generalizzato fin troppo e quindi il dataset non è più utilizzabile.
- abbiamo bisogno di algoritmi efficienti, in quanto la k-anonymity è un algoritmo complesso
- la k-anonymity non è detta che sia per forza legata ad una specifica tecnica

Problemi legati alla k-anonymity

La k-anonymity non ha modellato la conoscenza esterna che può essere comunque sfruttata per fare inferenza e quindi esporre i dati alla divulgazione di identità e attributi

7.4.3 Curse of dimensionality

La generalizzazione si appoggia molto sul concetto di **Curse of dimensionality**, cioè il fatto che ogni record deve avere k molto vicini fra loro. Il problema che il dataset reali disponibili per scopi di ricerca sono molti sparsi e inoltre hanno molti attributi.

- netflix, amazon

In questo caso anche il più vicino dei vicini potrebbe essere anche molto lontano. Se proiettiamo in poche dimensioni, quello che succede è che perdiamo molta informazione e la conseguenza di tutto questo è che i dataset di tipo k-anonimo in questi casi dove abbiamo tante dimensioni diventano essenzialmente inutili. La k-anonymity è ottima per dataset che hanno una cardinalità accettabile, altrimenti è un approccio che potrebbe essere scartato, almeno nella sua definizione attuale.

Chapter 8

Differential Privacy

Idea generale sulla **Differential Privacy (DP)** è quella di rilasciare il risultato di una query è quello di introdurre del rumore in modo tale che risultato sia in qualche modo non invertibile. Così facendo non viene possibile andare a capire quale sia il dataset a partire dal quale è stato calcolato. Primo meccanismo che andremo ad introdurre è il meccanismo randomizzato subito dopo seguito dal **meccanismo di Laplace**

8.1 Definizioni

8.1.1 Meccanismo Randomizzato

L'idea della DP è che non possiamo pubblicare il risultato vero e allora introduciamo della randomicità nel processo di calcolo. Funzione che prende in input un dataset D , una query q e restituisce un valore stocastico, vale a dire un valore qualsiasi del codominio, dove ad ogni valore è associato una certa probabilità.

8.1.2 δ -differential privacy

- Ω indichiamo insieme di tutti i dataset
- Q insieme di possibili query che possono essere fatte
- definiamo dataset adiacenti due dataset che differiscono di un solo record.

Noi vogliamo garantire che la probabilità di ottenere un risultato da D o D' sia la stessa.

- un meccanismo M rispetta la ϵ -differential privacy se vale la seguente formula
- la probabilità che il meccanismo restituisca il risultato r quando il dataset è D , diviso la probabilità che il meccanismo restituisca il risultato r quando il dataset è D' deve essere compresa tra $e^{-\epsilon}$ e e^{ϵ}
- ϵ **privacy budget** indica il livello di privacy che viene rappresentato dal meccanismo. Con un ϵ che tende a 0 entrambi tendono a 1 e quindi il rapporto tra le due probabilità è all'incirca 1, quindi stiamo chiedendo che le due probabilità siano all'incirca uguali e questo deve essere vero per ogni possibile risultato (per ogni punto della retta reale) e per ogni coppia di dataset adiacenti. Immaginatelo come se fosse un borsellino di privacy che abbiamo a disposizione, dove ogni volta che vogliamo attuare un'operazione che parta dai segreti dobbiamo attingere a questo nostro budget e quindi sprecarne un po'. Continuiamo fino a quando non lo esauriamo e quindi non possiamo fare più ulteriori analisi.

$$1 \approx e^{-\epsilon} \leq \frac{P(M(q, D) = r)}{P(M(q, D') = r)} \leq e^{\epsilon} \approx 1$$

- altra cosa fondamentale è che tanto ϵ è vicino allo 0 tanto più e^ϵ è vicino a 1 e quindi tanto più simili devono essere le due probabilità, quindi con un ϵ molto piccolo viene garantita molta privacy, le due probabilità sono quasi uguali, caso contrario viene permesso che la probabilità che un risultato provenga da D o D' siano poco diverse.

$$e^{-\epsilon} \leq \frac{P(M(q, D) = r)}{P(M(q, D') = r)} \leq e^\epsilon$$

8.1.3 Privacy vs. Accuracy

Se il meccanismo è ben fatto il valore restituito dal meccanismo è il valore vero di $q(D)$ e quindi chiediamo che il risultato sia sensato e che quindi restituisca un valore sensato vicino al vero risultato di $q(D)$. Nella definizione di ϵ -differential privacy questa attenzione non c'è, si chiede solo che il meccanismo sia privato.

- funzionamento meccanismo. Prende un dataset, una query q e restituisce 100. Risultato innacurato. Se volessi l'altezza media di una classe 100 è un risultato sbagliato
- d'altro canto, è un risultato perfettamente privato. Non abbiamo modo di capire che il dataset segreto sia D o D'

Attenzione, quando si disegna un meccanismo di ϵ -differential privacy è importante rispettare la definizione e che il meccanismo sia accurato e serva a qualcosa.

8.1.4 Il meccanismo di Laplace

- abbiamo un dataset D e una query q , dove il risultato vero è $q(D)$
- il meccanismo costruisce una distribuzione di Laplace centrata nel vero valore $q(D)$ ed estrae un risultato da questa distribuzione
- è una specie di normale concentrata nel valore centrale. Dalla figura si nota come non sia un'unica distribuzione, ma una famiglia di distribuzione. Dipende da due parametri μ ci dice dove è centrata la distribuzione, l'altro parametro σ ci dice la forma esatta della distribuzione, tanto più piccolo è tanto più la distribuzione è concentrata intorno al valore centrale, caso contrario la distribuzione diventa più piatta. In termini di accuratezza nel primo caso la distribuzione è tanto migliore in quando restituirà valore che saranno più vicini al valore centrale, ovvero quello giusto. Caso contrario, ogni valore della retta reale diventa ugualmente probabile quindi il meccanismo sarà inaccurato.

Come scegliere il parametro?

- se fossimo liberi di farlo lo sceglieremo il più piccolo possibile. Purtroppo non è così facile in quando deve essere scelto secondo un criterio che comunque vada a soddisfare il meccanismo di ϵ -differential privacy.
- parametro che dovrà dipendere da due grandezze. ϵ , ovvero il livello di pp che vogliamo garantire e la seconda è la funzione q che vogliamo distorce in maniera differenzialmente privato.
- diverse funzioni richiedono diverso livello di distorsione.

Abbiamo due distribuzioni di Laplace 8.1 dove la rossa è centrata nel valore 2 e la verde nel punto 2.1. Per garantire la ϵ -DP, dobbiamo far sì che le due distribuzioni siano molto vicini tra loro in ogni singolo punto. Ovvero, in ogni singolo punto della retta reale, la distanza tra le due distribuzioni deve essere più piccole di una soglia e^ϵ . Aumentando il parametro ϵ le due distribuzioni diventano più piatte e vicine, caso contrario le due distribuzioni diventano più diverse soprattutto nel punto 2.

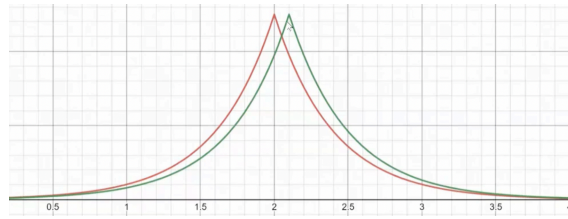


Figure 8.1: Due distribuzioni differenti di Laplace

- quando vogliamo rispettare tanta privacy, vogliamo che le due distribuzioni siano tanto vicini e quindi scegliere un parametro σ grande e di conseguenza ϵ piccolo.

Il parametro σ deve aumentare quando aumenta la distanza, ovvero la variazione di q tra dataset adiacenti. Il parametro σ viene scelto come $GS(q)/\epsilon$

- altro modo per descrivere il meccanismo di Laplace è quello di andare a calcolare il vero risultato $q(D)$ e poi sommarli del rumore estratto da una distribuzione di Laplace centrata in 0 con lo stesso parametro.

8.1.5 Sensitività Globale (GS)

Misura la variazione massima della query q quando calcolata in due dataset adiacenti

- prendiamo tutte le coppie D e D' calcoliamo la variazione di q in norma 1 e prendiamo il massimo

$$GS_1(q) = \max_{D \sim D'} \|q(D) - q(D')\|_1$$

- si dimostra che il meccanismo di Laplace con parametro $\sigma = GS(q)/\epsilon$ rispetta la ϵ -DP, ovvero fa sì che le due curve siano abbastanza vicine da rispettare la DP.

Definizione generica sia quando q è una funzione scalare che vettoriale.

Parametro migliore che si possa scegliere

Fin ad adesso abbiamo considerato query q scalari, ovvero che prendono un dataset D e restituiscono un singolo numero. In realtà il meccanismo di Laplace funziona anche quando il risultato non è più un singolo numero ma un vettore numerico.

- calcoliamo il risultato $q(D)$ che a questo punto sarà un vettore e li aggiungiamo un rumore di Laplace ad ogni singola componente $q(D)$.

8.1.6 Beyond the Laplace Mechanism

Ci sono casi in cui il meccanismo di Laplace non può essere utilizzato. La somma del rumore può essere fatta solo se il risultato di $q(D)$ è un numero, in caso contrario dobbiamo trovare un altro modo per risolvere il problema. Nel caso in cui la query fosse comunque numerica ci sono dei casi in cui il meccanismo non funziona bene, **disturba il risultato**.

- **selezione differenzialmente privata.** Il risultato restituito dalla query è un risultato che massimizza una certa funzione di utilità. Il meccanismo di Laplace aggiunge del rumore, ma è possibile che modificando poco il risultato in realtà, la funzione di utilità crolli.

Customer	Max Amount
A	1
B	1
C	3.01

Figure 8.2: Esempio per cui Laplace not run

Capire a che prezzo vendere il prodotto, ovvero quello che massimizza i ricavi

- per ogni cliente viene riportato il prezzo massimo disposto a pagare ogni customer.
- se scegliessimo un prezzo tra 0 e 1 tutti comprano e quindi ricaveremo tre volte tanto il prezzo, viene venduto tre volte
- se scegliamo un prezzo tra 1 e 3.01, A e B smettono di comprare il prodotto e compra solo C, quindi ricaviamo una volta il prezzo stabilito
- superiore a 3.01 ricaviamo 0

Il prezzo ottimale (3.01) è quello che ci fa vendere un solo pezzo ma al prezzo maggiore.

Supponiamo di voler usare un meccanismo DP per calcolare questo risultato e useremo Laplace. Calcoleremo il vero risultato 3.01 e li sommiamo del rumore (molto piccolo). Il risultato finale distrugge l'utilità, si passa dal guadagnare il massimo a guadagnare 0. Proprio per cui siamo costretti, onde evitare problemi di questo genere, ad utilizzare un altro meccanismo, il meccanismo esponenziale.

8.1.7 Il meccanismo esponenziale

Meccanismo funzionante anche per quelle query non numeriche.

- abbiamo una funzione q che deve scegliere tra un insieme di possibili risultati R il risultato che massimizza il risultato di una certa funzione di utilità U .
- La funzione U non dipende solo da R ma anche dal dataset che stiamo considerando. Questo perchè se il dataset è 1, avremo alcuni valori di utilità, valori che cambieranno nel caso in cui dovessimo cambiare il dataset. Quindi dipende anche dal dataset D .
- il risultato vero della funzione idealmente sarebbe quello giallo

Il meccanismo associa ad ogni singolo risultato dell'insieme R una probabilità d'estrazione e questa probabilità è scelta proporzionale alla funzione d'utilità, dove con maggior probabilità estraremo il risultato corretto e così via

Come facciamo ad assegnare una probabilità ad ogni possibile risultato

Dipende da due fattori

1. livello di pp che vogliamo rispettare, ovvero il privacy budget ϵ
2. la funzione di utilità U che stiamo considerando.

Le singole probabilità associate ad ogni singolo risultato r devono essere proporzionale a $e^{U(D, r)}$ e elevato a ϵ per

- ϵ privacy budget
- $U(D, r)$, funzione di utilità associato al risultato r

- $GS(U)$, sensitività globale della funzione di utilità

In Laplace vedevamo la variazione massima della funzione, qui vediamo la variazione massima dell'utilità.

- valore dell'utilità in ogni singolo risultato r sia per il dataset segreto D che D'
- per ogni r si sceglie la massima variazione su ogni possibile coppia di dataset adiacenti e poi si sceglie tra tutti i possibili risultati r . Ci sono due massimi perchè U dipende da due valori non più da uno solo.

$$GS(U) = \max_{r \in R} \max_{D \sim D'} |U(D, r) - U(D', r)|$$

LA GS è la variazione massima che possiamo avere quando la calcoliamo su dataset adiacenti.

8.2 Proprietà della Differential Privacy

I due diversi meccanismi presentati sono Laplace e Esponenziale. Il primo viene utilizzato per funzioni numeriche, il secondo per funzioni non numeriche o problemi di selezione private. Con questi due strumenti messi a disposizione viene possibile andare a calcolare in maniera differenzialmente privata praticamente ogni funzione. In verità è più complesso di così. In entrambi, per poterli applicare abbiamo bisogno comunque di poter calcolare la GS. Avvolte il calcolo della variazione non è tanto semplice da calcolare. Quanto cambia il valore della funzione se aggiungo o tolgo un record dal dataset, se la funzione è molto complicata, immaginate un algoritmo molto complesso, non riusciamo a dire quanto cambia il risultato cambiando l'input anche di poco, quindi non riusciamo a calcolare la variazione, la GS e di conseguenza non siamo in grado di applicare i meccanismi che abbiamo a disposizione. Per fortuna la DP gode di alcune proprietà ottime che fanno sì che possiam prendere questo algoritmo complesso, spezzettarlo in sotto funzioni semplici (funzioni per la quale sia in grado di calcolare la GS) e poi rimporre il tutto. Questi teoremi ci danno un modo per capire se l'algoritmo complessivo continua a rispettare una qualche forma di DP e quanta pp rispetta. I tre teoremi che presenteremo, messi assieme permettono di comporre insieme diversi meccanismi privati e quindi rendere privato anche un algoritmo molto complesso.

8.2.1 Teorema di Post-Processing

- abbiamo un dataset segreto e un meccanismo di DP, che applichiamo su questo dataset ottenendo un risultato $M(D)$. Risultato che comunque rispetta la ϵ -DP.
- continuiamo la nostra analisi, applicando una nuova funzione sul risultato privato ottenuto sul risultato precedente. Se questa seconda funzione che applichiamo non dipende più dai dati, ma elabora soltanto il risultato precedente, allora continua a rispettare la DP.

Vuol dire che quando calcoliamo una grandezza in maniera privata, possiamo continuare a fare tutte le trasformazioni che voglio, stando comunque sicuri che questi risultati continueranno a rispettare la DP. Questo a patto che le ulteriori funzioni non accedano più ai dati segreti. In caso contrario, abbiamo bisogno di utilizzare un meccanismo nuovo di DP.

- post-processing non peggiora le garanzie di privacy

8.2.2 Teorema di Composizione

Cosa succede se applichiamo più di un meccanismo sullo stesso dataset?

- immaginiamo di avere due meccanismi, dove entrambi rispettano la DP, dove in particolare M_1 rispetta la $\epsilon_1 - DP$ ed M_2 rispetta la $\epsilon_2 - DP$
- singolarmente i due meccanismi sono privati, quindi rispettando la DP. Il problema è capire cosa succede nel momento in cui decidiamo di pubblicare i risultati contemporaneamente, quindi capire chi ci garantisce che ancora la coppia di risultati garantisca la DP

Tale garanzia viene data appunto da questo teorema di composizione. Il meccanismo complessivo che pubblica entrambi i risultati $M_1(D)$ e $M_2(D)$ rispetta ancora la DP. Il livello di privacy viene definito come la somma dei livelli di privacy di singoli algoritmi privati, quindi ϵ_1, ϵ_2 singoli livelli di privacy.

- il meccanismo complessivo che pubblica entrambi i risultati è ancora privato, ma meno privato dei singoli meccanismi. Ragionamento abbastanza ovvio. Più informazione estraggo dal dataset, più è facile ricostruire il dataset segreto, quindi individuare un particolare individuo. Se calcolo 100 meccanismi rischiamo di compromettere la privacy.
- la DP comunque viene ancora rispettata ma meno. Quanto meno? La somma degli ϵ dei singoli meccanismi

Se mettiamo assieme i due teoremi, possiamo prendere questi due risultati, comporli come vogliamo perchè tanto non sprechiamo più privacy budget, questo perchè non stiamo più accedendo ai dati originali e quindi possiamo fare tutte le operazioni che vogliamo su questi risultati.

8.2.3 Teorema di composizione in parallelo

- immaginiamo di avere un dataset D e lo spezziamo in due parti disgiunte
- applichiamo un meccanismo prima sul primo blocco e dopo sul secondo. Singolarmente i due meccanismi rispettano la ϵ -DP.
- quando pubblichiamo entrambi i risultati secondo il teorema precedente dovremmo rispettare la $\epsilon + \epsilon$ DP.

Questo teorema dice che rispettiamo la sola ϵ DP, non c'è peggioramento nel livello di privacy. Questo perchè stiamo applicando il meccanismo a sezioni disgiunte del dataset. Se aggiungiamo un nuovo record, questo viene aggiunto o nella prima parte, o nella seconda, quindi di fatto ci preoccupiamo di difendere la privacy in uno solo dei dataset (in quello dove è stato aggiunto il record).

8.3 (ϵ, δ) -Differential Privacy

Fino ad adesso abbiamo fatto riferimento alla prima definizione di DP, conosciuta anche come DP pura, che dipende da un solo parametro ϵ . Si è visto che in molti casi questa definizione è un po troppo stringente e quindi per garantire un ottimo livello di privacy si rischia d'introdurre un po troppo rumore e quindi ottenere un risultato molto poco accurato e quindi molto diverso rispetto a quello che è il valore vero. Si è pensato di modificare un po la definizione, in modo da rilassarla, aggiungendo un nuovo parametro δ in modo da permettere di aggiungere meno rumore e ottenere risultati più precisi.

Definizione simile a quella vista prima

- un meccanismo M rispetta (ϵ, δ) -**DPferential privacy** per ogni possibile query q , per ogni possibile coppia di dataset adiacenti D e D' e per ogni possibile risultato del meccanismo r , la probabilità che il risultato provenga dal dataset D è minore uguale di e^ϵ per la probabilità che il meccanismo restituisca r a partire dal dataset D' a lui adiacente $+ \delta$
- δ , c'è un teorema che spiega il suo significato

$$P(M(q, D) = r) \leq e^\epsilon \cdot P(M(q, D') = r) + \delta$$

Significato di δ dato da un teorema

Un meccanismo M rispetta la (ϵ, δ) -DPferential privacy se esiste un evento E che si verifica con una probabilità $P > 1 - \delta$ tale che ogni volta si verifica questo evento E , il meccanismo rispetta la ϵ -DPferential privacy, invece non importa cosa succede quando E non si verifica.

- δ è una sorta di probabilità di fallimento del meccanismo
- con $P(\delta)$ il meccanismo fallisce, ma in tutti gli altri casi il meccanismo funziona

I teoremi visti prima continuano ad essere validi anche qui.

Se la probabilità di fallimento risulta essere molto piccola (δ molto piccolo), comunque la definizione di δ -DP è molto più debole, questo perchè stiamo ammettendo che ci possa essere un fallimento e che quindi alla fine il risultato non stia rispettando la privacy.

Esempi d'applicazione

Vogliamo calcolare la funzione $q(D)$ = numeri di record del dataset D

- **Meccanismo 1**

- estrae un numero nell'intervallo $[0, 1]$ con probabilità uniforme, quindi tutti i numeri hanno la stessa probabilità
- se il numero estratto è $> \delta$ allora utilizza Laplace per rilasciare il risultato, quindi viene rilasciato $q(D) + \text{rumore dovuto a Laplace}$
- se invece $< \delta$ viene rilasciato l'intero dataset

Questo meccanismo rispetta (ϵ, δ) -DPferential privacy, perchè con probabilità $1 - \delta$ abbiamo un risultato privato, ma con probabilità δ rilascio tutti dati. Nonostante questo il meccanismo continua a rispettare la (ϵ, δ) -**DPferential privacy**.

- **Meccanismo 2**

- se $< \delta$ rilasciamo $q(D)$.

La (ϵ, δ) -DPferential privacy viene rispettata, perchè con probabilità $1 - \delta$ rispettiamo la ϵ -DP, ma con probabilità δ non viene più rispettata. Un po' meno grave perchè comunque rilasciamo un numero di record e non l'intero dataset.

δ deve essere scelto piccolo, questo perchè in caso di fallimento possono esserci conseguenze gravi. La scelta di quanto deve essere piccolo viene lasciata a noi e scelto in base al meccanismo che decidiamo di usare. Se riteniamo il meccanismo molto pericoloso vogliamo che δ sia quasi 0, perchè in caso di fallimento potrebbe succedere un casino. Altrimenti, potremmo sceglierlo anche un po' più grande.

δ sceglierlo almeno inversamente proporzionale al quadrato del numero dei record del dataset.

8.3.1 Il meccanismo di Gauss

Meccanismo usato davvero quando s'intende usare la (ϵ, δ) -DPferential privacy è quello di Gauss. Funziona all'incirca come quello di Laplace

- calcola il risultato vero $q(D)$ e li aggiunge del rumore.
- tale rumore stavolta viene estratto da una distribuzione normale. Distribuzione che dipende da due parametri
 - μ , che dice dove è centrata la distribuzione e poichè vogliamo aggiungere meno rumore possibile la centriamo in 0
 - σ^2 , dice la forma esatta di questa distribuzione. Tanto più piccolo è σ tanto più sarà concentrata intorno al valore 0 sarà la distribuzione

Esattamente come prima non possiamo scegliere σ liberamente, dobbiamo sceglierlo in modo che sia rispettata sempre la (ϵ, δ) -DPferential privacy. Il meccanismo di Gauss rispetta la (ϵ, δ) -DPferential privacy prendendo ϵ, δ entrambi tra 0 e 1, se la varianza è $\sigma^2 = \frac{2GS_2(q)^2 \log \frac{1.25}{\delta}}{\epsilon^2}$. Viene utilizzata sempre la GS per decidere quale sia la forma adatta per rispetta la DP, ma stavolta usiamo la L2.

- se la funzione q è una funzione scalare non cambia niente. Abbiamo un numero se facciamo norma 1 è uguale al valore assoluto di v con norma due radice quadrata di v^2 e questo fa esattamente valore assoluto di v
- se fosse vettore potrebbe succedere che la norma 2 sia molto più piccola della norma 1 e quindi riduciamo la quantità di rumore inserito e quindi il meccanismo di Gauss viene ad essere tanto conveniente proprio in questo caso.

8.3.2 Laplace vs Gauss

1. Laplace

- rispetta la ϵ -DP. Molto meglio perchè risulta essere più forte come garanzia di privacy
- $\forall \epsilon$
- L1

2. Gauss

- (ϵ, δ) -DP
- vale soltanto quando $\epsilon \in (0, 1)$
- L2, potrebbe essere visto come un punto a favore di Gauss in quanto la L2 potrebbe restituire un valore molto più piccolo rispetto ad L1
- supponendo che le due sensitività sia uguali tra loro e scegliendo lo stesso ϵ la distribuzione di Gauss aggiunge molto più rumore. È più accurata perchè da con più alta probabilità dei valori vicini allo 0.

8.4 (ϵ, δ) -local differential privacy

8.4.1 Interactive vs Non-interactive

All'inizio dicevamo che lo scenario in cui ci muoviamo è quello **interactive**

- ci sono degli individui

- abbiamo un curatore che raccoglie i dati
- lo stesso curatore si preoccupa di pubblicare una o più analisi in riferimento a questi dati

Questo scenario dove il curatore calcola e pubblica analisi in maniera distorta si chiama **scenario interattivo** perchè bisogna immaginarsi questo scenario come una sorta di dialogo tra il curatore e l'analista che vuole capire delle verità a partire da quei dati. L'analista chiede ad esempio quanto vale la media mediana, e così via. Il curatore risponde in maniera ϵ -DP. C'è una sorta di dialogo interattivo in cui uno chiede e l'altro risponde.

- il possibile problema di questo scenario è che se facciamo tante query, dobbiamo usare per ogni query una parte del privacy budget a nostra disposizione e per il teorema di composizione vista prima, i privacy budget si sommano. Facendo tante analisi private spenderemo tanto privacy budget e quindi alla fine andremo a rispettare poca privacy.
- il curatore è disposto a rispondere all'analista, ma comunque fino ad un certo livello fino a quando il budget si esaurisce.

Per risolvere questo problema, ovvero non risponde a troppe query, o al massimo lo possiamo fare ma in maniera poco precisa perchè dobbiamo poco ϵ budget per ognuna delle risposte che diamo. L'idea è quella di utilizzare uno scenario **non interattivo**

- il curatore fidato anziché aspettare le domande dell'analista fa una copia privata del dataset e pubblica questo. Qui l'analista può fare tutte le query che vuole e per il teorema di post-processing visto prima non c'è più bisogno di aggiungere del rumore, xk non stiamo guardando i veri dati segreti/sensibili ma una copia privata

Occorre capire come fare una copia privata del dataset

L'idea è creare un dataset sintetico che sia il più simile possibile a quello vero (quello segreto). In uno scenario totalmente interattivo il significato di somiglianza non è tanto chiaro.

- Si possono calcolare delle macro-statistiche in modo che i dati rispettino queste macro-statistiche.
- Oppure, calcolare una sinossi privata dei dati. Non si pubblica un dataset con lo stesso formato, con nuovi dati leggermente diversi, si pubblicano tante statistiche che descrivano questo dataset e poi si lasciano queste informazioni all'analista

Quello che funziona meglio (interattivo e non) non può essere detto, dipende comunque dal numero di analisi che si vogliono fare. Spesso si parla di scenario non-interattivo ma in verità, un po' interattivo è. Quando pubblichiamo il risultato del dataset distorto, abbiamo già in mente lo scopo dell'utilizzo.

8.4.2 Untrusted curator

In entrambi gli scenari, era necessario che fosse presente la figura del curatore fidato che raccoglie e rilascia dati. Alle volte questa figura non esiste. L'ospedale ne è un esempio, che raccoglie i dati di ogni paziente per fare degli studi. I pazienti si fidano dell'ospedale, non si fidano di altri. Esistono altri scenari dove il singolo utente non vuole proprio condividere informazioni neanche alla persona che li raccoglie.

- le ricerche che facciamo su google. Google utilizza una forma di DP vabbè ma sti cazzi!
- in questo nuovo scenario la definizione di DP non è tanto adatta. La DP vista fino a adesso è una proprietà di una query che prende come input un dataset e chiede indistinguibilità tra le probabilità tra dataset adiacenti, ma a questo punto la funzione

che vogliamo distorcere non prende più un singolo dataset ma un singolo record, record del singolo utente che vuole comunicare i suoi dati quindi viene opportuno cambiare la definizione di Differential Privacy. Non vogliamo più mascherare la presenza di un particolare individuo e del record di quel particolare individuo, ma vogliamo nascondere come è fatto quel record.

Proprio per cui introduciamo una nuova definizione di DP, (ϵ, δ) -local differential privacy.

8.4.3 (ϵ, δ) -local differential privacy

- local perchè per ogni utente distorce il proprio record.
- la funzione cambia, non si prende più in input un dataset e restituisce un risultato, ma una funzione che prende in input un record e restituisce un risultato distorto
- q va da U (insieme di tutti i record) in un codominio R

Il metodo chiede indistinguibilità, ovvero che siano simili le probabilità di ottenere ogni particolare output r se la funzione parte da un record x o x' che sia (cade la nozione di dataset adiacenti). Noi vogliamo che qualsiasi record debba essere confuso con qualsiasi altro. Questo perchè quando rilasciamo dati non vogliamo che venga riconosciuto, proprio per cui quel record che rilasciamo debba confondersi con tutti i record.

8.4.4 Confronto tra le due differential privacy

1. Differential Privacy

- le formule sono le stesse, cambia la notazione, qui dataset li record
- cambia rispetto a cosa chiediamo indistinguibilità. Qui ad esempio, per ogni coppia di dataset adiacenti, li record.
- si basa su funzioni query che prendono un dataset. Invece la LDP prende su query che prendono in input un record o singoli individuo
- chiede indistinguibilità per ogni coppia di dataset adiacenti
- tutti i teoremi che valevano per la DP valgono anche per la LDP, e quindi viene possibile comporre insieme tutti i meccanismi di LDP che vogliamo e continuiamo a rispettare la LDP con le stesse regole viste per la DP normale
- la DP introduce meno rumore. Qui rilevavamo il risultato di una query che aggregava tutti i dati, quindi bastava aggiungere poco rumore per non far capire se c'era un record particolare

2. Local Differential Privacy

- di solito questa introduce più rumore rispetto alla DP.
- stiamo rilevando più informazione. prima solo il risultato di una query che aggregava tutti i dati. quindi bastava aggiungere poco rumore. qui stiamo rilevando uno per uno i singoli record
- chiede indistinguibilità per ogni coppia di record
- qui stiamo rilevando ogni record e quindi dovremmo aggiungere appunto più rumore.
- cambia la nozione di adiacenza, qui vogliamo confondere ogni record con ogni altro record, motivo per cui abbiamo bisogno di più rumore
- la forza di questa non è nella quantità di rumore inserita ma nel fatto che LDP viene usata quando non c'è un curatore fidato oppure non c'è proprio un curatore, siamo in uno scenario decentralizzato dove ogni singola persona pubblica i suoi dati in maniera privata e poi collaborativamente calcolano una certa grandezza che interessa (**inferred learning)**

Come raggiunge la Local Differential Privacy

Esistono dei meccanismi che trasformano una normale funzione in una funzione localmente differenzialmente privata

- il più famoso di tutti è la risposta ****randomizzata (randomized response**)**. Tecnica per rilasciare dati che esisteva intorno agli anni 70.
- supponiamo di fare uno studio per il quale servono delle informazioni sensibili. In particolare vogliamo sapere dai diversi individui se posseggono una certa propria ritenuta imbarazzante o addirittura illegale.
- Bisogna inventarsi un modo, in modo tale che le persone si fidano nel rilasciare dati. La risposta non sarà sempre onesta, ma ogni tanto mentirà. Introdurre un po' di rumore nella risposta dove ogni tanto mentiremo, in modo tale che se anche dovessi dichiarare la proprietà indesiderabile chi legge il risultato della risposta non sa con certezza se abbiamo risposto perché vero oppure perché ho aggiunto un poco di rumore.

8.4.5 Il meccanismo della moneta - Prima formulazione

L'individuo può rispondere o con un valore che corrisponde alla verità oppure con il falso. Prima di rispondere viene lanciata una moneta.

- se esce croce risponde con la verità;
- altrimenti tira un'altra volta la moneta e risponde con la verità quando esce testa e risponde con falso quando esce croce. Questa risposta non ha nessun legame con la verità.

Così facendo non riusciamo più a capire se quella persona abbia dato quella risposta perché è effettivamente vera oppure ha dato una risposta causata dal meccanismo randomizzato.

Quando è arrivata la definizione di local-DP, si è visto che questa risposta randomizzata rispetta una qualche forma di Local Differential Privacy con un $\epsilon = \log 3$

8.4.6 Generalized Randomized Response

La risposta randomizzata in realtà può essere utilizzata soltanto nel caso in cui la domanda fatta all'individuo che deve rilasciare i suoi dati, prevede una risposta binaria

- sì o no

Esistono altre query, come quelle che possono dare k risultati, città di provenienza, quindi come a distorcere una query del genere i cui possibili valori sono k ? Si è creata una versione generalizzata della risposta randomizzata.

- ci viene chiesto il risultato della query q per i miei dati In quale città vivo e tra tutte le città possibili, la risposta randomizzata generalizzata da come risposta tra tutte le risposte possibili una estratta da questa distribuzione di probabilità, cioè:
 - se il valore vero, ovvero quello che l'individuo risponderebbe in maniera sincera, viene restituito con probabilità $\frac{e^\epsilon}{e^\epsilon + k - 1}$
 - mentre qualsiasi risposta falsa viene restituita con probabilità $\frac{1}{e^\epsilon + k - 1}$

Ci chiediamo se questo meccanismo è accurato, in modo tale da capire se anche qui, così come succedeva nella risposta randomizzata normale la probabilità di dare una risposta vera è più alta rispetto a quella di dare una risposta falsa?

- la probabilità di dare una risposta vera è $\frac{e^\epsilon}{e^\epsilon + k - 1}$

- la probabilità di dare una risposta falsa è $\frac{1}{e^\epsilon + k - 1}$
- siccome sappiamo che per ϵ maggiore di 0 e^ϵ è maggiore di 1 effettivamente la probabilità di dare la risposta vera è più alta.

D. Quando e^ϵ è più grande di 1?

R. Questo dipende da ϵ , quando è molto piccolo e tende a 0, e^ϵ tende a 1 vuol dire che la probabilità di dare la risposta vera è quasi uguale alla probabilità di dare qualsiasi altra risposta. grazie al cazzo, perchè ϵ è il privacy budget, tanto più piccolo è tanta più privacy rispettiamo tanto più inaccurato è il meccanismo.

- quando ϵ è tanto più grande di 0 e e^ϵ è molto più grande di 1 e quindi il meccanismo diventa accurato

Cosa succede se scegliamo un $k = 2$, dove con k intendiamo il numero possibile di risultati

- la probabilità di dare la risposta vera è, considerando $\epsilon = \log 3$ è $3/4$
- la probabilità di dare la risposta falsa è altrimenti, considerando $\epsilon = \log 3$ è $1/4$
- probabilità che dipende da epsilon e quindi possiamo modularla secondo il livello di pp che vogliamo garantire. Scegliamo $\log 3$ quello di prima e sostituiamo
- considerando i primi due punti i risultati coincidono con le probabilità di prima, il meccanismo della risposta randomizzata generalizzata è uguale a quella di prima

Cosa succede se k aumenta? $k = 5$ e $\epsilon = \log 3$

- probabilità dell'unica risposta vera è $3/7$
- probabilità di dare 4 risposte false possibili, e qual è la probabilità di dare una di queste 4 risposte false. $1/7$ e fino a qui tutto bene, la prob di V è più grande rispetto alla probabilità di dare quella singola risposta falsa
- si nota che all'aumentare di k le probabilità risultano essere abbastanza simili e quando k cresce il meccanismo diventa meno accurato

Il meccanismo funziona ma attenzione che quando k cresce o quando ϵ è piccolo il meccanismo non è tanto accurato.

8.4.7 Metodi per preservare la LDP

1. unico metodo che abbiamo visto fin ora per garantire la LDP è la risposta randomizzata generalizzata, da applicare solo quando la funzione q è una funzione a valori categorici, cioè il codominio di possibili valori che può restituire sono discreti, perchè dobbiamo dare una probabilità discreta ad ogni singolo output possibile
2. se invece la funzione q è una funzione a valori numerici, come faccio a garantire la LDP. In realtà possiamo usare i meccanismi per la DP globale, quindi Laplace. Ogni singolo individuo calcola il vero valore dei suoi dati $q(x)$ e li somma del rumore estratti da una distribuzione di Laplace, qui però adesso cambia ciò che vogliamo proteggere, quindi, quando andiamo a decidere la forma di rumore di Laplace e decidere quanto rumore inserire non dobbiamo guardare alla massima variazione tra dataset adiacenti ma alla variazione tra ogni coppia di record, quindi la sensitività globale è quanto cambia la funzione q calcolata su qualsiasi due record diversi. Questo fa capire che questa sensitività globale sia alta, se prendo qualsiasi possibile record è possibile avere una variazione molto grande per q proprio per cui il meccanismo sarà poco accurato.

8.5 Machine Learning and Differential Privacy

Il problema è capire come applicare la differential privacy ad algoritmi poco più complessi o in particolare ad algoritmi di Machine Learning.

Cosa vuol dire Machine Learning Privato?

- si prendono dei dati, training set
- l'obiettivo è trovare un modello che meglio descrive meglio i dati iniziali e questo modello viene trovato tramite un algoritmo
- il modello dipende dal task, ovvero dal compito che vogliamo risolvere con questo algoritmi di ML. Pensiamo al più comune algoritmo di ML, ****l'algoritmo di classificazione.**** L'obiettivo è insegnare al computer come classificare dei dati, cioè il training set contiene tanti record etichettati, l'obiettivo è trovare un modello ovvero una funzione che preso ogni record non etichettato l'algoritmo ti sa dire qual è la sua etichetta.
- il computer deve essere in grado di capire la funzione che collega i record alle etichette, Ovviamente viene considerato una famiglia di funzioni, dove tutte hanno la stessa struttura ma che dipendono da dei parametri θ e quindi scegliere il modello adatto significa scegliere il miglior parametro θ , ovvero quello che risolve meglio il task, quindi quello che associa meglio le etichette ai dati.

L'obiettivo del ML privato è allenare i modelli (quindi trovare i parametri θ che individuano il modello migliore) in maniera differenzialmente privata, come si fa? Si usa un algoritmo che prende come input i dati di training e restituisce la migliore funzione, presa dall'insieme delle funzioni che stiamo considerando, quindi il parametro θ migliore.

- abbiamo la funzione A che prende il dataset e restituisce θ (miglior parametro possibile)
- il modello stesso è una funzione f_θ che prenderà una volta scelto il θ migliore, un nuovo record e restituirà ad esempio una classe. Abbiamo due funzioni

1. funzione allenamento

2. funzione modello stesso

Fare ML differenzialmente privata significa allenare in maniera privata. La funzione che vogliamo calcolare in maniera differenzialmente privata è A , non il modello stesso. Questo vuol dire che noi vogliamo far sì che Dal risultato dell'allenamento non si possa capire se un particolare record era presente o no all'interno del training set. Dopodiché

- se andremo a dare dei nuovi record/dati al modello allenato e questo ci restituirà un risultato, quello non sarà differenzialmente privato. Non è detto che dal risultato del modello non riusciamo a capire quale sia il dato che abbiamo dato in input. In altri termini noi vogliamo che la funzione A che diamo in allenamento, rispetti la DP, ma non che la f rispetti la local DP

Fare **ML privato** significa allenare in maniera privata il modello e non far capire a chi riceve il modello se un particolare record c'era o non c'era all'interno del training set. Si aggiungerà del rumore stocastico in fase di allenamento del modello e quindi potremmo pensare che se aggiunto questo rumore, il modello potrebbe non imparare bene. In verità la

- DP e ML non sono in contrasto l'uno con l'altro, non spingono in direzioni opposte. Lo scopo della DP è quello di imparare qualcosa dai dati a disposizione senza dipendere troppo pesantemente dal singolo dato.

- vogliamo trovare un risultato di una query che descriva la popolazione da cui i dati sono estratti ma che non vari troppo se aggiungiamo o togliamo ogni singolo record.
- In realtà anche il ML pure. Uno dei problemi che riguarda il ML è evitare l'overfitting ovvero il modello ottenuto dipenda troppo pesantemente dai dati cui è stato ottenuto. Potremmo quindi trovare dei modelli che funzionino benissimo con i dati a disposizione, ma poi quando diamo dei nuovi dati potrebbe non funzionare bene.
- Dobbiamo trovare modelli che siano in grado di funzionare anche su altri dati.

Le due tecniche hanno dei punti in comune. Infatti il ML privato ha avuto un grande successo.

L'obiettivo è calcolare la funzione A quella che prende in input un training set e restituisce come output θ (parametro del modello finale) in maniera differenzialmente privata. θ è un vettore di numeri

- A è una funzione numerica e il modo più facile per distorcere una funzione numerica è utilizzare Laplace. Invece di calcolare θ (parametro ottimale) potremmo calcolare θ e poi aggiungere del rumore estratto da una distribuzione di Laplace centrata in zero e con parametri , con forma che dipende dalla sensitività globale GS della funzione A/ϵ che è livello di privacy che vogliamo rispettare
- Problema è **conoscere la sensitività globale della funzione A^{**} , cioè sapere quanto cambiano i parametri che stiamo calcolando del modello se aggiungo o tolgo un record dal training set. Immaginate una rete neurale, riuscire a capire quanto cambiano i parametri per colpa di un singolo record è impossibile e quindi questa GS non possiamo calcolarla.

Abbiamo un metodo per distorcere la funzione allenamento ma non possiamo usarlo in quanto non siamo in grado di calcolare la sensitività globale. Bisogna inventarsi altri metodi.

- altro metodo che non possiamo usare è il seguente. A ha l'obiettivo di scegliere il migliore θ tra tutti i θ possibili, ovvero parametro che massimizzi una certa funzione obiettivo (loss function) L . Questo è il problema della selezione privata vista con il meccanismo esponenziale, in cui volevamo trovare tra tutti i possibili risultati quello che massimizzava una funzione di utilità.

Ci sono due problemi in riferimento a questo metodo, problemi che rendono inutilizzabile questo metodo.

1. l'insieme di tutti i possibili parametri è R^d , dove d è la dimensionalità del parametro θ . Avendo infiniti parametri θ non siamo in grado di calcolare per ogni singolo parametro la funzione L e associarli la probabilità proporzionale ad L . C'è un problema di tempo, di complessità;
2. per usare il meccanismo esponenziale è quello di poter calcolare la GS della funzione L e questa non siamo in grado di calcolarla e quindi non siamo in grado di utilizzare di conseguenza il meccanismo esponenziale.

Quello appena descritto e che non funziona tanto bene si chiama **Output perturbation**, l'idea è di voler perturbare, aggiungere rumore al modello stesso, a θ . Ci sono due strategie possibili:

Input-perturbation. Aggiungere del rumore direttamente nell'input. Corrisponde allo scenario interattivo visto all'inizio del capitolo. L'aggiunta del rumore nell'algoritmo stesso non funziona tanto bene. Principalmente per due motivi

1. potrebbe richiedere tantissimi iterazioni e quindi alla fine andremo a rispettare poca privacy. Questo perchè distorcere ogni singola iterazioni rispetta un livello ϵ di privacy e quindi se faccio ad esempio 1000 iterazioni, rispetterò 1000 ϵ DP e quindi rispetto troppo poca privacy;
2. potrei scegliere anche a priori il livello di privacy che voglio rispettare e quindi il numero di iterazioni che farò e quindi spendere per ogni iterazioni la privacy complessiva divisa il numero di iterazioni. Ma anche in questo caso se il numero scelto delle iterazioni fosse troppo alto, allora il numero di privacy budget da attribuire ad una singola iterazione sarà molto piccolo e quindi garantiremo troppa poca privacy.

Una possibile soluzione potrebbe essere quella di non inserire rumore nell'algoritmo e distorcere prima i dati nel training set con meccanismi LDP visti in precedenza. Si distorcono i dati e poi si applica l'algoritmo.

In-process Mechanism, come si fa ad arrivare dal training set al modello, esiste un algoritmo iterativi che lo fa, dove attribuiscono un valore a θ , migliorando di passo in passo, fino a quando non ottengono un θ migliore. L'algoritmo nel suo complesso è molto complesso, quindi non siamo tanto in grado di capire la sensitività nel suo complesso, ma se lo andiamo a spezzettare in tanti funzioni più semplici, siamo in grado di calcolare. Quindi per esempio potremmo dividere l'algoritmo nelle sue iterazioni, dove singola iterazione è una funzione più semplice per la quale siamo in grado di applicare la sensitività e quindi applicare uno dei meccanismi noti ad ogni singola iterazione. I teoremi di composizione, poi ci dicono, se stiamo stati bravi nell'applicare bene la DP (ogni volta che l'algoritmo accedeva ai dati segreti) che anche l'algoritmo complessivo rispetterà la DP

8.5.1 L'algoritmo DP-k-means (input perturbation)

È un esempio di meccanismo di algoritmo differenzialmente privato. Problema del clustering dove l'algoritmo da voler distorcere è il k-means. Il problema del clustering è il seguente:

- preso un insieme di dati (insieme di punti in uno spazio), trovare k gruppi in modo da rappresentare questi punti. Dove punti abbastanza simili finiranno all'interno di uno stesso cluster e punti distanti apparterranno a cluster diversi
- il **k-means** assegna ogni punto ad ogni cluster in base alla vicinanza a dei punti specifici nello spazio definiti come **centroidi** che rappresentano i singoli cluster.

Quindi dobbiamo trovare k centroidi che meglio descrivano i cluster

- inoltre vogliamo che la distanza di ogni singolo punto rispetto al centroide più vicino sia minimizzata.

L'obiettivo è trovare i **centroidi in maniera differenzialmente privata**. Per trovare i centroidi, l'algoritmo più famoso è quello di **Lloyd**.

1. algoritmo iterativo, dove ad ogni iterazioni prende i dati in input, i centroidi calcolati nell'iterazione precedente e fa questi due passi
 - a. assegna ogni singolo dato al centroide più vicino, quindi crea i cluster e sta considerando i centroidi calcolati nell'iterazione precedente
 - b. calcola i nuovi centroidi come **media dei punti all'interno dello stesso cluster**

Iterata fino a quando non raggiungiamo una **condizione di stop** (centroide che non si muove più o si muove poco rispetto ad una soglia che abbiamo definito noi progettisti) o non si trovano i centroidi ottimali. Sono state proposte due idee che rendono questo algoritmo differenzialmente privato.

1. consiste nell'aggiungere del rumore di Laplace nella fase di calcolo di nuovi centroidi, quindi andremo a calcolare una media distorta. Nel dettaglio.
 - a. insieme di tutti i dati, dove ogni record (punto) appartiene ad un particolare cluster
 - b. calcoliamo nuovi centroidi a partire dal cluster appena ottenuto facendo la media di tutti i punti all'interno del cluster
 - c. per renderlo in maniera privata la media viene calcolata rispetto la ϵ -DP utilizzando il meccanismo di Laplace, dove le singole coordinate dei k centroidi rispetteranno ϵ -DP
 - d. quando vado ad applicare le k coordinate di tutti i centroidi, rispetteremo la ϵ -DP, in quanto queste funzioni media agiscono su sezioni disgiunte del dataset e quindi stiamo applicando in parallelo tante volte la funzione media e per il **teorema di composizione in parallelo** l'iterazione complessiva rispetto la ϵ -DP.

L'algoritmo complessivo rispettare la $(n*\epsilon)$ -DP. A differenza di quello che succede nell'algoritmo di Loid, dove noi abbiamo un criterio di stop che ci dice quando fermarci, qui dobbiamo conoscere a priori il numero di iterazioni che faremo, perchè avremo un privacy budget totale da usare e quindi per sapere quanto privacy budget usare dobbiamo sapere il numero di iterazioni n . L'unica operazione che facciamo in più rispetto al normale algoritmo è quella di calcolare le medie attraverso il meccanismo di Laplace. Quindi adesso vedremo come andare a calcolare la media in modo differenzialmente privata

Calcolo delle medie in modo differenzialmente privato 1:10:00(minutaggio lezione)

Quello appena visto è un modo per distorcere l'algoritmo.

- prendiamo i dati li teniamo segreti applichiamo una versione randomizzata dell'algoritmo di Lloyd dove aggiungiamo del rumore per il calcolo dei centroidi e otteniamo come output dei centroidi distorti
- metodo che funziona ma aggiunge un po troppo rumore, dove il centroidi si sposta e quindi i cluster che otteniamo sono non molto precisi, dovuto al fatto che servono diverse iterazioni. Con poche iterazioni funziona bene, quando diventano tante c'è bisogno di aggiungere rumore ad ogni singola iterazioni e quindi si rischia di avere un risultato impreciso.

DP-k-means (input perturbation)

Metodo proposto che si basa sulla perturbazione dell'input, dove il rumore non viene più aggiunto nell'algoritmo stesso, ma nell'input

- dopodichè viene applicato algoritmo normale senza bisogno di distorcerlo ulteriormente e il risultato complessivo, ovvero i centroidi rispetteranno il teorema di DP grazie al teorema di proc-processing. L'algoritmo non guarda più i veri dati ma una versione distorta di questi.

Il rilascio privato dei dati avviene così

1. l'idea è dividere lo spazio in m celle.
2. sovrapponiamo la griglia sui dati e come risultato si avrà che ogni punto andrà a finire in una cella della griglia
3. l'idea è quella di approssimare ogni punto in una cella con il centro della cella. In questo modo distorciamo un po i dati e come risultato avremo un dataset in cui i punti possibili sono soltanto i centri delle m celle della griglia, dove ogni singolo centro di una cella comparirà tante volte quanti sono i punti in quella cella.

Le coordinate al centro della griglia non dipendono dai dati, ciò che dipende dai dati è quanti punti vengono approssimati con quel valore li . Quello che bisogna calcolare in maniera differenzialmente privata è il conteggio del numero di punti che cadono in una cella. Questo viene fatto con il meccanismo di Laplace, dove le funzioni conteggio sono le classifiche funzioni che si applicano con il meccanismo di Laplace. Questo perché hanno una sensibilità molto bassa e quindi alla fine si riesce a dare una stima abbastanza precisa del numero di punti all'interno di una singola cella e se la cella è sufficientemente piccola, l'approssimazione del punto con il centro della cella non è male. Si è visto spesso che questo metodo, ovvero l'aggiunta del rumore all'input, funziona meglio dell'altro.

Questo è un esempio di algoritmo di ML privato. In realtà c'è ne sono un fottio, so asaj, che vanno da alberi decisionali a deep learning. Vabbè leggetevi la slide.

8.6 Limitation and Critical Issues

Verranno elencati una serie di problemi legati alla differential privacy

1. Come **scegliere un buon valore** di ϵ
2. **problema legato alla sensibilità globale**
3. **controllo del numero di iterazioni**, se ne ho tante aggiungo più rumore e questo equivale a meno privacy.
4. **problema di convergenza**, dimostrato come algoritmi iterativi di solito convergono ad un certo risultato, questo quando non aggiungiamo rumore. Appena aggiungiamo rumore questa dimostrazione di convergenza crolla, quindi molto spesso l'algoritmo non converge più.
5. **trovarci con un risultato che va fuori dal dominio**. Mettiamo di avere una query q numerica che restituisce un numero tra 0 e 1. Possiamo usare Laplace per distorcere. L'aggiunta del rumore comunque non deve sfiorare 1 in quanto il risultato ottenuto non avrebbe nessun senso. Quindi occorre capire come comportarci in questo caso. Ci sono tante possibilità.
 - a. si ripete il meccanismo fintanto che non trovo un numero valido
 - b. prendere il risultato ottenuto e proiettarlo all'interno del dominio. Il valore ottenuto dopo l'aggiunta del rumore viene proiettato e diventa 1 nel caso è superiore a 0, 0 nel caso sia minore di 0. Questa operazione è post-processing, perché non accediamo più ai dati ma stiamo modificando il risultato di una query, non consuma DP.
6. **scelta di parametri o hyperparametri**. Spesso gli algoritmi dipendono da dei parametri. Per poter applicare l'algoritmo a dei dati, occorre scegliere una configurazione per settare opportunamente quei parametri. Come si fa a sceglierli? Si potrebbe fare un'analisi dei dati per capire quale sia il valor migliore per i parametri, oppure applicare tante volte l'algoritmo con configurazioni diverse di parametri e scegliere la configurazione che ci dà il risultato migliore. Purtroppo in un setting privato dove non abbiamo accesso ai dati, quello appena detto non può essere fatto, oppure viene fatto applicando la DP, non possiamo accedere direttamente ai dati. Possiamo chiedere al curatore di eseguire l'algoritmo con tanti parametri diversi e scegliere il risultato migliore, ma vuol dire che ogni singola volta che l'algoritmo viene ripetuta una parte del privacy budget viene consumata e questo fa peggiorare tantissimi l' ϵ budget. Allo stesso modo le analisi esplorative per scoprire i valori migliori non possono essere fatte, o meglio potrebbero essere fatte ma ciò implica a consumare privacy budget. L'idea è **scegliere un algoritmo che non ha parametri o uno che ne abbiamo pochi**.

8.6.1 Come scegliere ϵ

La presenza di questo parametro nella definizione di differential privacy è una fortuna. Ci dà un modo per capire il livello di privacy che stiamo rispettando e rende anche il meccanismo di differential privacy più flessibile. In certi casi quando serve tanta privacy sceglieremo un ϵ più piccolo, in altri casi più grande. Oltretutto, misurando la quantità di privacy rispettata dal meccanismo ci dà un metodo per confrontare due diversi meccanismi. Abbiamo due algoritmi dove uno rispetta la ϵ privacy e il secondo la ϵ' privacy, quale scegliamo? Naturalmente quello che rispetta di più.

- questa risposta è da prendere con le pinze.

Se uno dei due rispetta più privacy ma quello scelto distrugge completamente i risultati, non è detto che sia l'algoritmo migliore. C'è sempre un trade-off tra accuratezza e dati. Di questo trade-off dobbiamo tener conto quando scegliamo il parametro.

Abbiamo detto più piccolo è ϵ migliore sono le garanzie di privacy, ma anche più piccolo è più alta è la distorsione. Quindi alle volte capita che si scelga un ϵ grande per avere un meccanismo più accurato. Problema

- quando ϵ è piccolo, quindi più vicino allo 0 il significato della definizione è chiara, dove il rapporto tra le due probabilità sia poco più di ϵ .
- quando ϵ diventa grande l'approssimazione e^ϵ all'incirca uguale a 1 non vale più, non capiamo bene cosa vuol dire. Consideriamo $\epsilon = 8$, quindi il rapporto tra le due probabilità deve essere $\leq e^8$ all'incirca = 2981.
- stiamo chiedendo che la probabilità del dataset D sia al massimo 2981 più grande del dataset D'. La garanzia di privacy non è altissima

Mettiamo che ci sia un meccanismo che dia come risultato r, questo risultato, se il dataset segreto è D ha probabilità di essere estratto pari ad 1, quindi quando il dataset è D sempre il risultato che otteniamo è r, altrimenti caso contrario è 0,0003, probabilità quasi nulla. Non abbiamo più il dubbio che il dataset segreto sia D, nonostante questo rispettiamo la definizione di 8 ϵ privacy. **HA SENSO TUTTO CIO?**

- viene utile sapere cosa fanno gli altri e come hanno svolto il compito e quindi sapere cosa hanno fatto gli altri è utile. Usare un registro dove viene scritta conoscenza pratica, e quindi scegliere epsilon. ϵ cambia tantissimo a seconda dei dati che si usano.

8.6.2 Problema legato alla sensitività globale (GS)

Ci sono una serie di problemi legati alla sensitività globale, ovvero capire quanto rumore aggiungere per sporcare il risultato di una funzione bisogna capire quanto quella funzione varia tra dataset adiacenti. Questa misura di quanto vale questa funzione è la sensitività globale. Il problema che la sensitività globale è una proprietà della funzione che vogliamo distorcere e non abbiamo nessun trucchetto per abbassare questa sensitività. Se è alta dobbiamo poter aggiungere tanto rumore, e alcune volte le funzioni non sono adatte per essere distorte perché richiedono tantissimo rumore e questo implica dare come risultato, un risultato appunto che sia molto distorto/impreciso.

Come procedere in questi casi?

In alcuni casi la GS è infinita, non riusciamo a trovare una soglia massima della variazione della funzione q, potrebbe essere sempre più grande rispetto ad una soglia che noi scegliamo. C'è qualche strategia per non usare la GS e usare qualcos'altro? Naturalmente sì, si può provare ad usare la **sensitività locale della funzione (LS)**

- dove X è il dataset segreto, quelli adiacenti a lui sono quelli vicini che differiscono di un solo record
- quando noi usiamo il meccanismo e diamo il risultato, la verità è che più o meno dal risultato si riesce a capire dove si trova il dataset
 - risultati alti e questo implica nel sapere che quel particolare risultato si trova o nel dataset x oppure in quelli adiacenti
 - altrimenti, quindi risultati molto bassi e quindi dataset lontani.
- a noi interessa sola la parte x . Quando decidiamo la quantità di rumore noi quello che facciamo è guardare la GS che ci dice quanto varia la funzione su ogni coppia possibile di dataset adiacenti e quindi potrebbe succedere che due dataset adiacenti sono in realtà due dataset lontanissimi (in rosso su slide) dal vero dataset segreto e se considerassimo questi due dataset adiacenti, la funzione cambia tantissimo (GS molto alta e siamo obbligati ad aggiungere molto rumore).
- in verità per confondere il dataset x con uno suo vicino basterebbe molto meno rumore, perché localmente la variazione di q è più piccola. Aggiungendo meno rumore garantiremmo la confusione tra x e x' , ma per colpa dell'altra coppia dobbiamo aggiungere del rumore. L'idea è quindi di utilizzare non più la GS ma la **sensitività locale**.
 - **GS**, massima variazione di q fra tutte le possibili coppie di dataset adiacenti
 - **LS**, funzione che dipende dalla query e dal vero dataset segreto, quindi è la variazione massima di q tra tutte le coppie dove uno dei due dataset della coppia è il vero dataset segreto D . Ovviamente è molto più bassa di quella globale, al massimo uguale.
 - sicuramente quindi se usiamo LAPLACE aggiungeremo meno rumore ma purtroppo un meccanismo di LAPLACE che considera la LS non rispetta la differential privacy e l'idea è la seguente
 - se usassimo Laplace con forma della distribuzione del rumore che dipende dalla sensitività locale dovremmo, fissare σ (forma da attribuire alla distribuzione del rumore) centrare la distribuzione nel vero risultato $q(D)$ e estrarre il risultato da questa distribuzione di probabilità (curva rossa in un caso)
 - prendendo un dataset adiacente D' otterremo una curva nera, stessa forma, e centrata in altro punto.
 - La distanza tra le due curve è piccola perché il rumore è sufficientemente grande da farci confondere da D e D'
 - La ragione per cui questo meccanismo non riserva la DP è x_k quando abbiamo usato questo meccanismo e quindi quando abbiamo scelto la forma della curva è che abbiamo anche dichiarato la LS del dataset D , ma questa cambia a seconda del dataset e quindi potrebbe succedere che tra due dataset D e D' in uno otteniamo una LS e in un'altra ne otterremo un'altra (grande o piccola). Quindi non è la distanza tra le due distribuzioni che non va bene, ma il fatto che nel dire quale distribuzione usiamo diciamo anche quale sia il dataset segreto comunque diamo un'informazione che permette di identificare quale sia il dataset segreto.
- altra idea è non fissare la forma, cioè ogni volta scelgo la forma della distribuzione basandomi sul dataset che ottengo, (forma in base su quale dataset applico il meccanismo). Nemmeno questo rispetta la DP, una delle due distribuzioni aumenta e quindi sono diverse e questo implica aumento di distanza tra le due.

Idea è non usare questa LS, il **Propose-Test Release** permette di diminuire la quantità di rumore

Propose-Test Release

- la LS va bene come distanza tra curve ma non possiamo dichiararla perchè ci dice quale è il dataset segreto, quindi non la dichiariamo e scegliamo un upper-bound, valore che sia più grande della LS ma che non dipenda dal dataset, ma comunque più piccola rispetto alla GS in modo da diminuire il rumore.
1. analista che propone una soglia, io accetto il risultato solo se tu me lo calcoli con questo valore della distribuzione di Laplace, in modo tale che io analista sappia che non c'è troppo rumore
 2. il curatore del dataset sa che il meccanismo rispetta la DP solo se il b è maggiore della LS
 - a. se superato il test utilizza il meccanismo di Laplace scalato su questo risultato b
 - b. altrimenti, dice non posso darti il risultato perchè altrimenti non infrangerei la DP.

Anche questo non rispetta la differential-privacy e la ragione è la seguente. Il problema è che noi consideriamo sempre due dataset adiacenti D e D' , dove uno ha $LS < b$ e l'altro maggiore, quindi per due dataset adiacenti una volta si ottiene il risultato e un'altra volta no. Idea finale è sempre di fare il test in maniera differenzialmente privata aggiungendo del rumore all'interno del test. Finalmente con questo modo di rendere privato il test, otteniamo un meccanismo basato su un upper bound della LS che rispetta la DP ma la (ϵ, δ) -**differential privacy**.

8.6.3 Esempi di applicazioni reali basati sulla Differential Privacy

- Google, Apple (usa la local), Uber, Microsoft Windows, 2020 US Census dati del censimento ma che rispettando la differential privacy, dove il valore di ϵ scelto è 17.4.
- ricordate questo punto fondamentale **fare errori non è una cosa strana**

Chapter 9

Privacy in distributed system

Capitolo diviso in due parti

1. introduzione ai metodi per garantire la pp nei sistemi distribuiti quindi ambienti dove abbiamo già in qualche modo una necessità di privacy ulteriore perchè abbiamo nodi diversi che partecipano allo stesso sistema informativo distribuito che curano dati e non vogliono che siano distribuiti/condivisi con altri nodi del sistema della rete. I metodi utilizzati sono tantissimi. Noi studieremo le storiche tecniche utilizzate
2. parleremo del federel learning che nasce con in mente alcune garanzie di privacy ma comunque deve essere migliorato per poter effettivamente garantire la privacy delle persone che hanno condiviso dati in maniera distribuita nel sistema.

9.1 Definizioni e proprietà principali

9.1.1 Distributed Data Analysis: The Standard Method

Siamo in un contesto dove vogliamo analizzare dei dati (analisi statistica o qualcosa di più complesso come l'estrazione di un modello di ML). L'obiettivo è analizzare dati, costruire modelli. Tipicamente quello che succede nelle grande medie realtà e quello di trovarci in un sistema dove nodi raccolgono un certo numero di dati da parte di utenti (supermercati che raccolgono dati di transazione nei supermarket da parte dei clienti). Per qualche motivo vorremmo garantire la privacy degli utenti e non permettere ai diversi nodi della rete di accedere a dati contenuti in altri noi. Tipicamente l'approccio utilizzato era l'approccio basato sui **datawarehouse** (studiato fino a 10 anni fa).

- abbiamo database locali che raccolgono dati (**local data**)
- dati popolano i **data warehouse**, che raccoglie dati e permette di rappresentare questi dati sotto diversi dimensioni in modo da fare diversi analisi per estrarre informazioni statistiche e anche eventualmente pattern e modelli
- il modulo eventuale di **data analysis** di ML si interfacciava direttamente con il data warehouse

Si nota come l'approccio distribuito viene meno. I dati locali, che comunque rimangono localmente nei vari database, vanno ad alimentare un data warehouse che però è centralizzato e i dati dall'essere locali si trovano in una posizione unica, ovvero in questo database centralizzato che è il data warehouse. Questo non garantisce **ne privacy ne performance**, in quanto tutto il carico è su unico nodo.

1. grossa catena di supermercati dove tutti i dati delle transazioni arrivano in un data warehouse generale. Nu casin

2. problemi di connettività, ci sono grossi flussi di dati che circolano tra nodi locali e il data W
3. problemi legati all'eterogeneità, specialmente in un sistema dove i diversi nodi sono strutturalmente diversi fra loro (ovvero raccolgono informazione diversa, o chiamati semplicemente in modo diverso), la fase di data fusion (fusione di dati) in un unico datawarehouse potrebbe essere laboriosa e richiedere lavoro eccessivo e provocare un overhead sui sistemi
4. problemi di privacy

In generale quindi diciamo che questo metodo non funzionava

9.1.2 Private Distributed Data Analysis

Una soluzione che ovvia ai problemi precedentemente presentati potrebbe essere la seguente.

- eliminare il data warehouse e analizzare direttamente i dati dalle fonti locali. Quindi avremo delle frecce che partono dal data analysis e dirette verso le varie fonti locali
- comunque tra i database locale e il nodo centrale che si occupa del data analysis, deve scambiare informazioni con i database e scambia i dati e quindi i database locali trasferiscono dati direttamente al nodo centrale (server centrale) dove questi li analizza direttamente senza avvalersi di un datawarehouse
- comunque non cambia nulla, abbiamo eliminato la parte di datawarehouse ma comunque è tutto nel nodo centrale che si occupa di ML e Data Mining.

Cosa potrebbe funzionare?

9.1.3 Private Distributed Mining

Declinato in tantissimi modi

- abbiamo i database locali che hanno anch'essi una componente che si occupa di fare la cosiddetta **local data analysis**. I dati sui singoli database locali vengono analizzati/trattati da dei moduli che accedano direttamente ai vari dati locali.
- i risultati prodotto dai vari singoli moduli vengono condivisi con un server centrale e questo combina i risultati delle varie analisi per produrre dei risultati combinati che siano validi globalmente
- molto meglio, in quanto l'analisi viene fatta localmente e quindi su una mole di dati più trattabile e questi non vengono scambiati con direttamente con un nodo centrale. Vengono scambiati i risultati intermedi dell'analisi che possono essere pattern o modelli estratti da un singolo nodo.

Parte importante da ricordare è che dobbiamo sempre superare la concessione di avere un nodo centrale che ha accesso a tutti i dati sia per motivi di performance che privacy.

Perché c'è bisogno di effettuare analisi dei dati in maniera privacy-preserving in maniera distribuita. Capire la necessità di questi ambienti più distribuiti

Immaginate il CDC che cerca di capire quando si sta verificando lo scoppio di un'epidemia.

- il CDC ha accesso ai dati singoli dei vari Istituti Nazionali che a loro volta hanno accesso ai singoli ospedali

- per poter capire quando si sta verificando lo scoppio di un'epidemia si può aver accesso ai dati assicurativi, ospedali, medici, ecc ecc
- non tutti i centri medici possono rilasciare i dati così come sono, naturalmente perché violerebbero la privacy dell'individuo, quindi viene necessario da parte di enti sovra Nazionali di accedere a informazioni distribuite in maniera **sicura e privata**

Altre tipologie di necessità legate al mondo industriale che riguardano le collaborazioni tra aziende

- le aziende non vogliano svelare i processi chimici ma vorrebbero comunque dire quelle che sono le prassi da evitare
- quindi, condividere informazioni che permettono d'individuare fornitori di reagenti che hanno un alto tasso di fallimento.
- tutto preservando i segreti, ovvero pratiche che favoriscono un'azienda da un'altra dal punto di vista della competizione

C'è bisogno di condividere dati in modo da permettere ad altre aziende di non produrre prodotti inutilizzabile.

Primo problema di privacy e il secondo di confidenzialità. I metodi che vedremo (Pensa e Polato) vengono usati sia per **problemi legati alla privacy** (ospedali) che per **problemi di confidenzialità** (segreti industriali)

9.1.4 Classe di soluzioni

Tipiche soluzioni nei sistemi distribuiti per garantire **privacy e confidenzialità**. Di queste e tre che andremo a presentare noi andremo a vedere solo la **Data Separation**

- **data obfuscation**, i dati vengono nascosti, quindi resi rumorosi da parte dei singoli nodi centrali e quindi il nodo o i nodi che si preoccupano di effettuare analisi e ML non hanno mai accesso ai dati reali ma accessi a dati sintetici o offuscati attraverso varie tecniche come la differential privacy
- **summarization**, si estraggono delle sinossi di dati (statistiche di vario livello) oppure dei riassunti di questi dati (attraverso l'utilizzo di tecniche come il clustering) dove non vengono condivisi i dati reali ma sinossi di dati
- **data separation**, in cui i dati rimangono nei nodi fidati.
 - l'acquirente del supermercato, fornisce dati al supermercato stesso perché si fida a fine di profilazione, ma comunque non vogliamo che lo stesso supermercato condivida con altri i dati privati con altri supermercati della catena. MI fido soltanto di un nodo, in modo che questo nodo abbia accesso ai miei dati e tutti gli altri no
 - l'analisi dei dati deve essere fatta in **maniera distribuita**, ovvero senza che gli altri nodi abbiano accessi a dati di altri nodi della rete

9.1.5 La Data Separation

- solo le parti fidati possono vedere i dati
- i dati sono mantenuti dal possessore/creatore. caso tipico del possessore quando produciamo dati su uno smartphone, anziché condividere dati facciamo in modo che le analisi siano fatte in maniera centralizzata senza che i dati fuoriescano dal dispositivo.

- ci possono anche essere diffusioni di dati limitate verso terze parti
- oppure esserci delle operazioni di analisi o trading che sono soltanto messe in atto da parte fidate dove queste verranno anche definiti

Problemi con la data separation

- capire se le terzi parti sono nelle condizioni di poter effettuare analisi
- capire se i risultati dell'analisi stessa effettuata a livello locale sia effettivamente private, potrebbe anche non capitare, in effetti in alcuni casi potrebbe non essere così

Tipologie di soluzioni che possono individuare in questo settore

- soluzioni che va sotto il nome di **Secure Multiparty Computation**, soluzione generale utilizzata al nell'ambito del federated learning (soluzione presentata da Pensa)
- **federated learning**, accezione ulteriore sicuro e privato (soluzione presentata da Polato)

9.2 Secure Multiparty Computation

Considerate che multiparty molto spesso ha l'accezione di 2-party. Nel senso che molti degli approcci presentati come multiparty funzionano molto bene quando le parti coinvolte sono due, poi bisogna vedere quando le parti sono più di due, questo dovuto a problemi legati all'overhead, quindi problemi legati ad una parte algoritmica legata alla complessità che non è per niente banale.

Noi parleremo di multiparty ma comunque tutti gli approcci che presenteremo funzionano quando le parti coinvolte non sono tantissime.

- l'idea è quella di calcolare una funzione basata su input che arrivano da diversi nodi, dove gli input sono posseduti da nodi non condivisi, quindi i singoli nodi non vogliono condividere i loro input con gli altri nodi
- abbiamo proprio una suddivisione degli input sui vari nodi che partecipando al sistema
 - un problema noto è quello del **milionario di Yao**
 - * due milionari che discutono tra loro perché vogliono stabilire chi è il più ricco tra i due ma in qualche modo non vogliono rivelare la loro ricchezza
 - * vogliono trovare un protocollo per capire chi è il più ricco senza che nessuno dei due sappia quale sia la ricchezza dell'altra

Questa è la base per introdurre il **secure multiparty computation** e essenzialmente il modo con cui è stato affrontato è rappresentando questa funzione (massimo della ricchezza) attraverso un circuito, dove le varie porte logiche che compongono questo circuito calcolano i risultati in maniera **sicura** e **privata**

Potremmo ampliare questo problema ad n milionari, ma questo complica notevolmente il circuito

9.2.1 Il problema del Milionario di Yao

- abbiamo un circuito diviso in due, in cui le due parti non comunicano
- ogni parte ha i suoi input e il circuito dovrà calcolare una funzione degli input delle due parti

- parte A abbia come input due bit a_1, a_2 , lo stesso per B b_1, b_2
 - aggiunge un valore randomico agli input e si condividono gli input con l'altra parte.
 - sulla parte di A avremo a_1 e b_1 e sulla parte di B avremo a_2, b_2 , naturalmente tutti scambiati con l'aggiunta di rumore
- si calcolano la condivisione degli output c_1, c_2 relativi alle singole parti, attraverso un circuito, che può essere un **XOR** oppure con le porte **AND** dove in questo caso particolare dobbiamo utilizzare una tabella di verità dove per esempio quando i valori di a_2, b_2 abbiamo un diverso tipo di output e quindi una diversa funzione che permette di calcolare un valore diverso di c .

C'è una condivisione ed entra in gioco una qualche forma di **criptografia**. Per fare in modo che gli input possano essere condivisi in maniera sicura si utilizza il protocollo di **Oblivious Transfer**.

9.2.2 Il protocollo Oblivious Transfer

- A ha i suoi input a_i
- B fa le scelte
- A non conosce le scelte di B e quest'ultimo può vedere soltanto il valore scelto

C'è una parte di crittografia che non trattiamo. La cosa importante è che sappiamo come funzionano il protocollo per problemi di ML

- A manda la chiave pubblica p a B
- B sceglie quattro valori casuali b_1, b_2, b_3, b_4 e cifra uno soltanto di questi quattro valori con la chiave p . La scelta ricade su uno solo dei quattro valori e la cifratura avviene con la chiave pubblica p
- B manda tutti questi valori ad A, dove solo uno è cifrato con la chiave pubblica e gli altri e tre no.
- A non sa quale sia il valore cifrato e cerca comunque di decrittare tutti i valori ricevuti da B con la chiave privata (che ovviamente A possiede) e manda i risultati a B.
 - manda i risultati $c_i = a_i \oplus e(f_p^{-1}(b_i))$, dopo $\oplus$ c'è la funzione di decifratura basata sulla chiave pubblica e sui valori di b_1 inviati da B
 - ricordate che A conosce la chiave privata, B conosce solo la chiave pubblica p e conosce anche quale dei quattro valori è stato scelto. A questo punto B, da come output soltanto dei 4 c che riceve da A da come output soltanto quello che sa essere quello reale, ovvero quello per cui ha usato la chiave pubblica per cifrare uno dei quattro valori, quindi decifra soltanto il valore di c relativo all'input b_i scelto utilizzando la chiave pubblica.
- così facendo il risultato di B può essere decifrato da A in modo da capire qual è il risultato finale della funzione logica che vogliamo calcolare.

Immaginate tutto questo quando le parti coinvolte sono più di due. Adesso dobbiamo capire come poter utilizzare tale protocollo in realtà per esempio per costruire un albero decisionale.

- ricordiamo di voler utilizzare delle funzioni che possano calcolare dei valori output in maniera sicura senza che le varie parti condividano i loro input in maniera chiara con i vari altri nodi della rete.

Un bel esempio di utilizzo di questo protocollo nell'ambito del ML è la costruzione degli **alberi decisionali**.

Costruzione di alberi decisionali

Constestualizziamo il problema

- Partizionalmente orizzontale dove il numero delle parti coinvolte sono essenzialmente due, dove l'estensione a più di due parti è molto complessa
- lo schema del database è condiviso e questo vuol dire che il set di attributi è noto per tutti.
- varie tuple del database appartengono ad ogni nodo, quindi ogni nodo ha le sue tuple che non vuole condividere con gli altri nodi.

Obiettivo è apprendere un albero decisionale e per farlo è utilizzare un algoritmo noto come **ID3**.

ID3 che riesce a soddisfare le definizioni di **Secure Multiparty Computation**.

Costruzione di un albero decisionale avendo a disposizione una tabella dove le prime due colonne sono input e l'ultima è l'output (classe)

- vogliamo capire se alcuni clienti di un supermercato sono clienti occasionali oppure no.
- cerchiamo di capire il problema attraverso attributi di tipo anagrafico

Un albero decisionale è appunto un albero dove ogni nodo esprime una decisione da fare su un certo attributo e poi abbiamo dei **nodi foglia** che contengono un valore di una classe e quelli **intermedi** sono nodi dove avvengono le decisioni.

- in questo caso. Per capire se un cliente è occasionale oppure no, quello che si fa è capire l'età e se è minore di 25 allora la classe è **repeat**
- altrimenti se è maggiore di 25 non abbiamo omogeneità di classe all'interno di queste tuple e quindi siamo costretti a considerare ulteriore attributo in modo da definire il tipo di classe finale

9.2.3 L'algoritmo ID3

Si basa sulla nozione di entropia o information gain (IG). In particolare se il problema è binario le due nozioni sono completamente intercambiabili.

1. IG e entropia vengono calcolati per ogni features.
2. consideriamo l'intero dataset, se ci sono delle tuple che non appartengono alla stessa classe, si va a cercare lo split del dataset in subset utilizzando la features per cui c'è il valore di entropia minore, o viceversa il valore di IG maggiore. Sia entropia che IG vengono calcolati sulla base della classe, per ogni feature, in modo da vedere come sono codistribuite le variabili rispetto alla variabile di classe. Entropia bassa significa che variabile di classe e variabile che stiamo considerando sono similmente codistribuite, altrimenti entropia alta vuol dire che c'è confusione e quindi l'attributo che stiamo considerando non riesce a prendere bene la variabili di classe. Per questo motivo scegliere la variabili per cui l'entropia è minima, o l'IG è massimo
3. si fa un nodo di decisione (sulla base di quell'attributo),
4. a questo punto si vanno a guardare di nuovo i subset creati a partire da questo nodo decisioni, in modo da vedere se le tuple appartengono alla stessa classe o meno. Se appartengono alla stessa classe si va a creare un nodo foglia, altrimenti

5. si ripete l'approccio di creazione di nodi decisionali

Obiettivo è quello di dividere sulla base dell'entropia e IG. L'algoritmo termina quando gli attributi sono finiti o tutti i vari subset sono già omogenei, senza aver bisogno di percorrere tutti gli attributi.

ESTENDERE IN MANIERA SECURE MULTIPARTY

- bisogna fare delle assunzioni, dove in alcuni casi possono essere considerate anche delle limitazioni, ovvero il fatto che protocollo che mostreremo funziona nel cosiddetto modello semi-onesto. Dove il protocollo viene seguito maniera fedele, ma bisogna tenere traccia di alcune computazioni intermedie. **semi-onesto** proprio per questo perchè alcune computazioni intermedie potrebbe risultare essere problematiche se accedute e condivise.
- considereremo soltanto un problema ***2-party**, dove l'estensione a più parti non è così banale e introduce parecchio overhead
- ulteriore assunzione è una limitazione, dove non calcoleremo un algoritmo ID3 esatto. avremo una delta approssimazione di ID3 (**ID3_δ**), dove δ avrà delle implicazioni sull'efficienza sia in termini prestazionali (tempi di calcolo) ma anche di accuracy dell'algoritmo
- altra limitazione è che questo algoritmo funziona solo su attributi di tipo categorico xk dobbiamo calcolare entropia e IG e questa viene possibile calcolarla solo su questi tipi di attributi. Ci sono comunque estensione dell'entropia nell'ambito continuo ma sono essenzialmente poco utilizzabili.

ID3 KEY STEP

- A - set di attributi
 - C - attributi di classe, dove noi considereremo solo classi binarie
 - D - insieme delle istanze
1. si calcola l'entropia o IG di ogni attributi utilizzando il dataset D
 2. si fa lo split del dataset D in subset utilizzando l'attributo dove IG è massimo o entropia minima
 3. si crea un nodo decisionale su quell'attributo li
 4. si fa ricorsione su subset rimanenti utilizzando gli altri attributi. *Si nota come lo stesso attributo viene utilizzato una sola volta, cosa che in altri algoritmi non avviene.*

9.2.4 Rendere Privacy Preserving ID3

Ci sono diversi step (1, 2, 3) da rendere privati.

Step 1: se l'insieme degli attributi A è vuoto, bisogna restituire un nodo foglia con la classe di maggioranza e capire quest'ultimo potrebbe essere lesivo dal punto di vista della privacy, essenzialmente si tratta di fare un conteggio e questo conteggio deve essere fatto in maniera privata. Come viene fatto questo tipo di conteggio e capire quale sia la classe di maggioranza in un insieme di tuple in maniera privacy preserving?

- a. sappiamo che l'insieme degli attributi è pubblico

- b. tramite l'algoritmo di Yao cerchiamo di capire quale sia la **classe di maggioranza**. Abbiamo D che viene splittato in D_1 e D_2 e calcoliamo il numero di tuple di D_1 per cui vale la classe C_1 e il numero di tuple D_1 per cui vale la classe C_2 fino alla classe C_L lo stesso per C_2 . Calcoliamo gli altri input che sono il numero di tuple del set D_2 che hanno la classe C_1 , il numero del set D_2 che hanno la classe C_2 $C_3 \dots C_L$
- c. la funzione che dobbiamo calcolare è quella per cui il numero di tuple $D_1(c_1) + D_2(c_i)$ è la più alta possibile, quindi restituire l'indice i per cui questa somma è la più alta possibile. Dove il calcolo di questa somma viene fatta grazie al protocollo di Yao

Step 2: Consideriamo che D siano transazioni dove tutte hanno lo stesso valore di classe c e dobbiamo restituire un nodo foglia con la classe c_i

- a. rappresentiamo un nodo foglia che ha più di una classe nel set di transazioni con un simbolo diverso da c
- b. le varie parti devono mettere come input o il simbolo fissato (quello per cui sappiamo che le tuple hanno valore diverso di classe) oppure $*c*$ stesso
- c. a questo punto il protocollo viene utilizzato per fare il check delle quality in modo da vedere se tutte le tuple nel nodo hanno la classe c_i oppure no

Quello che rende l'algoritmo approssimato è quello rappresentato dallo Step 3, perché è lo step dove viene calcolata l'entropia, questo perché l'entropia è una funzione che potrebbe rivelare qualcosa del dataset.

Step 3: bisogna trovare l'attributo che classifica meglio il dataset e quindi scegliere l'attributo con entropia minore e IG maggiore, dove questo calcolo deve essere fatto accedendo ai dati, ma noi non vogliamo accedere ai dati, proprio per cui

- a. calcoliamo in maniera sicura $x * \log(x)$
- b. richiamiamo l'algoritmo $ID_{3\delta}$ su tutti gli attributi rimanenti fino a quando non rimane nessun attributo e essenzialmente quello che viene fatta in maniera privata è il calcolo $x * \log(x)$ e questo viene fatto utilizzando la **serie di Taylor** $x * \log(x)$ dove questa serie sono addizioni e le addizioni sono molto belle da trasformare in forma Secure Multiparty perché sono circuiti semplici facile da realizzare.
- c. dato che Taylor è un'approssimazione del calcolo, utilizzando i primi n termini della serie di Taylor avremo un'approssimazione in base a quanti n utilizziamo (naturalmente più n utilizziamo e più overhead introduciamo e quindi più rendiamo complesso l'algoritmo stesso)

In sostanza utilizziamo l'algoritmo di YAO nel calcolo $x * \log(x)$ utilizzando le serie di Taylor

Questi sono gli step dove si utilizzano gli approcci di Secure Multiparty Computation all'interno di ID_3 , ogni volta che si vuole accedere ai dati per capire una funzione dei dati. Algoritmo ha complessità che dipende da δ , dove δ è il numero di elementi che consideriamo nell'approssimazione del problema, la cui precisione dipende da δ e quindi trovare un compromesso per trovare un algoritmo che sia performante e accurato. Questi sono i primi approcci proposti. Comunque la letteratura è ricca di altre proposte di calcoli effettuati in maniera privata e distribuita dove alcuni di questi sono introdotti in slide 24. Complesse da utilizzarle.

9.2.5 Altri approcci complementari

- **function encryption**, permette di imparare una funzione di quello che un certo messaggio cripto sta cifrando. Utilizzata per garantire l'accesso ad alcune specifiche funzioni

sui dati ad alcune terze parti. Quindi con la function encryption possiamo dire, tu terza parte puoi fare la somma su questi dati, tu moltiplicazione, ecc ecc. Dove ogni parte ha accesso ad una funzionalità sui dati cifrati senza rivelare gli input. Utilizzata dai data owners stessi per garantire l'accesso a terze parti su specifiche computazioni fatte sui dati

- **(fully) homomorphic encryption**, permette di effettuare delle computazione in chiaro, ad esempio $c = a + b$, dove c, a, b sono numeri in chiaro, ma in realtà quello che viene fatto è effettuare il calcolo della cifratura di a più la cifratura di b e quella che otteniamo è la cifratura di c quindi ottenere il risultato cifrato di c applicando la somma sui risultati cifrati di a, b e otteniamo il risultato di c , decifrato da chi ha il diritto a decifrarlo

Queste due cose sono abbastanza complesse, nel senso che funzionano abbastanza bene quando le funzioni sono abbastanza semplici, o meglio si riesce a fare qualcosa quando le funzioni come le somme sono abbastanza semplici, in casi più complessi tutto è più complicato, soprattutto non è facile arrivare ad un protocollo che sia completamente fully homomorphic.

- **federated learning**, approccio complementare a quelli che abbiamo visto nel senso che utilizza stessi approcci visti e anche la differential privacy vista precedentemente

Cosa importante da ricordare e dove vengono applicati i protocolli di secure multiparty computation nel caso di ID3 e quali sono le caratteristiche degli approcci secure multiparty computation senza entrare troppo nel dettaglio algoritmico, anche perchè avremmo bisogno anche di un'infarinatura grossa di sicurezza (stendiamo un velo pietoso che abbiamo dei corsi di SICUREZZA che sono la fine del mondo).

9.3 Il Federated Learning

Piccola introduzione veloce di cosa sono le reti neurali, per poi passare al federated learning.

Reti Neurali

Il ML vuole trovare una funzione che dato un input produce un output desiderato. Nell'ambito del learning supervisionato, abbiamo dei dati e un output associato a questi dati e vogliamo imparare una funzione che produce esattamente questo output dato un input. L'obiettivo è imparare il **processo che ha generato quell'output a partire da quell'input**. Ci sono tantissimi esempi di task di questo tipo.

- **task di classificazione di immagini**, classificare la cifra in modo che dica di cosa si tratta
- **next word(s) prediction**, data una parte del testo, predice quello che verrà dopo
- **playing chess**, imparare a giocare a giochi complessi.

(Deep) Artificial Neural Network

Una rete neurale emula il funzionamento del cervello umano, dove l'unità più piccola del cervello è il **neurone** o **perceptrone**, che in ambito ML lo si approssima con una funzione definita in questo modo

- nodo (neurone) dove ci sono degli input (esempi) dove ogni feature di questo esempio entra nel nodo con un relativo peso (w) avviene un qualcosa nel neurone e dopo vi è un output
- quello che avviene all'interno del neurone è una somma pesata dei vari input che poi passano in una **funzione di attivazione** (σ) e poi viene prodotto un output

- questo appena descritto è il blocco fondamentale che descrive una rete neurale, se poi questo blocco viene successivamente impilato in una rete a più livelli, quello che otteniamo è una rete a più livelli
- tralasciando il fatto della combinazione di input e pesi (visto come prodotto scalare) è la non linearità data dalle funzioni di attivazione

Una rete neurale è composta da diversi strati di pesi w che dato un input li trasformano man mano nell'output desiderato (vedremo come produrre l'output desiderato). Quindi quello che rappresenta una rete neurale è una famiglia di funzioni.

- famiglia perchè in base a come definiamo questi pesi (ciò che andremo ad imparare facendo il learning) noi esploreremo lo spazio di queste funzioni fino a quando non troviamo la funzione desiderata ovvero quella che produce l'output desiderato.

Lo scopo del ML è trovare la miglior funzione che risolve il task che si vuole risolvere e l'idea è che dato un esempio di allenamento, quindi training set, che associa degli input a degli output, il **goal del deep learning** è imparare questo set di parametri $\theta \equiv \{W^{(1)}, W^{(2)}\}$ in modo da massimizzare la probabilità che l'output della rete sia corretto dato l'input. Quello che definisce il modo in cui la rete apprende è la **funzione di loss**, quindi definire la discrepanza tra la predizione e il training set, quindi il vero valore che abbiamo associato agli esempi e questa funzione di loss rappresenta quello che stiamo sbagliando, dove in particolare vogliamo trovare quei parametri che minimizza questa funzione di loss. Questa è definita il più delle volte come una media degli errori che facciamo sui singoli esempi e quindi in sostanza quello che vogliamo minimizzare è appunto questa media.

- approccio più utilizzato è il **stochastic gradient descent (SGD)**, dove l'idea è trovare il minimo della funzione di cost della loss function utilizzando l'informazione che ci dà il gradiente.
- si parte da una parametrizzazione del tutto casuale della rete neurale che avrà un valore di loss molto alto sul training set, ne computiamo la derivata e cerchiamo di spostarsi nello spazio dei parametri, in modo tale da avvicinarci al minimo e lo si fa con questo algoritmo iterativo, dove
 - si parte da una guess dei parametri casuali
 - ciclando man mano sugli esempi del training ne peschiamo uno, ne calcoliamo il gradiente e ci spostiamo di un passo dato anche dal learning rate, quindi ci spostiamo di un po' verso il minimo locale e ripetiamo il procedimento

Il nome stocastico è dato perchè a differenza dell'approccio del gradiente totale che utilizza ad ogni passo tutto il training set, noi utilizziamo in questo esempio un solo esempio di training, ma dove di solito si usa un piccolo insieme di esempi, questo perchè vogliamo un trade-off tra veloce e accurati e la differenza tra come è l'andamento dei due algoritmi ovvero quello che utilizza il gradiente su tutto il training set (**full gradient**) e quello stocastico è che nel primo caso la discesa verso il minimo è molto più regolare dove ogni passo è costoso, ma nel secondo la discesa è molto più irregolare, soprattutto fino a quando non arriviamo vicino al minimo, dove l'andamento è molto veloce verso la zona dove c'è il minimo locale. Alle volte interessa non arrivare esattamente al minimo altrimenti staremo facendo overfitting.

- algoritmo stocastico non è ben visto nell'ambito matematico, ma per il ML sì

9.3.1 Definizioni e proprietà principali

La motivazione che sta dietro alla nascita del FL viene data a Google è il fatto che è diventato più difficile per i vari discorsi legati alla privacy, accedere ai dati per motivi di privacy e varie

legislazioni. L'idea è che i dati devono rimanere nei singoli nodi senza che venga distribuiti, ma che vengano usati localmente per fare learning.

Dall'altra parte c'è la necessità per metodi di deep learning aver bisogno di tanti dati per ottenere un apprendimento che sia ragionevole. Abbiamo queste due problematiche e quindi siamo costretti ad utilizzare meccanismi di learning distribuito e collaborativo che sia privacy preserving.

Abbiamo quindi il FD, visto come un set di ML dove più entità detti client collaborano per risolvere un problema di ML, dove solitamente sono coordinati da un server centrale chiamato aggregatore. La caratteristica fondamentale del FL è che i dati contenuti all'interno di ogni client non vengano distribuiti o scambiati tra le varie parti. Il learning è focalizzato su update (quindi aggiornamenti) del modello tramite update locali e aggregazioni a livello di server

- il server centrale, detto **aggregatore**, che orchestra il processo di learning, questo almeno nel FL centralizzato
- poi abbiamo i client chiamati anche **user**, nodi, che hanno i dati, quindi hanno solitamente un dataset relativamente piccolo e come numerosità abbiamo che possono essere
 - dalle decine fino alla centinaia, e siamo nel **cross-silo FL**
 - **cross-device FL**, milioni di utenti. Questo perché, l'idea che sta alla base del FL è utilizzare questa tecnologia ad esempio per andare a vedere come funziona G-board quando ci raccomanda parole per continuare il testo
- **horizontal FL**: esistono altre definizioni che riguardano piccole differenze del FL, dove in particolare riguardano l'orizzontale e il verticale. Questo sta ad indicare come ci immaginiamo essere diviso il dataset tra i diversi utenti in questo FL
 - se ogni utente ha un sottoinsieme degli esempi, **setting orizzontale**.
 - se invece ha tutti gli esempi (o gran parte degli esempi) ma solo un sottoinsieme delle features viene chiamato **setting vertical**

Noi ci concentreremo su **setting centralizzato cross-device e orizzontale**

9.3.2 Federated learning assumptions, goals & desiderata

Assumption

- i parametri del modello ovvero quelli scambiati tra le varie parti di questa rete, non contiene informazioni sui dati di training che sono all'interno dei client (vedremo come questa cosa non è vera)
- la dimensione del modello scambiata sia più piccola dei dati dei training, questo xk vogliamo che sia più efficiente dal punto di vista della comunicazione

Goal

- di avere privacy, visto che i client non distribuiscono i loro dati privati dovrebbe garantire in qualche modo un certo livello di pp
- deve essere utile, perché se partecipo al FL voglio che abbia in qualche modo un ritorno di utilità qualsiasi essa sia

Desiderata

- il modello che si impara utilizzando l'approccio federato sia molto simile o più vicino possibile allo stesso modello che avrei appreso centralizzando i dati.

9.3.3 FL: il protocollo generale

- abbiamo un server centrale, l'**aggregatore** e quattro nodi. L'aggregatore inizializza un modello globale (fatto in diversi modi, inizializzazione random) per il task che deve risolvere e lo condivide con i client
- quattro nodi che rappresentano i clienti, dove questi appena ricevono il modello aggiornano il modello ricevuto con i loro dati privati
- una volta che ogni client aggiorna il modello, ogni client invia il modello all'aggregatore che si ritroverà con un certo numero di modelli, li aggrega in un qualche modo e genera un nuovo modello globale
- il processo si ripete, inviando il modello aggiornato ai clienti, fino ad un certo criterio di convergenza

9.3.4 Cross-device FL: esempio giocattolo

1. il server inizializza il modello e lo invia a tre dei quattro client che partecipano alla federazione
 2. ogni client inizia a fare training e naturalmente non possiamo assumere che tutti riescano a terminare il training o che tutto vada a buon fine. Nell'esempio presentato in aula, l'utente verde riesce a terminare il training e restituisce il modello aggiornato al server. L'utente giallo fallisce e quindi non invierà nulla e quello rosso finisce ma con un tempo di training molto più elevato.
 3. Il server aggrega i due modelli ricevuti, crea il nuovo modello globale e lo invia ad un subset diverso di utenti, e così continua.
 4. ogni volta che avviene un'aggregazione finisce un round. Il FL avviene in round anziché in epoche se pensate invece al DL standard
- non tutti i client riescono a fare training, questo dovuto a varie ipotesi (batteria scarica del cellulare)

9.3.5 Federated Learning: major challenges

- ogni utente ha potenzialmente una distribuzione di dati molto diversa. Se stessimo facendo qualche tipo di learning sulle immagini, ogni client produrrà immagini molto diverse. Questa **NON-IID**, dati che non sono indipendenti e indicamente distribuiti, possono creare problemi durante il learning
- **sbilanciamento**, dove utenti possono produrre più dati rispetto ad altri
- **distribuito in maniera massiva**, perché il numero potenziale di utenti è maggiore rispetto al numero medio di esempio di training che ognuno di essi possiede
- **comunicazione limitata**, abbiamo a che fare con una rete di comunicazione che può essere instabile. Pensate soprattutto ad un setting federato in cui gli smartphone fanno parte della federazione.

9.3.6 Federated SGD: FedSGD

A bit of notation

- n : numero totale di esempi
- K : numero di client
- n_K : numero di esempi che ha il client
- η : learning rate
- T : numero totale di round
- t : round "corrente"
- w : d'ora in poi indica i parametri del modello (quindi il modello stesso)
- f : d'ora in poi, la funzione di loss

Approccio piu semplice per fare FL è il cosiddetto **Federated SGD: FedSGD**

- **osservazione**: un client selezionato random nel setting federato è equivalente ad un sample(o batch) di esempi nel DL standard
- **Federated SGD (FedSGD)**: ad ogni round fare un singolo step di discesa di gradiente utilizzando gli update fatti nei vari client e poi aggregati
- nel FL (come visto nell'esempio di prima) solo una frazione di client partecipa al round. Pensate a Google con milioni di device, non può aspettare i cazzi di un device.
 - ci sono dei criteri per essere leggibili per partecipare da un punto di vista attivo nel FL. Un device obsoleto non viene utilizzato poichè la batteria non dura tanto. Quindi criteri per selezionare device che sia ad esempio in carica, potenza di calcolo ecc..
 - se abbiamo che la frazione di utenti è la totalità stiamo in setting quasi **full-batch (non-stochastic) gradient descent**, tuttavia non realistico e quindi la frazione C è molto piccola rispetto alla totalità

9.3.7 Funzionamento di FedSGD

- assumiamo sempre che il server abbia inizializzato i pesi in qualche modo
- per ogni round quello che viene è
 - l'aggregatore fa broadcast del modello globale
 - ogni client computa il gradiente con i suoi dati locali

Adesso abbiamo due alternative:

1. cliente invia direttamente il gradiente al server e questo aggiorna i pesi utilizzando il gradiente della funzione loss computato come la media pesata dei gradienti dei singoli client. Nel nostro esempio è pesata sul numero di esempi. Si potrebbe anche omettere il peso e fare la media perdendo un po di accuratezza
2. il client una volta computato il gradiente aggiorna i propri pesi e invia il modello aggiornato all'aggregatore (server)

FedSGD non vede nessuna differenza, entrambe le alternative sono valide. Da un punto di vista matematico non cambia nulla. Quello che però vedremo è che l'approccio **(alternativa 2)** lo si può generalizzare e ottenere il **Federated Averaging: FedAvg**

9.3.8 Federated Averaging: FedAvg

Il FedSGD dal punto di vista della comunicazione è altamente inefficiente. Perché ad ogni computazione del gradiente c'è una comunicazione avanti e indietro di tutto il modello che stiamo allenando. Non è desiderabile e quindi come si procede?

- o si seleziona più utenti possibili in modo tale che ogni passo sia sempre accurato
- oppure facciamo più computazioni nel singolo client, quindi anziché fare la computazione per ogni singolo gradiente, facciamo più epoche nei vari clienti.

Quello che cambia rispetto a prima è che una volta che il client computa il gradiente utilizza l'alternativa 2 precedentemente introdotta nel FedSGD, ovvero il client computa direttamente l'update del modello ma lo fa per più epoche, quindi continua a computare il gradiente e modificare il modello. Una volta fatto questo invia il modello al server e quest'ultimo lo aggrega

- se il numero di epoche è uguale a 1 e la batch size è n_k (ovvero gli esempi che sono all'interno del client) stiamo facendo FedSGD

FedAvg funziona bene in pratica, tuttavia se il numero di epoche è maggiore di 1 non garantisce una convergenza lineare anche con funzioni di loss che sono fortemente convesse e smooth.

Intuizioni del perché questa cosa potrebbe non convergere in maniera lineare viene visto in figura

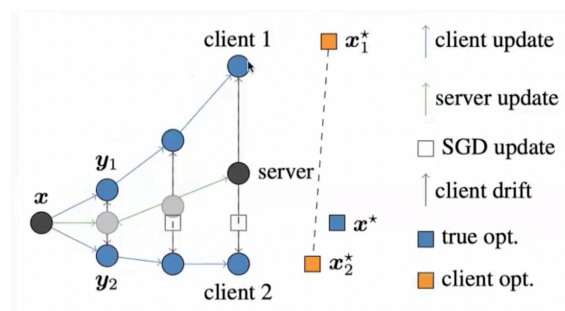


Figure 9.1: Funzionamento di FedAvg

Dove i parametri sono x, y . A partire dallo stesso modello x se continuo a fare epoche sul client 1 quello che succede che la traiettoria che fanno i pesi per quel client verso client 1 (traiettoria che segue $y1client1$). Differentemente per il client 2 la traiettoria che fa è quella in basso, naturalmente se fa update su quei dati. Come potete vedere, l'ottimo che vorremmo ottenere è x^* . Quello che succede che man mano che l'aggregatore aggrega questi pesi più epoche faccio più potenzialmente mi sposto da quella che è la traiettoria ottima. Si nota come il primo passo corrisponderebbe al passo ideale di SGD. La divergenza accade. La divergenza si verifica per il fatto che i dati sono **NON-IID**, dove la distribuzione dei dati nei singoli client potrebbe essere molto diversa e quindi la stima del gradiente della loss è molto diversa e potrebbe divergere.

9.3.9 Il Federated Learning Decentralizzato

FL non centralizzato, dove tutti avviene attraverso la comunicazione tra client (server non c'è). Un modo per fare federated learning decentralizzato è il cosiddetto **gossip learning**, dove

- ogni nodo inizializza un modello in modo random localmente o in accordo

- ogni nodo seleziona un suo peer manda il proprio modello (eventualmente potrebbe anche comprimerlo) dove rimane in attesa di ricevere modelli da altri nodi
- ogni volta che il modello viene ricevuto, se ne fa merge, update e si continua con questo protocollo

Gossip Learning funziona ovviamente con tutti i difetti del FL in generale e non abbiamo un server centrale.

9.4 Privacy in Federated Learning

Parliamo di privacy, abbiamo visto come il FL utilizza come unica arma per fronteggiare la privacy è che i dati non vengono condivisi con nessuno ma vengono utilizzati per modificare il modello.

- la speranza è che il fatto di condividere un modello allenato sui propri dati non faccia leak d'informazione sui dati che ho localmente.

Il modello può dire qualcosa sui dati di training di cui è stato allenato? Sì. E abbiamo un teorema che dimostra che per

- per reti neurali dove ogni layer è fully-connected si può ricostruire (se si assume che esistono gradienti non zero) l'input in maniera precisa. In questo caso questo teorema lo dimostra se faccio l'update con un singolo esempio si riesce a ricostruire, ovviamente i singoli update si fanno su batch di esempi, tuttavia non esiste un teorema così forte, ma si può mostrare che si può costruire parte degli esempi di training. Sostanzialmente l'assunzione che fa il FL per difendere la privacy **non è vera**. Questo fa sì che ci siano degli attaccanti che sfruttino la cosa.

9.4.1 Tipi di attacchi nel FL

Possiamo avere degli attaccanti per eludere la privacy tra chi partecipa alla federazione

- **semi-honest**, visto in precedenza, dove l'attaccante partecipa in maniera onesta al protocollo però ogni qualvolta riceve un modello, può fare degli analisi per estrarre delle informazioni sul modello ricevuto. Fintanto che è un nodo che partecipa al FL è un po' più difficile, perché a lui arriva sempre un modello aggregato tra tutti gli utenti, tuttavia il server riceve l'update dei singoli, quindi può fare inferenze mirate
- attaccante malizioso, dove oltre a fare questo tipo d'analisi, partecipa in maniera non corretta al protocollo, ad esempio modificando il modello che invia al server, in modi strategici in modo tale che al round successivo riesce ad ottenere informazioni possibili o in altri casi l'attaccante può definire un modello di ML per estrarre informazioni da modelli condivisi.

Ci sono due attacchi principali che utilizzano questo flow, del fatto che il modello può avere informazioni sui dati di training. Attacchi simili nell'idea ma diversi per quanto riguarda l'implementazione

- **membership inference**, capire che dati degli esempi capire se questi sono stati utilizzati per fare training
- **model inversion**, imparare quelli che sono stati i dati utilizzati per fare training. Solitamente si crea un modello di ML che utilizzando la rete sia in modo **black box**, provando a dare degli esempi vedendo cosa dà in output, oppure se partecipa alla federazione, ha la rete vera e propria con i singoli pesi e quindi montare un attacco più sofisticato facendo considerazioni sui vari pesi o gradienti

TUTTO QUESTO PER DIRE CHE C'È BISOGNO DI AVERE OLTRE AL PROTOCOLLO FEDERATO ANCHE DEI MECCANISMI DI DIFESA.

Tutto questo per dire che c'è bisogno di avere, oltre al protocollo federato, anche dei meccanismi di difesa. Noi ci baseremo su quei meccanismi basati sulla statistica e crittografia, dove vedremo in particolare un esempio di Secure Multiparty Computation semplice

9.4.2 Homomorphic encryption

- fare delle operazioni matematiche su dati che sono criptati, ottenere un risultato e questo sarà la versione criptata di quei dati che avremmo ottenuto se avessimo fatto la stessa operazione su dati in chiaro. Sfortunatamente vale per un sottoinsieme di operazioni (addizione e moltiplicazioni) e queste spesso sono sufficienti per fare quello che bisogna fare
- l'idea è che i **client** criptano i modelli che inviano al **server**, questo li deve solo aggregare, li aggrega criptati, fa broadcast del modello e poi i singoli client decripta il modello, fa update, criptarlo e inviarlo al server.
- in questo caso non ci fidiamo del server e tutto quello che gira nella rete è criptato con **homomorphic encryption**.

Problemi dell' homomorphic encryption

- super dispendioso dal punto di vista computazionale. a questo aggiungi che la maggior parte di nodi che partecipano alla federazione sono spesso smartphone questa cosa non si può fare

Altro meccanismo di difesa è la DP, dove questa può essere applicata o in maniera Globale o in maniera Locale

- **Local Differential Privacy**, i singoli clienti prima di condividere modelli o gradienti applicano del *noise* in modo tale da rendere più difficile l'attacco del server. Problema è che ogni volta fare update e add noise rende il learning meno efficace
- **Global Differential Privacy**, il noise è aggiunto dal server anziché del client. Il server una volta ricevuto, aggrega, fa del noise e fa broadcast. L'aggiunta del noise crea sempre problema, ma comunque è molto meno che farlo per ogni singolo update per ogni singolo client

9.4.3 Secure Aggregation (& SMC)

- si vuole computare un aggregato tra varie parti che non si fidano l'una dell'altra senza rivelare le singole parte che caratterizzano l'aggregato. Esempio considerando la somma, vogliamo computare la somma senza dire quelle che sono le parti che compongono questa somma.
- in generale, i singoli client inviano il modello con una sorta di **maschera**, dove quest'ultima è computata con le parti che partecipano all'aggregazione, in modo tale che una volta aggregato i risultati mascherati si elidono l'uno con l'altro e il risultato è l'aggregazione senza la maschera

Esempio di applicazione

- tutte le parti partecipano al protocollo (primo problema) e che ci sia una comunicazione sicura tra le parti

1. singoli utenti a coppie si concordano per una perturbazione (definita come una sorta di maschera) definita come un vettore (vogliamo computare una somma tra vettori) ed è pescata tra un'intervallo di interi $[0, R)^k$
2. per ogni utente
 - u e v si scambiano questa perturbazione dove $s_{u,v}, s_{v,u}$ sono diverse e ne computano la differenza modulo r $p_{u,v} = s_{u,v} - s_{v,u} \pmod{R}$
 - si nota come $p_{u,v} = -p_{v,u} \pmod{R}$ sono l'opposto modulo r (abbiamo girato di segno in questa differenza)
 - la perturbazione che l'utente fa con se stesso è 0, $p_{u,v} = 0$, quando $u = v$
3. ogni utente manda all'aggregatore, il proprio contributo x_u più la somma di tutte le perturbazioni con gli utenti modulo R
 $y_u = x_u + \sum_{v \in \mathcal{U}} p_{u,v} \pmod{R}$, dove y_u è il contributo aggregato dell'utente u
4. una volta che il server riceve tutto, fa la somma perturbata modulo R e quello che succede è che $\bar{x}$ è esattamente la somma degli x_u , questo perchè è facile dimostrare che le perturbazioni si elidono una volta aggregate tutte

Questo garantisce privacy perfetta, ma il problema è che stiamo considerando che tutti partecipino, ma anche se ci fosse la volontà di partecipare, il problema è che stiamo in un ambiente dove la comunicazione non è stabile, ma comunque ci sono dei meccanismi per riuscire a computare questo tipo di **secure aggregation** in caso di utenti che se ne vanno o falliscono. Tuttavia per gestire questa cosa non c'è più privacy perfetta ma comunque meno rispetto al caso ideale.

Per concludere il DF è usato?

Solo google per la GBoard ovvero predire le parole che scriviamo in chat.

Per concludere abbiamo che il federated learning è un passo verso un approccio verso privacy-preserving per fare collaborative learning. Non è perfetto e ha un sacco di challenges che devono essere risolte. Dal punto di vista della privacy il federated learning da solo non è sufficiente e i meccanismi allo stato dell'arte sono buoni per garantire privacy ma hanno dei drawbacks sia dal punto di vista computazionale che dal punto di vista dell'accuratezza.